



MASTER THESIS

Measuring the Quality of Threat and Risk Analysis

submitted by:

Arshathul Mohamed Haq Bahadur Ibrahim Khalifullah

Matriculation number: 200494

Submitted on: 07.08.2026

Examiner: Prof. Dr. Jianmin Chen
Supervisor: Prof. Dr. Jianmin Chen (HDBW)

Eidesstattliche Erklärung / Affidavit

Hiermit versichere ich, dass die vorliegende Arbeit ohne Hilfe Dritter und nur mit den angegebenen Quellen und Hilfsmitteln angefertigt wurde. Alle Gedanken, die direkt oder indirekt aus externen Quellen stammen, sind entsprechend gekennzeichnet.

Ich bestätige, dass ich bei der Erstellung dieser Arbeit Künstliche Intelligenz-Tools zur Entwicklung von Ideen verwendet und die entsprechenden Tools im KI-Verzeichnis aufgeführt habe.

Ich bin mir bewusst, dass diese Arbeit auf die Verwendung nicht autorisierter Mittel überprüft und daraufhin kontrolliert wird, ob sie teilweise oder vollständig plagiiert ist. Um meine Arbeit mit bestehenden Quellen zu vergleichen, gestatte ich, dass sie in eine Datenbank aufgenommen wird und dort verbleibt, um künftig eingereichte Arbeiten auf Plagiate zu überprüfen. Weitere Rechte zur Vervielfältigung oder Verwertung werden nicht gewährt.

Diese Arbeit wurde, in gleicher oder ähnlicher Form, bisher noch nicht einer Prüfungsbehörde vorgelegt oder veröffentlicht.

Declaration on Thesis

I hereby certify that this work was completed without the help of third parties and only with the sources and resources indicated. All ideas that originate directly or indirectly from external sources are properly denoted as such.

I acknowledge the use of artificial intelligence tools to develop ideas in the creation of this work and have listed the respective tools in the AI directory.

I am aware that this work will be screened for the use of unauthorized means and subsequently be checked for partial or complete plagiarism. In order to compare my work with existing sources, I consent to it being included in a database and remaining there for the purpose of checking future submissions for plagiarism. Any other rights of reproduction or exploitation are not granted.

This work has, in the same or in a similar form, not previously been submitted to an examination authority or published.

Arshathul Mohamed Haq, Bahadur Ibrahim Khalifullah

München, 07.08.2026

AI-Based Tools Directory

The following digital and AI-assisted tools were used during the preparation of this thesis. Their use was limited to the tasks stated below.

Tool	Category	Main task
GitHub Copilot	AI coding assistant	Debugging the PoC source code.
ChatGPT	Generative AI assistant	Literature discovery and summarisation; support in understanding academic sources; and generation of L3 comparison Report A using GPT-5.4.
Claude Sonnet 4.6	Generative AI assistant	Generation of L3 comparison Report C against the shared criterion catalogue.
Consensus	AI-assisted academic search tool	Finding relevant academic papers and supporting the understanding of their findings.
Internal TRA AI skill (anonymised)	AI-assisted industrial workflow	Operational pilot integrating the metric checker into TRA authoring. Generated feedback was reviewed by the involved project experts.

Author's responsibility. The research design, qualitative coding of the interview material, comparison of the L3 reports, interpretation of the evidence, and scientific conclusions are the author's own. The AI-generated reports were treated only as evaluation artefacts. All AI-assisted material incorporated into the thesis was reviewed, verified, and, where necessary, corrected by the author, who takes full responsibility for the content of this thesis.

Abstract

CPS and ICS connect software and communication networks with physical processes, so cyber incidents can disrupt production, damage equipment, or affect safety. TRA supports system scoping, the identification of assets, components, interfaces, and threats, and the justification of risk ratings and treatments. However, a completed TRA may appear comprehensive while omitting interfaces, threat coverage, trace links, or adequate justification. In the industrial setting examined, reviews rely heavily on expert experience, so such weaknesses may be assessed inconsistently or remain undetected.

This thesis develops a structured, measurable, and partly automatable approach for assessing TRA quality. Rather than introducing another threat-modelling method, it translates recurring expert review logic into explicit and repeatable criteria.

The study combines a literature review with five semi-structured expert interviews, analysed through hybrid deductive and inductive content analysis. The industrial evidence was collected from an anonymised industrial-automation setting within a large multinational industrial technology company. The resulting catalogue contains 32 criteria: 17 automatic, 11 semi-automatic, and four requiring expert judgement. The 28 automatic and semi-automatic core criteria were implemented in a PoC checker for structured TRA data in JSON format. The implemented checker is transparent and rule-based. It does not use AI to determine criterion results.

Evaluation comprised thirteen controlled defect variants of a public MiniCPS/SWaT-derived TRA, applications to confidential internal TRAs and written feedback from six practitioners. As a secondary exploratory lens, two AI-assisted reports were compared with the deterministic report for one shared case. This comparison illustrates differences between assessment approaches and is not used to validate the framework. Every degraded variant lowered at least one targeted status band. Against the predeclared target map, the mutation experiment achieved a precision of 0.905, a recall of 0.950, and an F_1 score of 0.927.

The findings show that automated checks can reveal structural completeness and consistency gaps, but semantic adequacy, technical plausibility, and contextual risk decisions still require expert judgement. Within its case-based scope, the framework supports more transparent, comparable, and repeatable reviews of completed TRAs.

Contents

Eidesstattliche Erklärung / Affidavit	i
AI-Based Tools Directory	ii
Abstract	iii
List of Figures	viii
List of Tables	x
List of Listings	xi
List of Abbreviations	xii
1 Introduction	1
1.1 Background and Motivation	1
1.2 Problem Statement	2
1.3 Research Objective	3
1.4 Research Questions	3
1.5 Research Approach	3
1.6 Scope of the Thesis	4
1.7 Significance of the Study	5
1.8 Structure of the Thesis	5
2 Conceptual Foundations	6
2.1 Purpose and Scope	6
2.2 TRA as an Analytical Artefact	6
2.3 TRA in CPS and ICS Literature	7
2.4 Quality as a Concept for Analysis Evaluation	7
2.5 Metrics and Measurement Theory	8
2.6 Expert Knowledge and Analysis Logic	9
2.7 Implications for Measuring TRA Quality	10
2.8 Chapter Summary	10
3 State of the Art and Related Work	11
3.1 Measurable Quality Indicators	11
3.2 Repeatable Metrics	11
3.3 Automated Checking of Completeness and Consistency	12

3.4	Research Gap	12
3.5	Chapter Summary	13
4	Research Methodology	14
4.1	Research Design	14
4.2	Methodological Procedure	14
4.3	Expert Interview Study	16
4.4	Data Analysis	18
4.5	Artefact Derivation and Operationalisation	18
4.6	Evaluation Strategy for the Artefact	19
4.7	Trustworthiness, Ethics, and Limitations	19
4.8	Chapter Summary	20
5	Interview Findings	21
5.1	General Characterisations of TRA Quality	21
5.2	Participation and Process	22
5.3	Formal Completeness	22
5.4	Coverage	23
5.5	Consistency and Traceability	24
5.6	Comprehensibility	25
5.7	Process and Governance	25
5.8	The Question of Measurability and Automation	26
5.9	Synthesis of Derived Quality Dimensions and Criteria	26
5.10	Chapter Summary	28
6	Quality Model and Evaluation Framework	29
6.1	Structure of the Quality Model	29
6.2	Criterion Attributes	30
6.3	Degrees of Automation	30
6.4	The Consolidated Criterion Catalogue	31
6.5	Scoring Scheme	33
6.6	Threshold Selection and Rationale	34
6.7	Evaluation Pipeline	36
6.8	Inputs, Representation, and Schema Dependence	38
6.9	Relationship to Existing Maturity and Standards Models	38
6.10	Chapter Summary	39
7	PoC Implementation	40
7.1	Implementation Goals and Technology Choice	40
7.2	Public Case Under Analysis: MiniCPS	41
7.3	Architecture and Data Flow	41
7.4	Structural Schema Abstraction	41
7.5	Core Criterion Algorithm Families	42

7.5.1	Family A — Ratio and Coverage Criteria	42
7.5.2	Family B — Presence, Placeholder, and Entry-Gate Checks	44
7.5.3	Family C — Descriptive-Adequacy and Structure Checks	45
7.5.4	Family D — Rule-Based Threat Specificity (CM-17)	45
7.5.5	Family E — Pairwise Similarity and Rating Agreement	46
7.5.6	Family F — Risk-Matrix Coherence (CM-20)	47
7.5.7	Family G — Governance and Rating-Distribution Checks	47
7.6	Grading and Aggregation	48
7.7	Reference Corpus and Configurable Thresholds	49
7.8	Output and Reporting	49
7.9	Implementation Verification and Traceability	50
7.10	Confidentiality-Preserving Design	51
7.11	Chapter Summary	51
8	Evaluation	52
8.1	Objectives and Evaluation Design	52
8.1.1	EO1–EO4	52
8.1.2	The Three Evidence Lenses	52
8.1.3	Objective-to-Evidence Mapping	53
8.2	Metric Descriptions and Calculation Overview	54
8.3	EO1: Automation Scope	54
8.4	EO2: Detection Validity through Controlled Mutation (L1)	55
8.4.1	Case Selection: Why MiniCPS	55
8.4.2	Modelling MiniCPS as a TRA	56
8.4.3	Method and Hypotheses	56
8.4.4	Injected Defect Classes	57
8.4.5	Analysis and Central Result	58
8.4.6	Threshold Sensitivity	60
8.5	EO3: Usefulness and Interpretability in Practice (L2)	62
8.6	EO4: Reviewer-Expectation Alignment and Evidential Classification	64
8.6.1	L2 Expectation Analysis	64
8.6.2	Refinement Commitments	70
8.6.3	Metric Classification	70
8.6.4	L3: Descriptive AI-Assisted Comparison	72
8.7	Threats to Validity	74
8.8	Chapter Summary	75
9	Discussion and Future Work	76
9.1	Revisiting the RQs	76
9.2	Industrial Perspective	77
9.3	Academic Perspective	78
9.4	Limitations	79

9.5 Reflection on Key Challenges	80
9.6 Recommendations	81
9.7 Future Work	82
9.8 Chapter Summary	83
10 Conclusion	85
References	87
A Semi-Structured Interview Guide	90
B TRA Quality Criterion Catalogue: Definitions and Automation Classes	93
C MiniCPS Reference TRA: Structured Summary	96
D Reproducibility and Artefact Statement	98
E Mutation Operators and Predeclared Target Map	100
F Per-Variant Detector Classification	101
G L3 Comparison Protocol and Agreement Computation	102
G.1 Report Sources	102
G.2 Label Normalisation	102
G.3 Agreement Computation	103
G.4 Validity Threats Specific to L3	104
H Threshold Sensitivity Sweep Design	105
I Worked Example: Reference Scorecard	106

List of Figures

Figure 4.1	Research design	16
Figure 6.1	Evaluation pipeline	37
Figure 7.1	Implementation data flow	41
Figure 7.2	Overall TRA-quality indicator and per-dimension scorecard summary generated by the prototype for the MiniCPS reference case.	50
Figure 7.3	Representative excerpt from the detailed core-metric scorecard in the HTML report, including criterion status and expandable pass/fail evi- dence.	50
Figure 8.1	Mutation delta matrix	58

List of Tables

Table 2.1	Derivation of candidate TRA quality dimensions	9
Table 3.1	Synthesis of related work for TRA quality evaluation	13
Table 4.1	Interview participants	17
Table 5.1	Synthesis of interview findings into quality dimensions and criteria . .	27
Table 6.1	Dimensions of the TRA quality model	29
Table 6.2	Consolidated TRA quality criterion catalogue	32
Table 6.3	Prototype threshold defaults used by the computed criteria	35
Table 7.1	Algorithm families and the core criteria they compute	43
Table 7.2	Traceability from implementation commitments to verification evidence	50
Table 8.1	The three evidence lenses used in this chapter	53
Table 8.2	Objective-to-evidence mapping	53
Table 8.3	Evaluation-oriented calculation patterns for the implemented core criteria	54
Table 8.4	Automation scope of the criterion catalogue by quality dimension . . .	55
Table 8.5	Mapping of MiniCPS/SWaT elements onto the TRA schema	56
Table 8.6	Degraded variants and their targeted quality dimension	57
Table 8.7	Overall indicator and criteria affected by each degraded variant (reference V0 scores 89.6)	59
Table 8.8	Overall indicator for a clean, a mildly damaged, and a heavily damaged TRA under three joint low, default, and high threshold configurations .	61
Table 8.9	Boundary-adjacent audit of threshold-dependent signals	61
Table 8.10	Reviewer expectation and observed tool behaviour, with gap class and refinement direction (EO4)	65
Table 8.11	Classification of core criteria by evidential character	71
Table 8.12	L3 shared-criteria status comparison on the same TRA artefact	73
Table 9.1	Synthesis of RQs, evidence, and answer strength	76
Table B.1	Definitions, measurement summaries, and automation classes of the TRA quality criteria	93
Table C.1	Security zones (Purdue levels) of the reference model	96
Table C.2	Components, assets, and protection goals of the reference model . .	97

Table C.3	Threat scenarios of the reference model	97
Table E.1	The thirteen mutation operators and their design-intent target criteria .	100
Table F.1	Detector classification per variant (status-band level)	101
Table G.1	The three L3 reports, the tool that produced each, and its evidential basis.	102
Table G.2	Normalisation of raw report verdicts onto the common scale used for the agreement computation.	103
Table G.3	Per-criterion derivation of the exact-label agreement figures from Table 8.12. Columns A/B/C give the normalised level; the last three columns mark whether each pair matches.	103
Table H.1	Threshold sweep ranges (default column = prototype value of Section 6.6)	105
Table I.1	Reference-TRA (V0) scorecard as produced by the analyser	106

List of Listings

7.1	Structural detection of the component container, independent of target area .	42
7.2	Covered-fraction computation (CM-07 shown; other Family A criteria substitute their own relevant and satisfied sets)	43
7.3	Exact matrix-cell and rationale verification for CM-20	47
7.4	Traffic-light grading using the cut-offs of Section 6.5	48
D.1	Copy-paste reproduction commands, run from the project directory	99

List of Abbreviations

ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge (MITRE)
CAPEC	Common Attack Pattern Enumeration and Classification
C/I/A	Confidentiality, Integrity, and Availability
CM	Criterion Metric (quality criterion identifier in the catalogue)
CPS	Cyber-Physical System
CWE	Common Weakness Enumeration
EO	Evaluation Objective (framed as a scoped yes/no question)
FN	False Negative
FP	False Positive
HMI	Human-Machine Interface
ICS	Industrial Control System
IEC	International Electrotechnical Commission
ISO	International Organization for Standardization
JSON	JavaScript Object Notation
MiniCPS	Open-source toolkit for security research on cyber-physical system networks
PLC	Programmable Logic Controller
PoC	Proof of Concept
RQ	Research Question
SCADA	Supervisory Control and Data Acquisition
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege
SWaT	Secure Water Treatment (testbed)
TP	True Positive
TRA	Threat and Risk Analysis

1 Introduction

1.1 Background and Motivation

TRA is part of everyday cybersecurity engineering for CPS and ICS. These systems are used in manufacturing, energy, transport, water treatment, and other process industries. Their software and communication networks interact with sensors, controllers, actuators, and physical processes. Security in this setting extends beyond information protection. A cyber incident may interrupt production, alter a process, damage equipment, affect the environment, or endanger people.

These consequences shape the priorities of industrial security. Confidentiality is often prominent in conventional enterprise IT, whereas industrial environments place particular weight on availability, reliability, predictable behaviour, and safety. Weaknesses that might cause data loss in an office system can have direct operational or physical effects in an ICS (Stouffer et al., 2023).

Industrial networks are no longer as isolated as many original designs assumed. Connections to enterprise networks and remote-access services have widened the attack surface (McLaughlin et al., 2016). Stuxnet demonstrated that an attack on industrial control technology could be designed to produce a deliberate physical effect (Langner, 2011). The history of SCADA exploitation also shows persistent attack vectors and recurring patterns across industrial systems (Anton et al., 2017).

Many CPS and ICS support critical infrastructure and services whose disruption can affect society beyond the organisation that operates them. The EU Critical Entities Resilience Directive establishes an all-hazards framework for entities providing essential services, while the NIS2 Directive requires essential and important entities within its scope to apply cybersecurity risk-management measures and report significant incidents. Its measures include policies on risk analysis, incident handling, business continuity, and supply-chain security (European Parliament and Council of the European Union, 2022a, 2022b). TRA quality is therefore relevant not only to engineering decisions, but also to operational resilience and regulatory accountability.

Geopolitical tensions add a strategic dimension to this exposure. State-linked cyber operations frequently follow geopolitical priorities, while ideologically motivated groups use disruptive activity to advance political messages (European Union Agency for Cybersecurity, 2025). For industrial and critical systems, cyber access can therefore be weaponised as an instrument of pressure against essential services. A credible TRA must consequently consider capable adversaries, external dependencies, and threat scenarios whose effects may extend across organisational and sector boundaries.

TRA now routinely informs product development and solution delivery. It supports architectural decisions, the choice of security controls, risk treatment, compliance work, and communication with customers or assessors (IEC, 2018, 2020). Those decisions are only as dependable as the analysis behind them.

A completed TRA is more than a collection of threats and risk ratings. It forms a chain from the documented scope and system model, through components, interfaces, assets, and threat scenarios, to protection goals, ratings, controls, and decisions about the risk that remains after treatment. Protection goals state the security properties that the analysis is intended to preserve. A missing or weak link can make later conclusions difficult to verify even when all expected sections appear to be present. Formal completion alone is therefore not sufficient evidence of quality.

Producing a TRA does not, by itself, guarantee a sound result. Analysts work with different levels of experience and with system information that may be incomplete or uneven. Two people can examine the same system and arrive at analyses with different coverage, assumptions, and levels of justification. Interfaces may be overlooked, protection goals may remain disconnected from threats, and important reasoning may remain in the analyst's head rather than in the document.

This study treats the completed TRA document, its structured data, and its supporting evidence as the objects of review. Their coverage, consistency, traceability, and clarity can be examined separately from the risk level assigned to the system. Reviewing these properties makes weaknesses visible and provides a more transparent and repeatable basis for judging whether the analysis is dependable.

1.2 Problem Statement

Established standards and methods explain how a risk analysis should be conducted, including the activities and documentation expected for industrial system design (IEC, 2020). They do not, however, provide a practical method for determining the quality of the completed TRA. Existing reviews concentrate primarily on methods and tools for conducting threat modelling and risk assessment (Cherdantseva et al., 2016; Granata & Rak, 2024). They give less attention to the completed analysis as an object that must itself be evaluated.

Within the industrial setting examined in this thesis, the finished TRA is commonly judged through expert review, as the interview findings in Chapter 5 confirm. A reviewer may check whether threats are missing, whether network-facing interfaces have been considered, whether assumptions and ratings are justified, and whether threats are linked to protection goals. These checks are valuable, but the criteria, required evidence, and thresholds behind them are not always stated.

Reviewers may therefore reach a similar overall judgement for different reasons, or apply different expectations to comparable projects. This weakens consistency between teams and makes a review difficult to reproduce. It also allows an apparently complete TRA to

conceal omissions or poorly supported conclusions. In an industrial setting, where the result may influence safety, operations, compliance, and risk acceptance, that uncertainty matters.

The research problem is therefore the lack of an operational evaluation framework for completed TRAs identified in the literature reviewed for this thesis. Such a framework must make expert review criteria explicit, connect each criterion to observable evidence and a repeatable measure, and distinguish checks that can be automated from judgements that still require technical and contextual expertise. The focus is the quality of the completed TRA and its documented evidence, not the general importance of risk analysis or the development of another threat modelling method.

1.3 Research Objective

The objective is to develop and evaluate a structured approach for assessing the quality of completed TRAs in CPS. The study produces a catalogue of quality criteria grounded in literature and industrial review practice. It defines the evidence and assessment logic associated with each criterion and implements the 28 automatic and semi-automatic core criteria for structured TRA data in JSON format. The intended outcome is a transparent and repeatable review aid. It should identify detectable quality gaps while preserving expert judgement for technical and contextual interpretation.

1.4 Research Questions

The investigation is guided by three RQs:

RQ1: What measurable quality indicators, derived from expert knowledge and literature, can be used to assess TRA quality in CPS?

RQ2: How can expert-based evaluation of TRA quality be translated into systematic and repeatable metrics for CPS?

RQ3: To what extent can automated checks, based on the metrics derived for RQ2, identify gaps in TRA completeness and consistency for CPS environments?

The questions build on one another. RQ1 identifies what should be assessed, RQ2 asks how those observations can be formalised, and RQ3 examines which parts of the resulting framework can be checked automatically.

1.5 Research Approach

The research design follows the progression of the three RQs and combines qualitative inquiry with design-science development and evaluation. For RQ1, a review of TRA, industrial cybersecurity, quality models, and measurement literature establishes the conceptual basis. Five semi-structured expert interviews provide the practice-based view of how completed TRAs are reviewed and which weaknesses practitioners repeatedly encounter. The interview material is examined through hybrid deductive and inductive content analysis, allowing

concepts from the literature to be considered alongside concerns emerging from professional experience.

For RQ2, the literature and interview findings are consolidated into a catalogue of quality criteria. Each criterion connects a quality concern to required evidence, relevant input data, assessment logic, and a degree of automation. A metric may therefore be a numerical ratio, a rule-based test, or an indicator of a property that remains for expert assessment. The 28 core criteria are implemented in a PoC checker that processes TRA data in JSON format. This representation makes scope elements, components, interfaces, assets, threats, assumptions, protection goals, ratings, and controls available as explicit fields and relationships.

RQ3 is examined through three complementary forms of evaluation. First, controlled defects are introduced into a reference TRA derived from the public MiniCPS framework and SWaT testbed (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016). Comparing the reference with each modified variant shows whether the checker responds to the intended weakness and whether unrelated criteria are affected. Second, confidential internal TRAs test whether the same criteria produce interpretable findings in genuine working contexts, with feedback from five interview participants and one additional practitioner reviewer. Third, the AI-assisted comparison contrasts two separately generated AI-assisted interpretation reports with the report generated directly by the implemented rule set for the same TRA dataset.

This sequence provides a traceable path from the evidence used to identify quality concerns, through their formalisation and implementation, to the evaluation of the resulting checks. The industrial application and report comparison provide case-based evidence. They are not treated as broad statistical validation. The boundaries of these claims are defined in the following section.

1.6 Scope of the Thesis

The unit of analysis is a completed TRA for a CPS or related industrial system, represented by its documented content and structured data. The assessment concerns the quality of that analysis, including its completeness, coverage, consistency, traceability, comprehensibility, and available governance evidence. It does not assess the absolute security of the system or the correctness of every engineering decision.

The study does not introduce a new threat-modelling technique, generate threat scenarios, or define a general risk assessment method. The PoC demonstrates automatic and semi-automatic checks on a defined JSON schema. It is not a production-ready review platform and does not claim coverage of every industrial domain, standard, document format, diagram, or source of external evidence. Semantic adequacy, technical plausibility, and context-dependent risk acceptance remain expert responsibilities.

Industrial confidentiality is part of the study boundary. Organisational evidence is reported only at aggregate or anonymised level. The partner organisation is anonymised and described only through characteristics relevant to the research context. The specific organisational units, participants, customers, projects, products, components, threat texts, ratings, confidential source-file names, and raw interview material are not disclosed. Detailed examples and reproducible artefacts use the public MiniCPS/SWaT case. Organisational tools and workflows are described generically or by anonymised labels, consistent with Sections 4.7 and 7.10.

1.7 Significance of the Study

The academic contribution is an explicit link between expert conceptions of TRA quality and observable properties of a completed analysis. By separating the quality of the analysis from the level of risk it reports, the study provides a basis for defining, discussing, and testing review criteria rather than treating quality as an undocumented overall impression. The criterion catalogue also records how each concern is connected to evidence, assessment logic, and automation potential.

The practical contribution is a review structure that produces criterion-level reasons for its findings. This makes omissions and inconsistencies easier to locate, supports comparison between reviews, and provides a clearer basis for discussing corrective action with analysts and decision-makers. Automated checks handle repeatable structural questions, allowing expert attention to concentrate on meaning, technical plausibility, and system context.

1.8 Structure of the Thesis

The document contains ten chapters. Chapter 2 develops the conceptual foundation by reviewing industrial TRA practice, quality models, measurement theory, and the formalisation of expert knowledge. Chapter 3 positions the research against related work and identifies the gap addressed by the study. Chapter 4 explains the qualitative and design-oriented methodology, and Chapter 5 presents the interview findings.

The quality model and criterion catalogue are developed in Chapter 6. Chapter 7 describes the PoC implementation, followed by the four-objective, three-lens evaluation in Chapter 8. Chapter 9 interprets the results, states the limitations, and identifies future work. Chapter 10 closes the study by answering the research problem and summarising its contribution.

2 Conceptual Foundations

2.1 Purpose and Scope

Building on the research problem and questions introduced in Chapter 1, this chapter develops the concepts needed to discuss TRA quality in CPS and ICS. It is not intended as a general survey of industrial cybersecurity. The narrower purpose is to establish what it means to treat a completed TRA as an object of evaluation.

Four areas of research are relevant. Work on CPS and ICS risk analysis explains the features that distinguish industrial assessments from conventional IT analysis. Quality models offer a way to move beyond an undefined impression of a “good” TRA. Measurement theory provides the discipline needed to connect an abstract quality property with an observable indicator. Finally, research on expert knowledge shows how experience can be represented through models, criteria, and rules without assuming that all judgement can be automated.

The distinction maintained throughout the chapter is between the risk of a system and the quality of the analysis that describes that risk. A low-risk conclusion is not evidence of a good TRA, just as a high-risk conclusion is not evidence of a poor one.

2.2 TRA as an Analytical Artefact

A TRA is commonly described as a process that identifies assets, threats, vulnerabilities, impacts, and possible treatments. Standards and engineering processes usually present it as a sequence of activities supporting design and risk decisions. That process leaves behind a document or structured dataset, however, and this output can be examined independently of the workshop or method that produced it.

Merely completing the expected sections is insufficient. A document may contain threats, impact statements, and ratings while overlooking interfaces, separating scenarios from the system model, or leaving the basis for a judgement undocumented. The presence of content and the quality of that content are not the same property.

IEC 62443-3-2 defines relevant expectations for the substance of an industrial security assessment (IEC, 2020). It requires the system under consideration to be defined, divided into zones and conduits, assessed for risk, and connected to target security levels and documented requirements. The standard does not score TRA quality, but its expectations help identify questions about coverage and coherence.

Method comparisons offer further support for examining the output itself. Cherdantseva et al. (2016) found substantial differences between SCADA risk assessment methods in scope, representation, dependencies, and practical suitability. Those differences affect what the

resulting analyses contain and how easily another person can review them. The systematic review by Tuma et al. (2018) reaches a similar conclusion for software threat analysis, where techniques vary in their inputs, procedures, validation, and empirical support.

CPS-specific work makes the relationship between representation and reviewability even clearer. Applying STRIDE in a cyber-physical setting requires components, communication paths, and cyber-physical interactions to be made explicit (Khan et al., 2017). The model-based approach of Maidl, Münz, et al. (2021) embeds security reasoning in a structured system description. Once the relevant elements and their relationships are visible, omissions, contradictions, and missing links can be examined rather than inferred.

This leads to the artefact-oriented view adopted here: the completed analysis can be reviewed for completeness, consistency, structure, and traceability.

2.3 TRA in CPS and ICS Literature

Industrial analysis cannot simply inherit the assumptions of enterprise IT. Process dependencies, physical consequences, real-time operation, and continuity requirements change both the threat picture and the meaning of an adequate assessment. Cherdantseva et al. (2016) show that methods not designed for SCADA often handle these features poorly. A quality judgement in this domain must therefore consider how well the analysis represents the industrial setting, rather than relying only on generic information-security practice.

The same point appears in threat modelling research. The CPS adaptation of STRIDE by Khan et al. (2017) depends on a concrete description of control components, communications, and physical interactions. Pattern-based and model-based work by Maidl et al. (2019) and Maidl, Münz, et al. (2021) goes further by capturing expert knowledge in reusable system representations. Such representations permit direct questions: Are all exposed interfaces considered? Are important components absent? Is each threat connected to the element it affects?

External knowledge can support coverage as well. The ATT&CK-based approach of Amro et al. (2023) reduces reliance on what an individual analyst happens to recall. Nevertheless, an extensive threat list is not automatically a good analysis. The threats must still fit the system and remain traceable to its components, interfaces, and protection needs.

Two points follow. Industrial TRA quality is inseparable from a domain-appropriate system representation, and structured forms of analysis make quality easier to inspect. What remains uncommon is a dedicated model for judging the completed artefact.

2.4 Quality as a Concept for Analysis Evaluation

The term *quality* needs a more precise meaning than a general impression of fitness or reliability. If reviewers are to compare TRAs consistently, quality must be separated into characteristics that can be discussed and evidenced.

ISO/IEC 25010 supplies the relevant methodological idea, although its original subject is systems and software quality (ISO/IEC, 2023). It treats quality as a set of characteristics and sub-characteristics rather than one undivided judgement. ISO/IEC 25023 then distinguishes those characteristics from the measures used to observe them (ISO/IEC, 2016). Research on threat-intelligence quality adopts the same basic approach by decomposing quality into explicit dimensions (Zibak et al., 2022).

A TRA is not a software product, so these models cannot be transferred literally. Their structure is nevertheless useful because a TRA is also an artefact produced for a purpose. It should support security reasoning and defensible decisions. Discussing its quality through separate dimensions is more informative than assigning it a general label.

The dimensions selected here are deliberately limited to properties that can be observed in the document or its structured representation. They address recurring problems such as missing coverage, contradictory ratings, unsupported conclusions, and unclear organisation. Correctness, usability, maintainability, and reliability also matter, but they raise different evaluation problems. Complete correctness cannot be known without a complete account of the real threat environment; usability depends on the reviewer and interface; maintainability concerns change over time. The present framework therefore concentrates on properties for which the artefact contains usable evidence.

Completeness asks whether the required content is present. **Coverage** asks whether the analysis addresses all relevant system elements and relationships within its declared scope. **Consistency** asks whether comparable cases receive compatible treatment and whether parts of the analysis contradict one another. **Traceability** concerns the path from a rating, conclusion, or treatment decision back to its supporting evidence. **Comprehensibility** concerns whether another reviewer can understand how the analysis was documented, organised, and performed.

Table 2.1 summarises how the reviewed foundations motivate the candidate dimensions used in this study.

The assigned risk level remains separate from these dimensions. Both a high-risk and a low-risk conclusion can result from careful analysis, and either can also result from a weak one. A plausible answer does not prove that the reasoning was sound. The purpose of a quality model is thus organisational: it turns a broad judgement into properties that can be stated, challenged, and supported with evidence.

2.5 Metrics and Measurement Theory

Defining a dimension is only the beginning. A metric is useful when it represents the property claimed for it, not simply when it produces a number. Fenton and Bieman (2014) emphasise that the underlying construct and the relationship between construct and measure must both be clear. Applied here, a completeness score needs a defensible account of which observable features constitute completeness.

Table 2.1: Derivation of candidate TRA quality dimensions

Source	Relevance for TRA quality	Candidate dimension
ISO/IEC 25010	Decomposes quality into characteristics that can be examined separately.	Comprehensibility
IEC 62443-3-2	Specifies expected industrial risk assessment content, including zones, conduits, threats, and security levels.	Completeness
SCADA & CPS risk assessment reviews	Compare scope, coverage, system representation, and practical suitability.	Completeness and consistency
Model-based CPS threat modelling	Exposes components, interfaces, and threat relationships for inspection.	Traceability
Expert review practice	Identifies omissions, weak assumptions, inconsistent ratings, and missing links between threats and controls.	Consistency and traceability

The same issue can be expressed as construct validity. Stable output does not validate a measure if the interpretation attached to that output is unsupported (Messick, 1995). A coverage ratio, for example, may faithfully count populated JSON fields while still missing important aspects of real analytical coverage. The schema makes measurement possible, but convenience of measurement is not evidence of validity.

Metrics are particularly useful where expert assessment would otherwise remain tacit. They can expose part of the reasoning behind a review and make repeated checks more consistent. They do not make expertise unnecessary. Industrial significance still depends on architecture, operational conditions, and the consequences of failure, all of which limit the value of context-free scoring.

Accordingly, each indicator needs a defined quality construct, an observable basis in the TRA, and an interpretation appropriate to the industrial context. Without those links, quantification adds precision in appearance only.

2.6 Expert Knowledge and Analysis Logic

CPS and ICS analysis necessarily relies on expertise. Reviewers must understand system boundaries, industrial architectures, control behaviour, communication paths, attacker capabilities, and physical consequences. The problem is not that judgement is involved, but that the basis for it may be invisible to everyone except the reviewer.

Comparative research provides one route towards greater transparency. By stating the dimensions used to compare assessment methods, Cherdantseva et al. (2016) make previously implicit distinctions open to scrutiny. Model- and pattern-based approaches offer a more direct form of formalisation. The representations proposed by Maidl et al. (2019) and

Maidl, Münz, et al. (2021) encode components, interfaces, dependencies, and security relationships in a form that can be inspected and checked.

Knowledge-based and rule-based systems demonstrate the same principle in other settings: a judgement can often be separated into criteria, relationships, weights, or decision rules. Only part of expert review is suitable for this treatment. Contextual knowledge and technical plausibility do not always translate into a fixed condition, and forcing them into one would create false confidence.

The appropriate balance is therefore selective formalisation. Recurring and observable checks can be made explicit, while decisions that depend on domain interpretation remain with the expert.

2.7 Implications for Measuring TRA Quality

Several design requirements emerge from this foundation. The indicators must reflect industrial system structure and consequences rather than generic IT assumptions. Quality must be separated into dimensions instead of being reduced immediately to one overall score. Each metric needs an observable basis and a defensible interpretation. Finally, formal rules should be used only where the review logic is stable enough to be expressed without concealing important judgement.

These requirements also mark the limit of measurement. Some desirable properties are not directly observable, and some apparently precise indicators contribute little to a real review. The framework must therefore remain connected both to the artefact's structure and to the way practitioners reason about it.

Industrial threat modelling, quality models, measurement theory, and knowledge formalisation provide the necessary building blocks. The unresolved task is to combine them into a framework aimed specifically at the quality of completed CPS and ICS TRAs.

2.8 Chapter Summary

TRA quality can be treated as a multidimensional property when its indicators are tied to observable evidence and interpreted within the industrial context. Formalisation can make recurring review checks more explicit and repeatable, but it cannot remove the need for expert judgement. Chapter 3 compares this position with related research and defines the remaining gap.

3 State of the Art and Related Work

Chapter 2 established the concepts used in the study. This chapter examines how far existing research has already addressed the three RQs. The comparison follows three themes: identifying quality indicators, turning expert review into repeatable measures, and using automation to find weaknesses. Its purpose is to separate established contributions from the specific problem that remains unresolved.

3.1 Measurable Quality Indicators

RQ1 asks how an experienced reviewer's tacit, often unstated judgement can be expressed as criteria that another person can understand and apply. The comparative review by Cher-dantseva et al. (2016) is useful because it evaluates SCADA risk assessment methods against stated dimensions. It demonstrates that aspects of an assessment can be examined systematically. Its object, however, is the method rather than the quality of a particular TRA produced with that method.

The STRIDE adaptation of Khan et al. (2017) brings the discussion closer to CPS artefacts. It ties threat identification to components, communication paths, and domain-specific threats. The example shows what structured coverage can look like, but the study is still concerned with performing threat modelling rather than reviewing a finished analysis.

Model-based and pattern-based research makes expert knowledge more inspectable. Maidl, Münz, et al. (2021) embed security reasoning in a CPS model, while Maidl et al. (2019) capture recurring structures through reusable patterns. Both reduce reliance on undocumented personal reasoning by connecting security concerns to an explicit system representation.

These studies provide three sources for possible quality indicators: comparative criteria, structured modelling practice, and formal representations of expert knowledge. They do not yet combine those sources into a quality model for evaluating a completed CPS or ICS TRA.

3.2 Repeatable Metrics

RQ2 asks how the criteria can become repeatable measures. IEC 62443-3-2 establishes a baseline of expected content by requiring a defined system under consideration, zones and conduits, risk assessments, target security levels, and documented security requirements (IEC, 2020). It does not provide a scoring model for TRA quality, but it indicates which parts of an industrial assessment should be visible.

Quantitative risk research shows that industrial security reasoning can be represented through defined inputs and procedures. The model of Zhou et al. (2025) is concerned with

risk rather than document quality, yet it demonstrates how qualitative domain concepts can be converted into defined measures. The system-specific vulnerability rating proposed by Maidl, Kröselberg, et al. (2021) adds an important qualification: an industrial measure needs to reflect the architecture and operating conditions of the system in which it is used.

Standards, quantitative models, and context-sensitive rating schemes therefore provide useful formalisation techniques. Their usual target is system risk or vulnerability severity, not the quality of the TRA artefact.

3.3 Automated Checking of Completeness and Consistency

RQ3 turns to implementation. QualSec incorporates quality-related criteria into automated risk identification for cyber-physical production systems (Eckhart et al., 2023). The knowledge-based approach of Phillips et al. (2024) demonstrates that structured security knowledge can support automated reasoning on practical CPS cases. Both are close to the present objective, although their output is a risk assessment rather than an assessment of the TRA itself.

Tool surveys document the range of available automation. The taxonomy of Shi et al. (2022) covers threat elicitation, model construction, visualisation, and documentation. Granata and Rak (2024) compare automated threat modelling techniques and open-source tools using explicit evaluation criteria. These studies reveal substantial variation in coverage and practical capability, but neither identifies artefact quality review as a primary tool function.

Automation is therefore established in CPS security analysis, but it is mainly used to create or support an analysis. Within the sources reviewed, dedicated checks for omissions, broken trace links, and internal contradictions in a completed TRA remain limited.

Table 3.1 consolidates the contribution and limitation of each related-work group for the present artefact-quality problem.

3.4 Research Gap

The field already contains most of the individual building blocks needed for TRA quality evaluation. Standards describe expected content, comparative research supplies evaluation dimensions, models expose security-relevant structure, quantitative methods formalise judgement, and tools automate parts of security analysis. These contributions were not found together in an integrated framework for evaluating completed artefacts within the literature reviewed.

IEC 62443-3-2, for example, sets expectations for a systematic industrial assessment but does not determine whether a completed analysis is coherent or well justified (IEC, 2020). Method comparisons such as Cherdantseva et al. (2016) use explicit criteria, but evaluate approaches rather than individual outputs. The models of Maidl et al. (2019) and Maidl, Münz, et al. (2021) externalise expert knowledge, yet their primary purpose is to construct an analysis. Quantitative work such as Zhou et al. (2025) measures risk rather than the

Table 3.1: Synthesis of related work for TRA quality evaluation

Study	Main focus	Link to TRA quality	Automation
Cherdantseva et al. (2016)	SCADA risk assessment methods	Comparative scope and coverage criteria inform completeness and consistency.	No
Khan et al. (2017)	STRIDE-based CPS threat modelling	Components and communication paths provide observable units for coverage.	Limited
Maidl et al. (2019); Maidl, Münz, et al. (2021)	Model- and pattern-based CPS modelling	Explicit representations support traceability and inspection.	Partial
Zhou et al. (2025); Maidl, Kröselberg, et al. (2021)	Quantitative and system-specific assessment	Defined scoring demonstrates repeatable, context-aware evaluation.	Partial
Eckhart et al. (2023); Phillips et al. (2024)	Automated, knowledge-based assessment	Structured knowledge demonstrates computational security reasoning.	Yes
Shi et al. (2022); Granata & Rak (2024)	Threat-modelling tools	Comparisons show uneven capability and little dedicated artefact review.	Yes

quality of the reasoning artefact. Automated tools likewise concentrate on generating or supporting threat analysis.

No integrated framework for reviewing a completed CPS or ICS TRA against explicit artefact-level criteria was identified among the sources reviewed. Three aspects of that gap are addressed in this study: identifying the relevant quality indicators, connecting expert review logic to repeatable measures, and testing how far automatic checks can reveal omissions or inconsistencies.

3.5 Chapter Summary

Existing work provides comparison criteria, formal models, quantitative methods, and automation, but the reviewed literature did not reveal an integrated model for evaluating completed TRA artefacts. Chapter 4 therefore explains how literature, expert interviews, artefact design, and evaluation are combined to address that gap.

4 Research Methodology

This chapter explains how the study moved from practitioners' review experience to a quality model and a working checker. The literature review did not identify a generally accepted model for the quality of a completed TRA. The methodology therefore first examines how experienced reviewers recognise omissions, weak justifications, inconsistent ratings, and unclear documentation. It then tests which parts of that reasoning can be expressed as checks over structured data.

The chapter sets out how the study addresses the research gap identified in Chapter 3. It provides the methodological chain followed by the interview findings, model construction, implementation, and evaluation in Chapters 5–8.

Two connected strands are used. Semi-structured expert interviews provide the qualitative evidence for RQ1. Their findings become design requirements for the quality model, metric catalogue, and PoC checker addressing RQ2 and RQ3. The eight sections below cover the research design and procedure, interview study, data analysis, artefact derivation, evaluation, methodological assurance, and chapter summary.

4.1 Research Design

The first part of the design is exploratory and qualitative. It does not estimate how often particular TRA problems occur in a population. Instead, it examines how experienced practitioners decide whether a completed analysis is coherent, understandable, sufficiently complete, and useful for decision-making. This requires attention to both the criteria they mention and the reasoning they use when applying them.

Starting with interviews is important because the literature review did not provide an established artefact quality model from which a closed survey could be constructed. The categories had to be examined against practice before they could be turned into a fixed framework.

The second part follows design-science logic (Hevner et al., 2004). In this approach, an artefact is built and evaluated to address an identified practical problem. Here, the quality model, criterion catalogue, and checker form that artefact. Evaluation asks whether the interview-derived criteria can be represented as observable checks and whether those checks react to deficiencies that reviewers regard as meaningful. The two parts correspond to the progression from RQ1 through RQ3 rather than operating as independent studies.

4.2 Methodological Procedure

The work was organised into five phases.

1. **Literature and state-of-the-art review.** Research on CPS threat analysis, artefact quality, measurement, and expert-knowledge formalisation provided the conceptual basis. Coverage, consistency, and comprehensibility were retained as initial sensitising dimensions: concepts used to guide the interviews without restricting what participants could raise.
2. **Expert interview study.** Five practitioners with experience in TRA creation, support, moderation, or review took part in semi-structured interviews. They discussed their review process, recurring weaknesses, and the checks they considered suitable for structured assessment.
3. **Qualitative analysis.** A hybrid content analysis used the initial dimensions as deductive starting points while allowing additional themes and criteria to emerge from the material.
4. **Framework derivation.** The findings were consolidated into quality dimensions and candidate criteria. Each criterion was assigned an automation class and a set of required inputs, creating the link between the interviews and the model in Chapter 6.
5. **Implementation and evaluation.** The core criteria were implemented as checks over JSON-formatted TRA data and applied to public and confidential cases in Chapters 7 and 8.

The phases were sequential but connected. Literature and interviews supplied the raw material, qualitative analysis organised it, and implementation tested which criteria could be operationalised. Figure 4.1 shows this relationship and the connection to the RQs.

Literature-review scope and selection. The literature component was conducted as a targeted narrative review rather than as a systematic literature review. It covered four bodies of evidence relevant to the RQs: CPS and ICS threat and risk analysis, artefact and software-quality models, measurement and qualitative-research methodology, and automated or model-based threat analysis. Peer-reviewed journal articles, conference papers, academic books, and primary sources from recognised standards and public authorities were prioritised. Sources were retained when they directly informed a quality construct, criterion, measurement decision, methodological choice, or automation boundary. Existing systematic and comparative reviews provided orientation across the wider fields of threat analysis and automated threat modelling (Cherdantseva et al., 2016; Granata & Rak, 2024; Tuma et al., 2018).

No exhaustive database-search protocol or claim of complete literature coverage is made. The review supports an analytical synthesis of the sources selected for the thesis, and all statements about an absent or limited prior approach are therefore explicitly restricted to the literature reviewed.

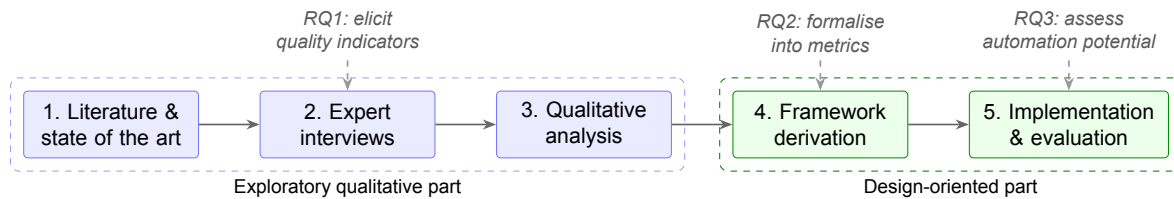


Figure 4.1: The five phases connect the exploratory qualitative work (blue) with the design-oriented work (green). Dashed links show the primary research question addressed by each phase.

4.3 Expert Interview Study

Rationale for using expert interviews. Expert interviews were chosen because much of the relevant knowledge is acquired through practice. Experienced reviewers can often recognise an unconvincing TRA quickly, but the basis for that reaction may not appear in a standard, template, or process description. Interviews offered a way to examine both the checks themselves and the reasoning surrounding them.

A questionnaire would have required the study to define a stable set of categories in advance. That would have been premature for a topic in which the purpose was precisely to discover how practitioners describe quality. Semi-structured interviews provided a common basis for comparison while still allowing examples, exceptions, and role-specific views to be explored.

The guide was developed in line with the principles described by Kallio et al. (2016). Its questions covered concrete review activities, informal scoring, recurring problems, repetitive tasks, possible automation, and situations in which expert judgement remains indispensable. This breadth was needed because the participants had worked as authors, reviewers, moderators, support specialists, and security decision-makers.

Study context. The study was conducted within related industrial-automation and security units of a large multinational industrial technology company. The organisation develops products, systems, and digital solutions for industrial and infrastructure environments. The participating practitioners create, support, moderate, or review TRAs as part of product and solution development. These analyses inform system-security decisions, risk treatment, and project documentation. Their recurring involvement in TRA preparation and review made this cross-unit setting appropriate for investigating how analysis quality is judged in industrial practice.

One organisation cannot represent every industrial sector or TRA process. The value of the setting lies in the depth and variation of practice-based evidence available across the participating units. The findings should not be interpreted as representing the partner organisation as a whole. To preserve confidentiality, neither the organisation nor the participating organisational units are identified, and all participants are referred to by codes.

Participant selection. Participants were selected purposively (Palinkas et al., 2015). Statistical representativeness was not the goal; the aim was to obtain relevant and varied experience. Five interviews were conducted between March and May 2026. The sample included perspectives from authoring, review, support, and moderation because each role encounters different aspects of TRA quality. Table 4.1 summarises the background that can be reported without compromising anonymity.

Table 4.1: Interview participants

Expert ID	Role / professional perspective	Involvement in TRAs
E1	Principal consultant	More than 25 TRAs in creation, review, and support
E2	Product and solution security role	More than 50 TRAs; development, product ownership, and a later management-oriented security perspective, including review and archiving
E3	Product security support	Assisted colleagues from process and technical perspectives; insight into a large number of partner-organisation TRAs and direct involvement in approximately 50 analyses
E4	Security expert and TRA moderator	Mainly security expert and, more recently, moderator; approximately 15 to 20 TRAs
E5	Security expert and occasional moderator	Approximately ten TRAs as security expert and occasional moderator; also reused prior TRAs as input

The sample is small and is not used to make population estimates. Its purpose is to provide detailed accounts from practitioners with substantial TRA experience.

Interview design. All interviews followed a guide of 22 main questions. Coverage, consistency, and comprehensibility served as initial *sensitising concepts*. They helped organise the conversation but were not treated as a final or exhaustive coding scheme. New concerns could therefore emerge from the participants' accounts.

- **Coverage** concerned whether relevant assets, threats, interfaces, scenarios, and other system elements had been considered.
- **Consistency** concerned logical alignment and contradictory treatment within the TRA.
- **Comprehensibility** concerned whether reviewers and stakeholders could follow the documented reasoning.

The interview began with the participant's role and experience, followed by open questions about strong and weak TRAs. Later questions examined the initial review process, warning signs, and recurring deficiencies that may be hidden by an apparently complete document. Coverage, consistency, and comprehensibility were then discussed in more detail. The final part asked about checks suitable for junior reviewers, possible scoring factors, repetitive tasks, automation, and the remaining need for human judgement. Core questions were common to all participants. Follow-up questions were used where an example or role-specific point required clarification. The full guide is provided in Appendix A.

Data collection. Most interviews were held through Microsoft Teams. Two took place in person. They were conducted in English and lasted about one hour on average. Participants consented to recording and to the use of the material for this research. Teams generated an initial transcript, which was checked against the recording and manual notes, particularly for errors in domain terminology. Questions, responses, and interpretive notes were kept connected so that later categories could be traced back to their context.

4.4 Data Analysis

The analysis combined deductive starting categories drawn from the initial framework with inductive refinement based on new themes in the interviews. This approach followed qualitative content-analysis principles (Krippendorff, 2018; Mayring, 2000). Coverage, consistency, and comprehensibility supplied the starting structure, but they did not limit what could be coded.

The analysis proceeded in four steps. First, each interview was reviewed against the interview guide. Second, relevant passages were linked to their questions and annotated with their significance for the research objective. Third, the interviews were compared to identify recurring concerns, including omitted interfaces, incomplete scenario coverage, unclear asset relationships, poorly justified ratings, inconsistent treatment, weak readability, and missing mitigation links. Finally, these concerns were grouped into broader categories and restated as candidate quality criteria. Statements about scoring, repetitive work, automation, and expert responsibility also informed the classification. Frequency alone did not determine whether a criterion was retained. The criterion also had to be conceptually relevant and recognisable in review practice.

4.5 Artefact Derivation and Operationalisation

The transition from interview finding to artefact required each candidate criterion to be described through three attributes:

1. **Quality dimension:** the conceptual category to which the criterion belongs, such as coverage, consistency and traceability, or comprehensibility.

2. **Degree of automation:** whether structured data permits an *automatic* check, whether a *semi-automatic* signal still needs human confirmation, or whether the criterion remains an *expert* judgement. A separate, non-scoring *framework* label records methodological enablers that sit outside the criterion catalogue.
3. **Required inputs:** the fields and relationships that must be present before the criterion can be assessed.

This description links the qualitative evidence to the design work. It records how a criterion was interpreted, what information it requires, and where responsibility must remain with a reviewer. At this stage the catalogue is a set of practice-grounded candidates, which Chapter 6 consolidates into the quality model.

4.6 Evaluation Strategy for the Artefact

Evaluation uses a small case set appropriate to a PoC rather than a broad statistical sample. Chapter 8 maps EO1–EO4 to three complementary evidence lenses. L1 is a controlled mutation experiment on a public MiniCPS/SWaT-derived TRA (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016). One defect class is introduced into each variant, allowing changes in targeted and non-targeted criteria to be compared with a declared target map. L2 applies the same implementation to confidential internal TRAs and collects feedback from six practitioners. L3 is an AI-assisted descriptive comparison of two separately generated AI-assisted interpretation reports with the report generated directly by the implemented rule set on one shared TRA artefact.

Seeded defects provide the reference for the mutation experiment. Industrial findings in L2 are interpreted against practitioner review. L3 is a descriptive comparison of independently generated reports and is not treated as a human usability assessment. Usefulness is judged in practical terms within L2: the checks should identify the main concerns, show the affected artefact elements, and avoid a volume of false findings that would make the report unusable. The design deliberately keeps expert confirmation in the practical evaluation because a mechanically consistent result may still lack technical meaning.

4.7 Trustworthiness, Ethics, and Limitations

Methodological trustworthiness. Several measures were used to strengthen credibility and traceability (Lincoln & Guba, 1985). A common interview guide ensured that all participants addressed the central topics, while follow-up questions preserved the exploratory character. Purposive selection brought together several professional perspectives. Recordings, corrected transcripts, questions, notes, and categories were linked in the analysis records. The accompanying traceability workbook preserves the mapping from interview evidence to the derived criteria.

The design strand adds a different form of checking by comparing automated findings with declared defects and with practitioner assessment. Human confirmation is retained for signals that depend on interpretation. These measures do not remove researcher judgement, but they make its role and evidential basis more visible.

Ethical and confidentiality considerations. Confidentiality was necessary because the participants discussed professional practice and internal review processes within the partner organisation. Neither the organisation nor the participating organisational units are identified, and names were replaced with expert identifiers. Recordings and transcripts were used for this research. The reported findings concern recurring quality issues rather than personal information or identifiable operations. Public implementation examples use synthetic or public data. Confidential industrial results are reported only in aggregate or simplified form.

Methodological limitations. The evidence has five main limits. The targeted narrative literature review did not use an exhaustive database-search protocol, so its gap claims are bounded to the sources reviewed rather than presented as proof that no related approach exists. Five interviews from related units of one partner organisation cannot represent the wider organisation, other industrial sectors, or TRA practices. Shared organisational experience may also make some criteria more specific to that environment than the sample reveals. The content analysis involves interpretation even though evidence links were retained. Finally, the implementation is evaluated on a small case set and should be read as a feasibility study, not as validation of a mature measurement instrument. The resulting catalogue is practice-grounded and partly automatable, but it remains open to revision through broader use and independent review.

4.8 Chapter Summary

The methodology connects an exploratory interview study with the design and evaluation of a quality assessment artefact. Interviews provide the practice-based review knowledge. Qualitative analysis organises that knowledge into candidate dimensions and criteria. Implementation tests which criteria can operate on structured data. Chapter 5 presents the empirical findings, Chapter 6 develops the consolidated model, Chapter 7 implements it, and Chapter 8 evaluates the resulting instrument.

5 Interview Findings

Building on the expert interview study described in Chapter 4, this chapter examines how experienced practitioners judge completed TRAs. It records the recurring concerns and assessment criteria found in the interview material. These findings provide the empirical answer to RQ1 and form the basis of the quality model developed in Chapter 6.

The material is organised by theme rather than by interview. The analysis began with the three sensitising dimensions of coverage, consistency, and comprehensibility, but, as anticipated in the methodology, the interview material extended this initial frame. Participants introduced distinct concerns around *participation and process* and *formal completeness*, and broadened the initial consistency theme into *consistency and traceability*. In the final five-dimension model, participation and related lifecycle evidence are consolidated under *process and governance*. Throughout, the five interviewees are referred to by their anonymised identifiers E1–E5, consistent with Table 4.1.

To preserve traceability between the raw material and the derived criteria, each thematic subsection summarises the recurring concern, the perspectives of the participants who raised it, and the candidate criterion or criteria it produced. The candidate criteria are given short reference labels (for example *component coverage* or *rating coherence*) that are carried forward and consolidated into the formal catalogue in Chapter 6.

5.1 General Characterisations of TRA Quality

Before discussing specific dimensions, the participants were asked what, in general terms, distinguishes a high-quality TRA from a poor one. Their answers revealed an important shared assumption: a TRA can appear complete on the surface while still being weak from a reviewer's perspective. Several participants stressed that the mere presence of threat lists, ratings, or an architecture description does not by itself indicate quality (E2, E3, E5). Instead, quality was associated with whether the analysis is *complete in substance*, *internally coherent*, *adequately justified*, and *reviewable by someone other than its author*.

A second shared theme was that quality is multidimensional. No participant reduced TRA quality to a single attribute or a single number. E2 explicitly rejected the idea that a TRA could be judged by a single count such as the number of threats, and E1 framed review as the accumulation of many small checks rather than one overall verdict. This observation directly shaped the later decision (Chapter 6) to express quality through several dimensions and to avoid collapsing the result into a single raw score.

A third theme concerned the role of experience. Participants repeatedly described recognising weaknesses quickly. As one participant put it, “you can feel when something is missing.”

However, the underlying reason was often harder to explain. This observation supports the central premise of the thesis: much of the assessment logic is tacit, and part of the research contribution is to make that logic explicit.

5.2 Participation and Process

A theme not contained in the initial sensitising dimensions but raised independently by several participants concerned *who* produced the TRA and *how it is maintained over time*.

Participants emphasised that the quality of a TRA is strongly influenced by whether the right mix of roles was involved in its creation. E2 described the importance of having “the right participants with different perspectives,” naming roles such as product owner, architect, product security expert, and product security officer. E5 similarly noted that part of a review is checking “whether all relevant roles were present.” The recurring concern here is *role participation*: a TRA produced without the relevant perspectives is more likely to contain blind spots, regardless of how polished it appears. This yielded the candidate criterion **relevant-role participation**.

A second process-related concern was the treatment of the TRA as a *living document*. E2 stressed that a TRA should be “maintained as a living document that is updated when the architecture changes,” and observed that whether the version history is correct is something that can, in principle, be checked automatically. This produced the candidate criterion **living document maintenance / update responsiveness**, concerned with version metadata, change dates, and the alignment between the TRA and the evolving system.

Both criteria highlight that TRA quality has a procedural dimension that is partly external to the document’s analytical content. As discussed in Chapter 6, role participation depends on metadata not always present in current TRA exports, which positions it as a criterion whose automation depends on a modest schema extension.

5.3 Formal Completeness

Participants distinguished *formal* completeness, meaning that the expected sections and fields are filled in, from *substantive* coverage, discussed in Section 5.4. Formal completeness was widely treated as an entry condition for review rather than a mark of quality in itself.

The most frequently mentioned concern was the presence of *placeholders and unfinished entries*. Participants reported encountering TRAs still containing template text, open questions, or markers such as “TBD” or “to be discussed” (E2, E3). Such entries were treated as immediate signals that the analysis is not yet reviewable. This produced the candidate criterion **placeholder / unfinished entry detection**, which several participants identified as obviously automatable.

A closely related concern was **mandatory field and section completion**: whether the core sections of the TRA, including the system overview, assumptions, assets, protection goals, and threats, are present and non-empty (E2, E3). Participants framed missing mandatory

content as a rejection criterion: a TRA with empty core sections is returned to its author before substantive review begins.

Participants also singled out **assumption validation**. E3 highlighted that assumptions are frequently recorded but left unvalidated, and that the proportion of validated assumptions is a meaningful and checkable quality signal. This produced a distinct candidate criterion concerned with the ratio of validated to total assumptions, separated from general field completion to retain assumption-level granularity.

5.4 Coverage

Coverage was the dimension that participants discussed in the greatest detail, and it expanded into several distinct candidate criteria.

The dominant concern was whether all relevant *system elements* are reflected in the threat analysis. Participants worried about **component coverage**, which asks whether every in-scope component is reached by at least one threat, and especially about **interface coverage**, since overlooked interfaces are a common source of missing threats (E1, E3, E5). Network-facing and external interfaces received particular emphasis: E4 and E5 argued that externally exposed interfaces must not be left unanalysed, producing the criterion **external / network-facing interface coverage**.

A second coverage concern linked threats to *protection goals and assets*. Participants described checking whether each protection goal is actually exercised by at least one threat (**protection goal coverage**) and whether every asset is represented by at least one protection goal (**asset-to-protection-goal mapping**) (E1, E3, E4). Gaps in these mappings were seen as signs that the analysis is disconnected from what it is meant to protect.

Participants also discussed coverage at the level of *system representation*. Several stressed the importance of an adequate **architecture figure** and a clear **system overview** (E1, E2, E3, E5). E5 was particularly emphatic that figures which are “too detailed, too abstract, or advertisement-like” undermine the analysis. These concerns were retained as candidate criteria whose *presence* is checkable automatically but whose *adequacy* remains an expert judgement. The same evidence was also interpreted as requiring agreement between the architecture representation and the components enumerated in the analysis. This produced the expert-judgement criterion **architecture-to-component alignment**: it asks whether the documented architecture and component inventory describe the same system, rather than attempting to infer architectural correctness automatically. Although this criterion arose from comments about system representation, the final model assigns it to Consistency & Traceability (D4), because it evaluates agreement between two representations of the same system rather than the presence of either representation alone.

Two further coverage criteria reflected reviewers’ early-warning heuristics. The first, **threat-sufficiency heuristic**, captures the intuition that a complex product with only a handful of threats “raises suspicion” (E3, E5). Participants were unanimous that this is a *screening*

warning, not a direct quality score, since more threats do not necessarily mean higher quality. The second, the **no-threat red flag**, captures E4's observation that a TRA claiming that no threats were identified is an immediate and decisive warning sign. Because the participants rejected an absolute threat count as a direct quality measure, the broader threat-sufficiency candidate was not retained as a scored criterion. Only the defensible zero-threat condition was retained as CM-16.

Finally, participants discussed the *method* behind coverage: whether a recognisable systematic approach was used (E3, E4). Examples included a question list, STRIDE, a model-driven method, or structured sources such as CWE, CAPEC, and ATT&CK. This produced criteria concerned with **method visibility** and **structured source use**, which participants viewed as supporting confidence in coverage without proving it.

5.5 Consistency and Traceability

Consistency was discussed primarily in relation to the *ratings* assigned to threats and to the *logical links* between parts of the analysis.

The strongest cross-interview theme was **rating consistency across similar threats**. E1 described encountering “the same rating justified differently, or different ratings for the same reasoning,” and E5 noted that duplicate or similar threats are sometimes rated differently without explanation (E1, E2, E4, E5). This produced two linked candidate criteria: the detection of **duplicate or similar threats**, and the flagging of **rating variance within clusters of similar threats**.

Participants also described checking the *internal logic* of risk ratings. E1 gave the concrete example that “if impact is low and likelihood is low, the final risk rating should consistently reflect a low risk,” producing the candidate criterion **risk-rating logical coherence**, which participants regarded as fully automatable given a defined risk matrix. A related criterion, **impact-to-protection-goal justification**, captures the expectation that a threat's impact rating should be grounded in the ratings of the protection goals it affects (E3, E4). This concern was consolidated into CM-20 as part of the broader rating-coherence and justification criterion. The PoC operationalises the deterministic portion through risk-matrix coherence and the presence of justification text. Whether the impact reasoning is substantively supported by the affected protection goals remains an expert decision.

Traceability emerged as a distinct concern that the original sensitising dimensions did not fully capture. Participants stressed the importance of being able to follow *how* conclusions were reached: how threats are linked to assets, how risk evaluations are justified, and how mitigations relate to identified issues (E1, E2, E3). The recurring criterion here, **rating justification completeness**, concerns whether exposure, exploitability, and impact ratings are accompanied by explanatory comments. E3 put it directly: “ratings without explanation...the reviewer cannot understand how the judgement was reached.” Participants agreed that the

presence of justification text is checkable automatically, while its *adequacy* requires judgement.

5.6 Comprehensibility

Comprehensibility concerned whether the documented analysis can be understood and followed by a reader other than its author. Participants consistently linked poor comprehensibility to *imprecision* and to *insufficiently described threats*.

The most concrete and frequently mentioned criterion was the detection of **keyword-only threat descriptions**. Participants reported threats described by a single term, such as “SQL injection” or “password policy,” without any explanation of the actor, action, target, or impact (E1–E5). This was the comprehensibility concern most readily expressed as an automatable check (a length or single-label heuristic), and every participant referred to it in some form.

Beyond length, participants described an implicit expectation that a well-formed threat states *who* is doing *what*, against *which* target, *through* which interface or by abusing which weakness, and *with what* impact. E3 articulated this structure almost verbatim. The quality model operationalises it as six slots: actor, action, target or interface, weakness, impact, and affected protection goal. This produces the candidate criterion **threat structure completeness**. It remains a semantic check requiring natural language or model-assisted support rather than a simple rule.

Participants also raised **vagueness and imprecision** as a general comprehensibility defect: “vague, overly general descriptions create room for interpretation” (E2), with E3 describing imprecision as “the main source of poor comprehensibility.” Finally, participants connected comprehensibility back to traceability through the criterion **reconstructability of rating justifications**, which asks whether a later reader can follow *why* each rating was assigned (E1, E2). This criterion bridges the comprehensibility and consistency dimensions and underlines that the two are not fully separable in practice.

5.7 Process and Governance

A final group of concerns related to the governance context surrounding the TRA. Although less central than coverage or comprehensibility, these concerns recurred and were retained as candidate criteria.

Participants referred to the importance of **authority approval**, meaning explicit sign-off on key sections by an accountable role, and to the linkage of the TRA to **known deficiency evidence** such as security requirements, static analysis, penetration-test results, vulnerability management, or end-of-life information. These concerns connect the TRA to the wider secure development process and, as Chapter 6 discusses, depend on evidence that often lies outside the TRA document itself. They are therefore characterised as criteria whose automation is currently limited and whose full assessment depends on either schema extension or expert review.

5.8 The Question of Measurability and Automation

A dedicated part of each interview explored which aspects of review are repetitive, which could be scored or automated, and where expert judgement remains essential. The responses were strikingly consistent and directly shaped the design of the framework in Chapter 6.

Participants identified the *structural* checks as the most repetitive and the most obviously automatable (E1–E5). These map to criteria that operate purely on structured fields and relationships. Examples include coverage of components, interfaces, protection goals, and assets, rating-logic coherence, placeholder and empty-section detection, and description length.

Participants placed meaning-based, or *semantic*, checks, including threat structure completeness, vagueness, duplicate detection, and rating justification adequacy, in an intermediate category. E3 in particular noted that large language models “may support the application of detailed textual quality criteria and generate improvement suggestions,” but participants agreed that such outputs require expert confirmation before they are trusted.

Finally, participants were clear that some aspects of quality *cannot* be reduced to objective metrics: whether the participating roles are adequate for a specific system, whether an architecture figure is genuinely fit for analysis, and whether a justification is technically sound. These were consistently assigned to expert judgement. The interviews therefore did not support full automation of TRA review. They supported a *tiered* model in which automation handles the mechanical checks, semi-automation assists with textual checks, and experts retain the judgement-based decisions. This tiered view is carried directly into the framework.

5.9 Synthesis of Derived Quality Dimensions and Criteria

The interviews indicate that TRA quality assessment involves more than the initial sensitising dimensions of coverage, consistency, and comprehensibility alone. The analysis supports an extended set of dimensions:

1. **Process and governance:** role and workshop participation, living document maintenance, authority approval, and known deficiency evidence linkage.
2. **Formal completeness:** mandatory section completion, placeholder detection, and assumption validation.
3. **Coverage:** component, interface, external interface, communication, protection goal, and asset coverage, together with asset-to-component and communication mapping, out-of-scope boundaries, and the no-threat red flag.

4. **Consistency and traceability:** threat specificity, protection goal C/I/A balance, rating consistency across similar threats, risk-rating coherence and justification, risk treatment coverage, rubber-stamping detection, assumption linkage, and duplicate detection.
5. **Comprehensibility:** system overview presence, scope description clarity, threat structure completeness, and vagueness reduction.

Table 5.1 consolidates this mapping, linking each derived dimension to the recurring expert concern that motivates it, the concrete criteria it yields (with the catalogue identifiers later assigned in Chapter 6), and the dominant degree of automation expected for those criteria. It makes the bridge from qualitative findings to the structured catalogue explicit and traceable.

Table 5.1: Synthesis of interview findings into quality dimensions and criteria

Dimension	Derived criteria (catalogue IDs)	Automation
Process & Governance	Role/workshop participation (CM-01); living document maintenance (CM-02); authority approval (CM-27); known deficiency evidence linkage (CM-28)	Semi / Auto*
Formal Completeness	Mandatory-section completion (CM-03); placeholder detection (CM-04); assumption validation (CM-05)	Auto
Coverage	Component, interface, external interface, communication, protection goal and asset coverage (CM-06 to CM-11); asset-to-component and communication mapping (CM-12); out-of-scope boundaries (CM-14); no-threat red flag (CM-16); architecture-figure adequacy (CM-29); systematic threat-identification method visibility (CM-30); structured threat-source use (CM-31)	Auto / Semi / Expert
Consistency & Traceability	Threat specificity (CM-17); protection goal C/I/A balance (CM-18); rating consistency across similar threats (CM-19); rating coherence and justification (CM-20); risk treatment coverage (CM-21); rubber-stamping detection (CM-22); assumption linkage (CM-23); duplicate detection (CM-24); architecture-to-component alignment (CM-32)	Auto / Semi / Expert
Comprehensibility	System overview presence (CM-13); scope description clarity (CM-15); threat structure completeness (CM-25); vagueness reduction (CM-26)	Semi

*CM-27/CM-28 are computable in principle but depend on metadata that current TRA exports may not contain. The catalogue in Chapter 6 records how they are reported when those fields are absent.

Each derived criterion carries an associated indication of whether it is *automatic*, *semi-automatic*, or *expert*, reflecting the measurability discussion of Section 5.8. These dimensions and criteria are treated as preliminary: their methodological function is to provide an empirically grounded bridge between qualitative expert insight and the structured quality framework developed in Chapter 6.

5.10 Chapter Summary

The interview findings show that practitioners judge TRA quality through many small, partly tacit checks rather than through one overall verdict. Coverage, consistency, and comprehensibility remained central, but they were insufficient on their own. The material added formal completeness and process and governance, and expanded consistency to include traceability. For each theme, the chapter identified recurring concerns, derived candidate criteria, and classified their automation potential. Chapter 6 consolidates these dimensions and criteria into a structured quality model and evaluation framework.

6 Quality Model and Evaluation Framework

Chapter 5 reported the recurring quality-related concerns expressed by the interviewed experts and translated them into a set of candidate criteria grouped into provisional dimensions. This chapter consolidates those findings into a structured **quality model** for completed TRAs and an **evaluation framework** that defines how the model is applied to a concrete TRA artefact. This addresses RQ2, which asks how expert-based evaluation of TRA quality can be translated into systematic and repeatable metrics. It also sets up the PoC implementation in Chapter 7 and its evaluation in Chapter 8.

The model is built on three design commitments derived directly from the interview findings. First, quality is treated as **multidimensional**: it is expressed through several dimensions rather than a single attribute, because no participant reduced TRA quality to one factor (Section 5.1). Second, each criterion is assigned an explicit **degree of automation**, because the interviews supported a tiered view in which automation handles mechanical checks, semi-automation assists with textual checks, and experts retain judgement-based decisions (Section 5.8). Third, the overall result is **never reduced to a single raw count**: the overall indicator is reported together with the failed-check view, status-weighted dimension scores, and actionable feedback (Section 5.1, E1 and E2).

6.1 Structure of the Quality Model

The quality model organises TRA quality into five *assessment dimensions* that score properties of a concrete TRA.

Table 6.1: Dimensions of the TRA quality model

#	Dimension	Concern (what it evaluates)
D1	Process & Governance	Whether the right roles were involved, the TRA is kept current, and approval and external evidence linkage are present
D2	Formal Completeness	Whether mandatory sections/fields are present and free of placeholders
D3	Coverage	Whether all relevant system elements, protection goals, and assets are analysed
D4	Consistency & Traceability	Whether ratings and analytical relationships are coherent, comparable, justified, and traceable across the TRA
D5	Comprehensibility	Whether the analysis can be understood and followed by another reader

Each dimension contains one or more **criteria**. A criterion is a defined, named property of the TRA artefact with an associated checking logic, a set of required inputs, and a degree

of automation. The full set of criteria forms a *consolidated catalogue* in which semantically similar concerns raised by several experts are merged into a single criterion while preserving traceability to the originating interview statements.

The *Process & Governance* dimension (D1) groups both the participation and living document criteria (CM-01, CM-02) and the approval and external evidence criteria (CM-27, CM-28), because all four concern process evidence that largely lies outside the TRA artefact and share the same limited automation. The implementation emits one scored row per dimension of Table 6.1, i.e. five scored dimension rows in total.

6.2 Criterion Attributes

To make the model operational, every criterion is described by a fixed set of attributes. These attributes are the structural contract between the qualitative findings and the implementation.

- **Identifier and name:** a stable reference (for example *CM-07: Interface Coverage by Threats*).
- **Dimension:** the quality dimension the criterion belongs to (D1 to D5).
- **Definition:** the property of the TRA the criterion measures.
- **Source:** the interview statements (and, where relevant, standards) that motivate the criterion, preserving empirical traceability.
- **Degree of automation:** one of three criterion classes, with a separate non-scoring framework label for methodological enablers (Section 6.3).
- **Checking logic:** the formula or conceptual rule used to evaluate the criterion.
- **Required inputs:** the TRA fields or structures the criterion depends on.
- **Reviewer judgement needed:** what, if anything, must remain an expert decision.
- **Priority / weight:** the recorded relative importance of the criterion, retained for possible future calibration.

This attribute set ensures that each criterion is independently interpretable, that its inputs are explicit (so applicability to a given TRA representation can be determined), and that the boundary between automated computation and human judgement is stated rather than assumed.

6.3 Degrees of Automation

The interviews established that criteria differ fundamentally in how far they can be checked without a human. The 32 catalogue criteria use three automation classes: Automatic, Semi-automatic, and Expert. A separate Framework label records non-scoring methodological enablers. Together, these categories structure the evaluation pipeline in Section 6.7.

1. **Automatic (Auto).** These criteria are computed directly from the structured TRA representation using deterministic rules, for example coverage ratios, risk-rating coherence, placeholder detection, and description-length checks. These are the most repetitive checks identified by the experts and the primary target of the PoC.
2. **Semi-automatic (Semi).** These criteria require natural language or model-assisted analysis whose output is presented to a reviewer for confirmation, for example threat structure completeness, vagueness scoring, duplicate detection, and justification adequacy.
3. **Expert.** These criteria require judgement that cannot be reduced to an objective metric, for example the adequacy of an architecture figure, the appropriateness of the participating roles, or the technical soundness of a justification.
4. **Framework.** This non-scoring label covers methodological enablers that shape *how* the assessment is conducted, for example the use of model- or AI-assisted semantic review. Framework entries are not included in the 32-criterion catalogue or its aggregate scores.

A deliberate design rule, taken from the interviews, is that automatic criteria produce *objective sub-scores*, semi-automatic criteria produce *candidate findings flagged for confirmation*, and expert criteria are *rated by reviewers*. The model never presents a semi-automatic or expert result as if it were an objective measurement.

6.4 The Consolidated Criterion Catalogue

The consolidated catalogue contains the criteria derived in Chapter 5, organised by dimension. Table 6.2 summarises the catalogue. The criterion definitions, measurement summaries, and automation classes are provided in Appendix B. Identifiers follow the consolidated *CM* numbering used throughout the implementation, and the final **Tier** column records whether a criterion belongs to the implemented *core* set or the expert-judgement *extended* set (Section 6.4 continues below the table). The catalogue comprises 32 criteria in total. The PoC computes the 28 core criteria CM-01 to CM-28, whereas the four extended criteria CM-29 to CM-32 remain subject to expert judgement. Thus, references to “the 28 criteria” in the implementation and evaluation chapters always mean the computed core set, not the complete 32-criterion catalogue. The CM identifiers reflect the order in which the criteria were derived rather than their final grouping, so a criterion may appear under a different dimension from the one suggested by its neighbouring numbers (for example CM-13 is grouped under comprehensibility). The identifiers are stable references, not a contiguous sequence within each dimension.

Table 6.2: Consolidated TRA quality criterion catalogue

Dimension	ID	Criterion	Auto.	Tier
D1 Process & Governance	CM-01	Relevant-role / workshop participation	Semi	Core
	CM-02	Living-document maintenance (updated since creation)	Auto	Core
	CM-27	Authority-approval presence	Auto*	Core
	CM-28	Known-deficiency evidence references	Semi*	Core
D2 Formal Completeness	CM-03	Mandatory field / section completion	Auto	Core
	CM-04	Placeholder / unfinished entry detection	Auto	Core
	CM-05	Assumption validation ratio	Auto	Core
D3 Coverage	CM-06	Component coverage by threats	Auto	Core
	CM-07	Interface coverage by threats	Auto	Core
	CM-08	External / network-facing interface coverage	Auto	Core
	CM-09	Communication coverage by threats	Auto	Core
	CM-10	Protection goal coverage in threat analysis	Auto	Core
	CM-11	Asset coverage / asset-to-protection-goal mapping	Auto	Core
	CM-12	Asset mapping to components / communications	Auto	Core
	CM-14	Out-of-scope boundaries	Semi	Core
	CM-16	No-threat / empty analysis red flag	Auto	Core
	CM-29	Architecture-figure adequacy	Expert	Extended
	CM-30	Systematic threat identification method visibility	Expert	Extended
	CM-31	Structured threat source utilisation	Expert	Extended
D4 Consistency & Traceability	CM-17	Threat specificity against a curated reference vocabulary (rule-based text analysis)	Semi	Core
	CM-18	Protection goal C/I/A balance	Auto	Core
	CM-19	Rating consistency across similar threats	Semi	Core
	CM-20	Rating coherence & justification	Semi	Core
	CM-21	Risk-treatment / handling decision coverage	Auto	Core
	CM-22	Rating-distribution / rubber-stamping detector	Auto	Core
	CM-23	Assumption usage / linkage by type	Auto	Core
	CM-24	Duplicate / similar-threat detection	Semi	Core
	CM-32	Architecture-to-component alignment	Expert	Extended
D5 Comprehensibility	CM-13	System overview / description presence	Semi	Core
	CM-15	Scope clarity by descriptions	Semi	Core
	CM-25	Threat-structure completeness (semantic)	Semi	Core

continued on next page

Table 6.2, continued

Dimension	ID	Criterion	Auto.	Tier
	CM-26	Vagueness / imprecision reduction	Semi	Core

*CM-27 and CM-28 are computable in principle but depend on metadata that current TRA exports may not contain. Where the fields are absent, the criterion reports an honest *not assessable* value rather than a false pass (Section 6.8).

Traceability chain. Table 5.1 connects the interview findings to the derived criteria and their anticipated automation. The catalogue above then fixes each criterion’s dimension, automation class, and core or extended tier. Table 7.1 maps every core criterion to its primary implementation family, Table 8.2 links the evaluation questions to their evidence, and Table 9.1 connects the resulting evidence back to RQ1–RQ3. Statement-level interview traceability and detailed criterion attributes are retained in the catalogue workbook identified in Appendix D.

The catalogue is intentionally broader than the subset that can be implemented immediately. To structure this, criteria are assigned to one of two **tiers**. The *core* tier comprises criteria that are classified as automatic or semi-automatic, map to defined fields in the structured TRA representation or its explicit optional extensions, recur strongly across interviews, and together cover all assessment dimensions. A core criterion reports *not assessable* when its optional input is absent rather than receiving a false pass. The *extended* tier comprises the remaining criteria, which document the full breadth of expert concern but depend on expert judgement, additional metadata, or future capability. The core tier defines the scope of the PoC evaluated in Chapter 8. The extended tier preserves the completeness of the empirical findings and frames the boundary of automation as a deliberate scoping decision rather than an omission.

Two ways of grouping the same criteria. The dimensions in Table 6.2 describe what each criterion assesses. They do not describe how each criterion is computed. Several criteria in different dimensions use the same underlying calculation pattern, such as a covered fraction, a presence gate, or a comparison of two threat records. Chapter 7 therefore presents the same 28 core criteria a second way, grouped into seven algorithm families (Table 7.1). The two views are complementary: the dimensions in this chapter answer “what aspect of quality does the criterion assess?”, whereas the implementation families answer “how is the criterion calculated?”. The criterion identifiers and definitions remain unchanged across both views.

6.5 Scoring Scheme

Individual criteria are scored according to their automation class. Automatic and semi-automatic criteria produce a percentage (for example the fraction of in-scope components

reached by a threat), a count (for example unfinished placeholders), or a boolean pass/fail (for example the no-threat red flag). The semi-automatic criteria differ from the automatic ones not in how they are scored but in that their underlying signal is derived from rule- or model-assisted text analysis that a reviewer is expected to confirm. The purely expert criteria of the extended tier, which are not computed in the PoC, are instead rated on an **ordinal scheme** elicited from the interviews, in which a criterion is rated on one of five levels (*none*, *weak*, *partial*, *minor deficiency*, or *good*), mapped to 0 %, 25 %, 50 %, 75 %, and 100 % respectively. This lets judgement-based criteria be aggregated alongside computed ones without implying a false precision, and it gives reviewers a shared vocabulary for rating textual quality.

Aggregation. Each scored criterion is first reduced to a three-level *status* (*ok*, *warning*, or *bad*) by comparing its percentage (or count) against fixed cut-offs, and each status is mapped to a numeric weight (*ok* = 100, *warning* = 60, *bad* = 20). A dimension score is the unweighted mean of the status weights of its criteria, and the overall indicator is the unweighted mean of the status weights of all assessed criteria. Because the overall indicator is computed at criterion level rather than by averaging the dimension scores, dimensions containing more criteria contribute proportionally more to it. The PoC uses **equal criterion weights** as a transparent baseline, not as a claim that all weaknesses have equal operational importance. Equal weighting is itself a substantive design choice: for example, a missing overview and a near-duplicate threat receive the same direct contribution, while correlated coverage criteria can collectively exert more influence than a sparsely represented property. The *priority* attribute recorded for each criterion (Section 6.2) is retained as documentation and for future weight elicitation, but it is not applied as a multiplier because the interviews did not produce reproducible numeric trade-offs. Consequently, the overall value is an unweighted descriptive index rather than a validated utility or risk score. It is always reported together with the criterion findings, per-dimension breakdown, and failed-check count, which remain the primary basis for review.

6.6 Threshold Selection and Rationale

Several automatic and semi-automatic criteria depend on numeric thresholds, including minimum word counts that separate a substantive description from a keyword, and the token-overlap value above which two threats are treated as near-duplicates. These thresholds are transparent, configurable design parameters rather than hidden constants. They are *not* empirically calibrated estimates. Each operational default is justified by a combination of (i) the interview statements that motivated the criterion, (ii) the minimum amount of text needed for a meaningful description, and (iii) convention from text-similarity practice. This supports prototype operation but does not establish that, for example, six words is superior to five or seven in a population of TRAs. Table 6.3 therefore lists the prototype defaults used in the PoC.

Table 6.3: Prototype threshold defaults used by the computed criteria

Threshold	Value	Rationale
Keyword-only minimum words (CM-17/CM-25)	6	A description below six words is typically a bare label (“SQL injection”) rather than an actor-action-impact statement (E1–E5).
System overview minimum words (CM-13)	20	A usable overview must be more than a heading. Twenty words is a conservative floor for one or two informative sentences.
Scope-description minimum words (CM-15)	5	A component is only adequately scoped when it carries a short descriptive phrase, not an empty or one-word field.
Near-duplicate Jaccard threshold (CM-19/CM-24)	0.6	A configurable heuristic selected for the prototype to flag high lexical overlap while tolerating some variation in wording.
Threat-specificity pass threshold (CM-17)	0.65	A threat passes only when its aggregate specificity score reaches 0.65. Given the configured weights, this necessarily combines concrete technical language with either structural linkage or substantive, non-vague wording.

The threat specificity criterion (CM-17) deserves a fuller explanation because it is the key rule-based natural language check for wording quality in the catalogue. Rather than a single keyword test, each threat receives a score from 0 to 1 that combines three signals. It passes only when the total reaches the 0.65 threshold in Table 6.3:

- **Component/interface linkage** (+0.30): the threat is tied to a concrete attack interface (an `interface_id`), so it names *where* it acts rather than floating free of the system model.
- **Concrete technical language** (+0.40): the threat’s wording is matched against a curated reference vocabulary. This signal fires only when at least two distinct vocabulary terms are present.
- **Substance without vagueness** (+0.30): the description exceeds the keyword-only minimum word count and contains fewer than two vague-wording markers, distinguishing a real actor-action-impact statement from a padded but empty one.

The three weights ($0.30 + 0.40 + 0.30 = 1.0$) intentionally make distinctive language a necessary ingredient: linkage plus length alone reaches only 0.60 and does not pass. Reaching 0.65 therefore requires concrete wording in addition to structural linkage or narrative length. This reduces sensitivity to keyword stuffing and reflects the interview position (E3, E4, E5) that a specific threat must be both *located* in the system and *concretely described*.

The design remains transparent and rule-based. Future extensions can still add embedding-based similarity on top of the current vocabulary-based baseline.

Because these values are judgement calls, Chapter 8 reports two different checks. A limited case-level sweep recomputes the ranking of a clean, a mildly damaged, and a heavily damaged TRA under joint low, default, and high settings. An analytical boundary audit then shows which near-cut-off inputs change classification as a threshold moves. The first is a robustness check for three separated cases. The second makes threshold dependence explicit. Neither constitutes empirical calibration, which requires independently reviewed real-TRA corpora and remains future work.

6.7 Evaluation Pipeline

The evaluation framework defines how the model is applied to a concrete TRA. It is organised as a seven-step pipeline for the computed core-tier workflow and the aggregation logic agreed by the experts. Figure 6.1 gives an overview of this flow before the individual steps are described.

1. **Entry gate.** Evaluate the reviewability conditions: mandatory section completion (CM-03), placeholder detection (CM-04), and the no-threat red flag (CM-16). Flag them prominently as *entry conditions*: when one fails, the TRA is marked as not yet reviewable and the corresponding findings are surfaced first, signalling that it should be returned to its author. All core criteria are still computed so the reviewer obtains the full picture rather than a single blocking error.
2. **Automatic layer.** Compute all *Auto* criteria directly from the structured representation, producing objective sub-scores for coverage, traceability, rating coherence, and comprehensibility proxies.
3. **Semi-automatic layer.** Run natural language or model-assisted criteria (threat structure completeness, vagueness, duplicate and similarity detection), producing *candidate findings* flagged for expert confirmation.
4. **Dimension roll-up.** Aggregate computed core-criterion scores per dimension by averaging their status weights (the unweighted PoC baseline; per-criterion priorities are recorded in the catalogue for future elicitation).
5. **Overall indicator.** Report the core-criterion-level overall mean alongside the *failed-check count* and *status-weighted dimension scores*. The result is never presented as a stand-alone number.
6. **Actionable feedback.** For every failed or low-scoring criterion, emit a triple of *expectation*, *meaning of the low score*, and a *candidate improvement action* for reviewer confirmation, clustering repeated deficiencies into batch guidance.
7. **Expert sign-off.** Experts validate the automated and AI-assisted outputs for project-specific validity before the assessment is finalised, retaining a human-in-the-loop step.

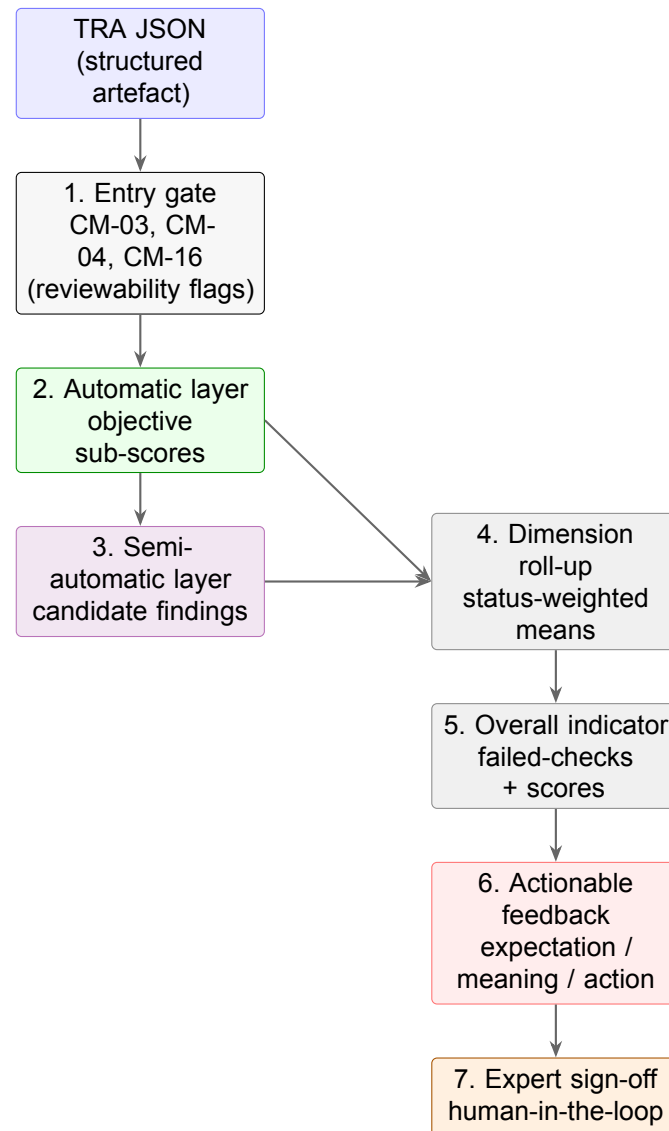


Figure 6.1: The seven-step evaluation pipeline. Step 1 checks reviewability, and Steps 2 and 3 assess the automatic and semi-automatic tiers. Steps 4 and 5 aggregate the results into status-weighted dimension scores and an overall indicator. Steps 6 and 7 turn the measurements into guidance while keeping a human in the loop. Box colours indicate the role of each step: blue for input, green and violet for the automatic and semi-automatic tiers, grey for aggregation, red for feedback, and orange for expert sign-off.

This pipeline operationalises the experts' shared view that automation should *support* review rather than replace it: steps 1 to 3 reduce the mechanical burden, step 6 turns measurements into guidance, and step 7 keeps judgement with the reviewer.

6.8 Inputs, Representation, and Schema Dependence

The framework operates on a *structured representation* of the TRA in which the relevant elements, including scope, components, interfaces, communications, security zones, assets, protection goals, threat scenarios with their ratings, and assumptions, are available as explicit fields and relationships. These explicit fields and relationships enable rule-based checking. The PoC adopts a JSON encoding for them: each element and its links become named fields, which keeps the data machine-readable while staying recognisably close to the spreadsheet-style layouts in which industrial TRAs are typically authored.

A consequence of grounding criteria in concrete inputs is that some criteria depend on fields that a given export may not contain. Role participation (CM-01), authority approval (CM-27), and known deficiency evidence (CM-28) are the clearest examples: the experts treated them as quality-relevant, but the information often resides outside the TRA document. The framework handles this limitation explicitly. Where the required input is absent, the criterion reports *not assessable* rather than passing or failing. It also identifies a small set of optional schema extensions (a participants block, approval markers, and deficiency-evidence links) that would move these criteria from expert or non-assessable status to automatic checking. The resulting framework's coverage is therefore *extensible by design*.

6.9 Relationship to Existing Maturity and Standards Models

The framework is positioned deliberately against existing maturity- and standards-based models. IEC 62443-4-1 defines secure product development lifecycle requirements and therefore informs expectations about development processes and their evidence (IEC, 2018). It is not itself a TRA maturity model. A separate TRA *maturity model* or qualitative review checklist may use such standards as a reference when assessing the *process and its evidence base*. The framework developed here instead assesses the *quality of the TRA artefact itself*. The two overlap where evidence is intrinsic to the document: formal completeness, coverage, consistency and traceability, comprehensibility, and any process-and-governance traces captured in the artefact. This is the part the framework can automate or support semi-automatically. They diverge on quality that depends on external secure development evidence, such as participation records, authority sign-off, and known deficiency artefacts. A maturity model audits that evidence, whereas the framework either leaves it to expert review or makes it checkable through a schema extension. The framework is therefore *complementary* to a maturity model: it provides continuous, objective, per-TRA feedback that reduces reviewer effort on the mechanical checks and feeds the higher-level maturity assessment. Standards such as IEC 62443-3-2 (IEC, 2020) contribute differently, by defining the expected analytical content (system elements, zones, conduits, threats, security levels) and thereby informing the coverage and completeness criteria.

6.10 Chapter Summary

Chapter 6 consolidated the interview findings into a structured quality model and an evaluation framework. The model organises TRA quality into five dimensions and a catalogue of named criteria, each carrying an explicit degree of automation, checking logic, and required inputs. Scoring follows the automation class: percentages or booleans for automatic and semi-automatic criteria, and a five-level ordinal scale for judgement-based ones. A seven-step pipeline ties these together, running from entry gates to status-weighted dimension scores, an overall indicator that is not presented alone, and actionable feedback. The framework runs on a structured JSON representation of the TRA, reports missing inputs honestly, and stays complementary to process-oriented maturity models and standards. Chapter 7 implements the core tier as seven algorithm families, and Chapter 8 evaluates it against four yes/no evaluation questions: automation scope (EO1), detection validity (EO2), usefulness and interpretability (EO3), and reviewer-expectation alignment (EO4). These questions are examined through a controlled mutation experiment, an exploratory industrial reviewer case study, and a descriptive AI-assisted comparison, as set out in Section 8.1 and Table 8.2.

7 PoC Implementation

Chapter 6 defined the quality model, the consolidated criterion catalogue, the scoring scheme, and the seven-step evaluation pipeline. This chapter describes the **PoC implementation** that turns that framework into a working tool. Its purpose is to demonstrate feasibility: to show that the core tier criteria (CM-01 to CM-28) can be operationalised in software from a structured TRA representation and reported in an interpretable form, with semi-automatic findings retained for human confirmation. This provides the practical basis for the evaluation in Chapter 8 and contributes to the answer to RQ3.

In line with the design commitments of Chapter 6, the implementation does not attempt to automate expert judgement. It computes the automatic and semi-automatic criteria, grades each against transparent thresholds, aggregates them into status-weighted dimension scores and an overall indicator that is not presented alone, and surfaces per-criterion findings that a reviewer can act on. The four extended criteria (CM-29 to CM-32) require expert judgement and are therefore outside the automated scope by design.

The discussion remains at the level of the *artefact and its algorithms* rather than the content of any particular analysis. All illustrative material uses the public MiniCPS case introduced in Section 7.2. The tool has also been applied to anonymised industrial TRAs, but, for confidentiality reasons discussed in Section 7.10 and in line with the ethical considerations of Section 4.7, no confidential project content is reproduced.

7.1 Implementation Goals and Technology Choice

The prototype was guided by four goals derived from the framework. First, *fidelity to the model*: each implemented check must correspond to a defined criterion from the catalogue, with the same required inputs and checking logic. Second, *reproducibility*: the tool must run on any machine without a complex setup, so that the evaluation can be repeated and inspected by others. Third, *schema generality*: the same code must handle the different container layouts that industrial TRA exports use, without hard-coding a single product's structure. Fourth, *interpretability*: the output must present not just numbers but per-criterion pass/fail detail and actionable feedback.

The tool is implemented in Python 3 using only the standard library, with no third-party dependencies. This improves reproducibility: the analyser parses a TRA in JSON, computes the metrics, and writes a standalone interactive HTML dashboard together with a machine-readable JSON metrics output, all from a single script. The absence of external packages removes version- and installation-related barriers, which is important for a tool intended to be re-run as part of a transparent evaluation.

7.2 Public Case Under Analysis: MiniCPS

To illustrate and later evaluate the tool without exposing confidential material, the implementation uses two related public references. **MiniCPS** is an open-source toolkit for emulating CPS networks and supports industrial protocols including Modbus/TCP and EtherNet/IP (Antonioli & Tippenhauer, 2015). The plant architecture used for the reference TRA is based on the SWaT testbed, a separate six-stage water treatment system with PLCs, sensors, actuators, an HMI, and a historian (Mathur & Tippenhauer, 2016). MiniCPS supplies the reproducible CPS network tooling context, whereas SWaT supplies the public plant architecture. MiniCPS is not itself the SWaT plant.

Neither public reference is modified. They provide the documented basis for the structured TRA used by the checker: process stages and controllers become in-scope components, sensor, actuator, and network links become interfaces and communications, network boundaries become security zones, and plant availability, process integrity, and water safety become assets and protection goals. Using public references in this way allows the implementation and its evaluation to be examined end-to-end without disclosing a confidential industrial TRA.

7.3 Architecture and Data Flow

The tool follows the seven-step pipeline of Chapter 6, realised as a single-pass analysis function that consumes a parsed TRA and returns a structured result object. Figure 7.1 shows the data flow, from the JSON input through parsing and normalisation, criterion computation, grading, and dimension roll-up, to the HTML and JSON outputs.

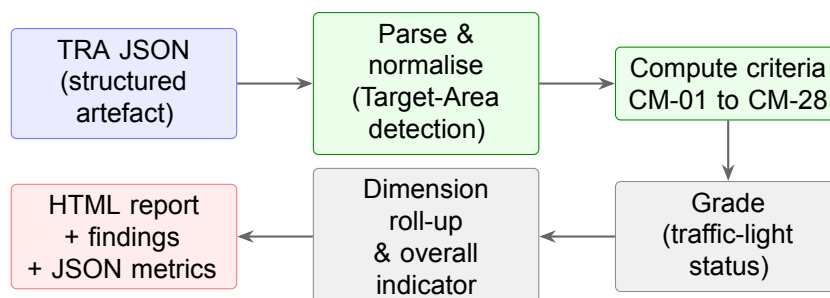


Figure 7.1: Data flow of the PoC. A TRA in JSON is parsed and structurally normalised, the core criteria are computed, each is graded to a traffic-light status, the statuses are aggregated into dimension scores and an overall indicator, and the result is written as an interactive HTML dashboard with per-criterion findings and a machine-readable JSON metrics output.

7.4 Structural Schema Abstraction

A practical obstacle is that TRA exports describe one of two *target areas* that use different container names for the same underlying structure. A software component analysis uses

keys such as `SWComponents` and `LogicalInterfaces`, whereas a system deployment analysis uses `SystemComponents` and `NetworkFacingInterfaces`. The inner field names (interface and communication identifiers, source components, target interfaces) are identical across both.

Rather than hard-coding either variant, the tool detects the relevant container *structurally*: it prefers the known keys and otherwise falls back to any top-level list whose key ends in `Components`. This keeps the criterion logic independent of the specific product or target area and allows the same implementation to run unchanged on the public MiniCPS case and on anonymised industrial exports. Listing 7.1 sketches this abstraction.

```
COMPONENT_ARRAY_KEYS = ("SWComponents", "SystemComponents")

def components_of(tra):
    # Prefer the known container keys for either target area
    for key in COMPONENT_ARRAY_KEYS:
        if isinstance(tra.get(key), list):
            return tra[key], key
    # Otherwise, fall back to any top-level "*Components" list
    for key, val in tra.items():
        if key.endswith("Components") and isinstance(val, list):
            return val, key
    return [], None
```

Listing 7.1: Structural detection of the component container, independent of target area

7.5 Core Criterion Algorithm Families

The PoC computes all 28 core criteria defined in Chapter 6. The four extended criteria CM-29–CM-32 require expert judgement and are outside the automated scope. The core criteria do not require 28 unrelated programs. They can be organised into seven algorithm families whose members share an input pattern and decision rule. This family view complements the dimension view of Chapter 6: dimensions describe the quality concern, whereas the families below describe the computation.

Each family is documented through its inputs, normalisation, decision logic, thresholds, outputs and failure handling, computational cost, and a worked example. Table 7.1 maps every core criterion to exactly one primary family. Some criteria combine more than one signal, but the table assigns them to the family that determines their reported value.

7.5.1 Family A — Ratio and Coverage Criteria

Family A asks what proportion of a declared or relevant set satisfies a required relationship. It covers validated assumptions (CM-05), threats linked to components, interfaces, communications, protection goals, and assets (CM-06–CM-12), the distribution of C/I/A protection

Table 7.1: Algorithm families and the core criteria they compute

Family	Primary calculation	Core criteria
A — Ratio and coverage	Counted proportion of a relevant set	CM-05, CM-06–CM-12, CM-18, CM-21, CM-23
B — Presence and entry gates	Required content or prohibited marker	CM-03, CM-04, CM-14, CM-16
C — Descriptive adequacy	Word-count, slot, and vagueness checks	CM-13, CM-15, CM-25, CM-26
D — Threat specificity	Curated technical-language signals	CM-17
E — Pairwise similarity	Token-Jaccard comparison and rating agreement	CM-19, CM-24
F — Matrix coherence	Exact impact–likelihood lookup and rationale	CM-20
G — Governance and distribution	Metadata, evidence, and rating-pattern checks	CM-01, CM-02, CM-22, CM-27, CM-28

goals (CM-18), threats with a handling decision (CM-21), and assumptions linked to the elements they qualify (CM-23).

Inputs and normalisation. For each criterion, the analyser reads a criterion-specific relevant set and the references or completed fields that count as satisfying it. Identifiers and categorical labels are normalised before comparison, and duplicates are removed where the criterion concerns distinct elements.

Decision logic. The common calculation, formalised in Equation 7.1, is a proportion:

$$\text{score} = 100 \frac{|\text{relevant} \cap \text{satisfied}|}{|\text{relevant}|}. \quad (7.1)$$

For CM-18, the counted proportions describe the balance among C//A goals. For CM-23, they are calculated from assumption definitions and their links by type. Thus, these checks share a counting and normalisation pattern even though their relevant sets differ.

Listing 7.2 shows the corresponding set-based computation for CM-07.

```
def covered_percent(relevant, satisfied):
    if not relevant:
        return None                # reported as not assessable
    covered = set(relevant) & set(satisfied)
    return round(100 * len(covered) / len(set(relevant)), 1)

score = covered_percent(declared_ifaces, referenced_ifaces)
```

Listing 7.2: Covered-fraction computation (CM-07 shown; other Family A criteria substitute their own relevant and satisfied sets)

Thresholds, output, and failure handling. Higher-is-better percentages use the standard bands: *ok* at or above 90 %, *warning* at or above 60 %, and *bad* below 60 %. In addition to the percentage, the report names the uncovered or incomplete elements. When a criterion genuinely has no applicable denominator, or its required source field was not captured, it is reported as *not assessable* and excluded from aggregation rather than converted into a false zero or a misleading pass.

Cost and example. Building the reference sets and comparing them is linear in the number of relevant elements and threat links, approximately $O(N + T)$. If five interfaces are declared and four are referenced by threats, CM-07 returns 80 %, a warning, and identifies the single uncovered interface.

7.5.2 Family B — Presence, Placeholder, and Entry-Gate Checks

Family B contains the minimum reviewability checks: mandatory sections must be present and non-empty (CM-03), unfinished placeholders must be absent (CM-04), out-of-scope boundaries must be stated where applicable (CM-14), and the analysis must contain at least one threat (CM-16).

Inputs and normalisation. Required sections are tested for both existence and content. Text-bearing objects are flattened recursively so that placeholder markers can be found independently of their location in the nested record. Boundary statements and the threat collection are read from their corresponding structured fields.

Decision logic and thresholds. CM-03 reports the share of required sections containing usable content. CM-14 and CM-16 are presence gates. CM-04 counts fixed unfinished-entry markers such as TBD, TODO, QUESTION, and ??. Percentage and boolean results use the standard higher-is-better bands. For the placeholder count, zero is *ok*, one to five is a *warning*, and more than five is *bad*.

Output and failure handling. The report lists each missing section, placeholder location, or absent boundary. The no-threat condition is surfaced as an entry warning because an empty threat collection makes later coverage values misleading. A missing optional boundary representation is distinguished from a confirmed absence where the schema permits that distinction.

Cost and example. These checks require one traversal of the required fields and text, $O(N + T)$. A draft with all mandatory sections but two threat descriptions containing “impact TBD” passes CM-03 and receives a CM-04 warning that points to both descriptions.

7.5.3 Family C — Descriptive-Adequacy and Structure Checks

Family C evaluates whether descriptive fields contain enough structure to support review. It covers the system overview (CM-13), component or scope descriptions (CM-15), threat-statement structure (CM-25), and vague or hedging wording (CM-26).

Inputs and normalisation. The analyser tokenises the relevant text and counts words. For CM-25, each threat is checked for the structural information defined in the catalogue: actor, action or substantive description, target or interface, weakness where represented, impact, and protection goal. CM-26 compares the normalised wording against the configured vague-expression list.

Decision logic and thresholds. CM-13 requires at least 20 words and CM-15 at least five. CM-25 reports the proportion of required threat slots that are filled, reusing the six-word minimum to distinguish an action statement from a bare label. CM-26 flags a threat containing at least two vague or generic markers. These are heuristic floors rather than semantic endorsements, so all four criteria remain semi-automatic.

Output and failure handling. Findings identify the short field, missing slot, or vague expression rather than returning only a score. Empty text is treated as missing content. A field unavailable because of the capture path is reported separately where the schema makes that absence observable.

Cost and example. The family scans each text once, approximately $O(TL)$ for average description length L . A threat that names an attacker, action, interface, impact, and goal but no weakness is reported as missing that one structural element rather than as an unexplained generic failure.

7.5.4 Family D — Rule-Based Threat Specificity (CM-17)

CM-17 estimates whether a threat is concrete and system-specific rather than a generic label. Because substantive specificity ultimately requires context, the result is a candidate finding for reviewer confirmation.

Inputs and normalisation. The analyser combines the threat name and description, records whether it is linked to a concrete interface, tokenises the text, and compares its terms with the curated reference vocabulary derived from the corpus of Section 7.7.

Decision logic. Three transparent signals are combined as shown in Equation 7.2:

$$specificity = 0.30 I_{interface} + 0.40 I_{distinctive} + 0.30 I_{substantive}. \quad (7.2)$$

The distinctive-language signal requires at least two matching vocabulary terms. The substance signal requires at least six words and fewer than two vague markers. A threat passes at 0.65 or above, subject to the safeguards described in Section 6.6.

Thresholds, output, and failure handling. The weights intentionally prevent interface linkage plus length alone from passing: $0.30 + 0.30 = 0.60$. The report shows the contributing signals and a text excerpt, allowing the reviewer to understand and challenge the result. If the configured corpus is unavailable, the vocabulary-dependent signal cannot be claimed and the report must expose that input limitation rather than treat generic wording as verified.

Cost and example. After the reference vocabulary has been built, each threat is scanned once, approximately $O(TL)$. The label “Spoofing” lacks length, linkage, and distinctive context and fails. A threat describing replayed Modbus commands against a named PLC interface supplies both structural and distinctive signals and can clear the threshold.

7.5.5 Family E — Pairwise Similarity and Rating Agreement

Family E compares threats with one another. CM-24 identifies candidate near-duplicates. CM-19 asks whether sufficiently similar threats carry consistent ratings.

Inputs and normalisation. Each threat’s name and description are tokenised into a set of normalised content words. Empty and placeholder-only token sets are not treated as meaningful evidence of similarity.

Decision logic. For every unordered threat pair, the analyser computes the Jaccard similarity defined in Equation 7.3:

$$J(A, B) = \frac{|A \cap B|}{|A \cup B|}. \quad (7.3)$$

Pairs with $J \geq 0.6$ are candidate near-duplicates for CM-24. CM-19 then compares the stored ratings within the similar pairs or clusters and flags divergent values. The comparison is lexical and structural. By itself, it does not prove that two threats are semantically equivalent.

Thresholds, output, and failure handling. The 0.6 cut-off is a configurable prototype threshold evaluated in the sensitivity sweep. Each finding contains both threat identifiers, their similarity, and the relevant ratings so that a reviewer can confirm whether the comparison is meaningful. Pairs lacking usable text or ratings are skipped or reported as not assessable rather than assigned an invented agreement value.

Cost and example. Comparing all pairs costs $O(T^2k)$ for average token set size k . Two HMI denial-of-service descriptions with substantial token overlap may exceed 0.6. CM-24 reports the pair, while CM-19 additionally reports any difference in their stored ratings.

7.5.6 Family F — Risk-Matrix Coherence (CM-20)

CM-20 encodes the rule that a stored risk rating should agree with the project's impact-likelihood matrix and should be accompanied by an explanatory rationale.

Inputs and normalisation. The analyser reads impact, likelihood, stored risk, and the rating-comment field. Recognised labels are normalised before lookup.

Decision logic. The expected rating is obtained from the exact matrix cell as specified in Equation 7.4:

$$expected = RISK_MATRIX[impact][likelihood]. \quad (7.4)$$

A complete pass requires the stored value to equal the expected value and the required rationale field to be present.

Listing 7.3 shows the corresponding matrix-cell and rationale check.

```
expected = RISK_MATRIX[norm(impact)][norm(likelihood)]
coherent = norm(stored_risk) == expected
passes   = coherent and has_rating_comment(threat)
```

Listing 7.3: Exact matrix-cell and rationale verification for CM-20

Thresholds, output, and failure handling. Matrix agreement is exact; there is no partial-credit threshold. A finding reports the input labels, stored rating, expected rating, and missing-comment condition. Unknown or absent matrix labels are skipped or marked not assessable rather than forced into a standard cell.

Cost and example. Each threat requires constant-time lookup, so the family costs $O(T)$. If the matrix expects *Significant* for a threat's impact and likelihood but the stored value is *Moderate*, the report names both values and flags the mismatch.

7.5.7 Family G — Governance and Rating-Distribution Checks

Family G checks whether the structured artefact carries observable traces of the review process and whether its risk ratings show an obviously degenerate pattern. It covers participation metadata (CM-01), document maintenance (CM-02), rating distribution (CM-22), approval metadata (CM-27), and references to known-deficiency evidence (CM-28).

Inputs and normalisation. The checks read the available participant, creation/change, approval, and evidence-reference fields. CM-22 normalises and counts the stored risk labels. These criteria deliberately use only evidence represented in the structured artefact. They do not infer an undocumented process.

Decision logic and thresholds. CM-01, CM-27, and CM-28 test for the relevant metadata or reference signal. CM-02 compares the available creation, change, or version information to determine whether the document shows evidence of maintenance. CM-22 inspects the rating frequency distribution and flags a degenerate case in which all ratings have the same value. The result is a rubber-stamping warning, not proof that a naturally concentrated distribution is wrong.

Output and failure handling. Findings identify the missing process trace or the observed rating distribution. Because current exports may omit participant, approval, or external-evidence metadata, the affected criteria report *not assessable* when the input is absent. This is essential: absence from an export is not equivalent to evidence that the underlying activity did not occur.

Cost and example. Each metadata field or rating is visited once, so the cost is $O(T+N)$. If all twenty rated threats carry *Moderate*, CM-22 reports the uniform distribution as a possible rubber-stamping pattern for expert review.

7.6 Grading and Aggregation

The families produce raw percentages, booleans, counts, or a not-assessable state. A common grading layer converts assessable values into the traffic-light statuses used throughout the report.

Inputs and normalisation. The grading layer receives each criterion's raw result, whether higher or lower values are preferable, and whether the required input was available. A result whose required evidence is absent remains *not assessable*. It is not converted into a passing or failing value.

Decision logic. Higher-is-better percentages are *ok* at or above 90, *warning* at or above 60, and *bad* below 60. Lower-is-better percentages use the configured inverted bands. Count criteria are *ok* at zero, a *warning* from one to five, and *bad* above five.

Listing 7.4 presents the implemented grading logic for these bands.

```
def grade(m):
    if m.get("kind") == "count":
        return "ok" if m["num"] == 0 else ("warn" if m["num"] <= 5 else "bad")
    v = m["value"]
    if m["better"] == "low":
        return "ok" if v <= 10 else ("warn" if v <= 40 else "bad")
    return "ok" if v >= 90 else ("warn" if v >= 60 else "bad")
```

Listing 7.4: Traffic-light grading using the cut-offs of Section 6.5

The machine-readable implementation uses the literal string `warn`, while the dashboard and thesis prose display the human-readable status *warning*. Both labels therefore refer to the same middle status band.

Each status is mapped to a weight (*ok* = 100, *warning* = 60, *bad* = 20). A dimension score is the unweighted mean of its assessed criterion weights, and the overall indicator is the unweighted mean over all assessed criteria. A criterion whose required inputs are absent remains *not assessable* and is excluded from both means. For example, two *ok* results and one *warning* produce $(100 + 100 + 60)/3 = 86.7$. An additional not-assessable criterion does not change that mean.

Output, failure handling, and cost. The report presents the overall indicator together with its dimension breakdown, failed-check count, and underlying criterion findings, so the aggregate never stands alone. Grading and aggregation visit each criterion once and therefore cost $O(M)$ for M criteria.

7.7 Reference Corpus and Configurable Thresholds

Two elements of the implementation are configuration rather than fixed logic. First, the rule-based specificity check (CM-17) compares each threat against a curated corpus of well-formed threat scenarios that establishes a reference vocabulary. The corpus is a directory of example TRAs and can be extended without changing the code. Second, the numeric thresholds of Section 6.6, including minimum word counts and the near-duplicate similarity cut-off, are declared as transparent parameters rather than hidden constants, so that their influence can be examined through the sensitivity analysis reported in Chapter 8.

7.8 Output and Reporting

The tool writes its result as a standalone interactive HTML dashboard and a machine-readable JSON metrics output. For each criterion it reports the identifier and name, the dimension, the automation class, the computed value and status, and the explicit *pass* and *fail* lists that name the specific elements involved (for example, which interfaces are uncovered or which threats carry an incoherent rating). The reviewability entry conditions (CM-03, CM-04, CM-16) are surfaced first, and the per-dimension breakdown and overall indicator are presented together with the failed-check count so that, consistent with Section 6.5, no single number stands alone. This element-level detail makes the output actionable: a low score is always accompanied by the concrete findings that produced it. The JSON output also separates the machine-readable assessment from the presentation layer and supports downstream reuse without parsing the HTML report.

Figure 7.2 shows the overall indicator and per-dimension summary generated for the public MiniCPS reference case. Figure 7.3 shows the detailed criterion scorecard view that supports reviewer traceability from status labels back to concrete pass/fail readings.

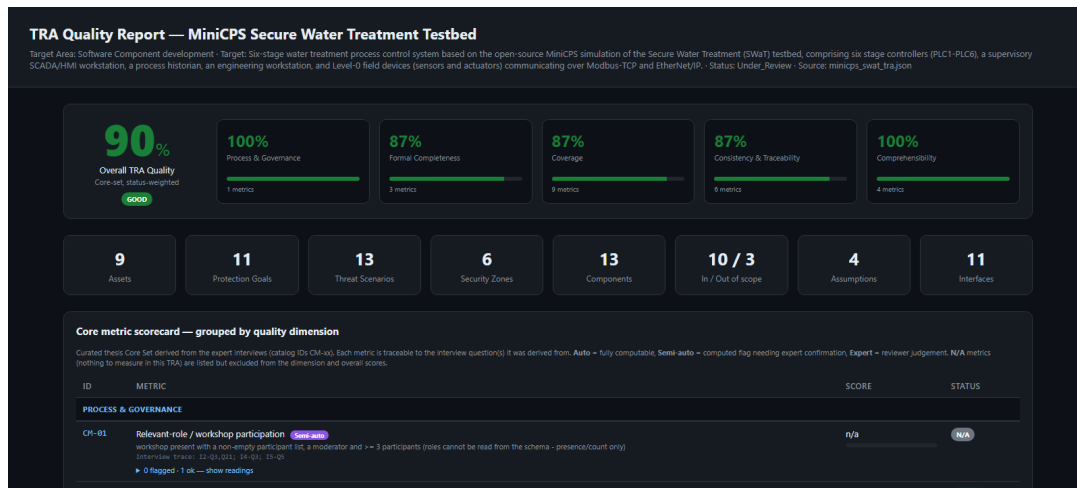


Figure 7.2: Overall TRA-quality indicator and per-dimension scorecard summary generated by the prototype for the MiniCPS reference case.

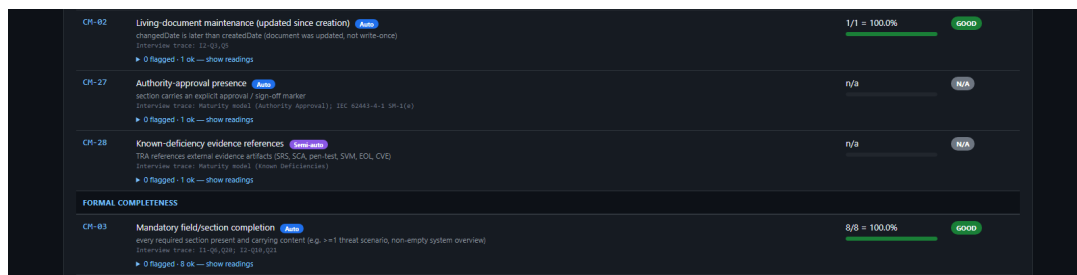


Figure 7.3: Representative excerpt from the detailed core-metric scorecard in the HTML report, including criterion status and expandable pass/fail evidence.

7.9 Implementation Verification and Traceability

Verification is performed at system level: controlled inputs pass through the complete analyser and the outputs are compared with declared expectations. Table 7.2 links the implementation commitments of Section 7.1 to the detailed evidence of Chapter 8.

Table 7.2: Traceability from implementation commitments to verification evidence

Commitment	Observable implementation behaviour	Verification evidence
Model fidelity	Catalogue identifiers, inputs, calculations, status rules, and aggregation are retained.	All thirteen variants change a targeted status band (Section 8.4.5; Appendix F).
Schema generality	Target-area containers are detected structurally and normalised.	The same analyser processes the public and confidential internal cases (Sections 8.4.1 and 8.5).
Failure transparency	Missing metadata becomes <i>not assessable</i> ; unknown risk labels are skipped.	CM-27/28 and the CM-19 baseline limitation remain explicit (Section 8.4.5).
Configurability	Word-count, language, and similarity thresholds are parameters.	The low/default/high sweep preserves case ordering (Section 8.4.6; Appendix H).
Interpretability	Element-level pass/fail evidence appears in HTML and JSON.	Practitioner and usefulness reviews assess actionability (Sections 8.5 and 8.5).

This evidence verifies end-to-end prototype behaviour, but does not claim formal verification or exhaustive unit-test coverage. Appendix D documents the artefacts and procedure for independent repetition.

7.10 Confidentiality-Preserving Design

The implementation is described and demonstrated without disclosing confidential material. All illustrative inputs and outputs use the public MiniCPS case, whose architecture is openly documented and citable. Where the tool has been applied to industrial TRAs, only aggregate, structural, or anonymised observations are discussed, and no real component names, threat text, ratings, or product-identifying details are reproduced. The tool can support this approach because it operates on a *structural* representation: its logic depends on the presence and relationships of fields, not on their confidential values, so the method can be shown in full while the data remain protected. Aggregate-only reporting is consistent with the ethical and confidentiality considerations set out in Section 4.7.

7.11 Chapter Summary

Chapter 7 presented the PoC implementation of the core-tier criteria. The tool is a dependency-free Python program that parses a structured TRA, detects the target-area layout structurally, computes the 28 automatic and semi-automatic criteria (17 automatic and 11 semi-automatic) using transparent algorithms, grades each to a traffic-light status, aggregates them into status-weighted dimension scores and an overall indicator that is not presented alone, and produces an interpretable HTML report with element-level findings together with the same assessment in machine-readable JSON. Representative algorithms are organised into seven families covering all 28 core criteria: ratios and coverage, presence gates, descriptive adequacy, threat specificity, pairwise similarity, matrix coherence, and governance/distribution checks. This makes the mapping from every criterion to its primary computation explicit without repeating near-identical logic. The implementation commitments are also traced to system-level verification evidence in Section 7.9. The implementation is demonstrated on the public MiniCPS case and is designed so that it can be applied to confidential industrial TRAs without disclosing their content. Chapter 8 evaluates the tool through a controlled mutation experiment, an exploratory industrial reviewer case study, and an AI-assisted comparison.

8 Evaluation

8.1 Objectives and Evaluation Design

This chapter tests whether the quality model of Chapter 6, once implemented in the tool of Chapter 7, responds to known TRA quality defects and produces findings that experienced practitioners can interpret. It is the main source of evidence for RQ3, concerning the extent to which quality indicators can be checked automatically, and it also tests RQ1 and RQ2 by examining whether the operationalised indicators behave as the expert evidence led the study to expect.

The evaluation separates four *evaluation questions*, which state what must be established, from three *evidence lenses*, which state how the evidence is obtained. Each question is answerable with *yes* or *no*, subject to an explicitly stated scope, and receives a verdict immediately after its supporting evaluation. This prevents a claim from being treated as established merely because it appears in more than one part of the chapter and makes the evidential basis of each conclusion traceable.

8.1.1 EO1–EO4

EO1—Automation scope. Question: Can most catalogue criteria be computed from a structured TRA while keeping the boundary between automatic, semi-automatic, and expert judgement explicit?

EO2—Detection validity. Question: Does the checker detect intentionally injected defects while leaving unrelated criteria substantially stable?

EO3—Usefulness and interpretability. Question: Do experienced practitioners find the checker understandable and useful as a first-pass review aid?

EO4—Reviewer-expectation alignment. Question: Can differences between reviewer expectations and checker behaviour be explained and classified in a traceable way?

EO4 addresses a limitation that a purely technical experiment cannot resolve. EO2 can show that a criterion reacts to its designed defect, but it cannot show whether a reviewer will interpret that reaction correctly, mistake a structural pass for proof of substantive quality, or encounter a finding caused by information lost during data capture. EO4 therefore treats reviewer expectation as an explicit source of evidence and records a cause for each observed mismatch.

8.1.2 The Three Evidence Lenses

Table 8.1 summarises the purpose and validity emphasis of the three evidence lenses.

Table 8.1: The three evidence lenses used in this chapter

Lens	Vehicle and purpose	Validity emphasis
L1—Controlled mutation	Public MiniCPS/SWaT-derived mutation study: seed one defect class at a time, test whether the targeted criteria respond, and characterise any off-target movement.	Internal
L2—Industrial reviewer case	Application to genuine internal TRAs and written feedback from six practitioners: five interview participants (E1–E5) and one additional practitioner reviewer (R1) from a separate organisational unit, with uneven criterion-level expectation and usefulness feedback.	Practice-based
L3—AI-assisted comparison	Comparison of the rule-based report with two separately generated AI-assisted interpretation reports on one shared TRA artefact.	Secondary illustrative comparison (not validation)

The lenses are complementary rather than interchangeable. L1 provides controlled, repeatable evidence but cannot demonstrate real-world usefulness. L2 supplies practice-based evidence but cannot provide planted ground truth or systematic criterion-level validation. L3 asks whether a separate assessment route identifies compatible issue families, but agreement with general-purpose LLM outputs is only a plausibility comparison and its single-case design does not support validity claims.

8.1.3 Objective-to-Evidence Mapping

Table 8.2 fixes the primary and secondary evidential basis of each objective. The mapping is used throughout the chapter so that an objective is not described as being supported “everywhere” without identifying the evidence on which the conclusion rests.

Table 8.2: Objective-to-evidence mapping

Objective	Evaluation question	Primary evidence	Secondary evidence
EO1	Can the automation boundary be stated explicitly?	Scope analysis (Section 8.3)	L1 and L2
EO2	Does the checker detect seeded defects with limited unrelated movement?	L1 (Section 8.4)	—
EO3	Is the checker useful and interpretable as a first-pass review aid?	L2 (Section 8.5)	—
EO4	Can expectation differences be explained and classified?	L2 (Section 8.6.1) and synthesis (Section 8.6.3)	L3 (Section 8.6.4)

The rest of the chapter follows the EO1–EO4 sequence. The calculation overview is given first, followed by the EO1 scope analysis, the public-case setup and EO2 mutation experiment, the EO3 practitioner evaluation, and the EO4 expectation and classification analysis, including the illustrative L3 comparison. Threats to validity qualify the combined evidence before the chapter summary.

8.2 Metric Descriptions and Calculation Overview

A result can only be interpreted correctly if the reader understands what kind of calculation produced it. The criterion definitions, measurement summaries, and automation classes are provided in Chapter 6 and Appendix B. Representative algorithms and failure behaviour are documented in Chapter 7. Table 8.3 condenses the shared calculation patterns needed to read the evaluation without duplicating the complete catalogue. Chapter 7 gives the finer seven-family algorithm mapping. The table below consolidates those families by how their results must be interpreted during evaluation.

Table 8.3: Evaluation-oriented calculation patterns for the implemented core criteria

Pattern	Core criteria	Calculation and interpretation
Process and formal gates	CM-01–CM-05, CM-14, CM-16, CM-27, CM-28	Presence, metadata, role, validation, or unfinished-entry checks. Missing optional metadata produces <i>not assessable</i> . A pass confirms a minimum precondition, not substantive analytical quality.
Coverage ratios	CM-06–CM-12, CM-18, CM-21, CM-23	Referenced or completed elements divided by the declared relevant elements. Failures localise missing links. Passes do not establish semantic adequacy.
Consistency comparisons	CM-19, CM-20, CM-22, CM-24	Exact matrix verification, distribution checks, or pairwise similarity and rating comparison. Similarity-based results remain subject to contextual confirmation.
Text and scope heuristics	CM-13, CM-15, CM-17, CM-25, CM-26	Word-count floors, required-slot checks, vocabulary-based specificity, and vague-language markers. These produce candidate findings rather than final semantic judgements.
Aggregation	All assessed core criteria	Values are graded as <i>ok</i> , <i>warning</i> , or <i>bad</i> and mapped to 100, 60, or 20. Not-assessable criteria are excluded from the dimension and overall means.

8.3 EO1: Automation Scope

Chapter 6 already records the automation class of every criterion. Table 8.4 condenses those assignments to answer EO1 without repeating the catalogue definitions. The criterion-level assignments underlying this summary are documented in Appendix B, Table B.1.

Thus, 28 of 32 criteria are computable in principle, but 11 of those produce semi-automatic findings rather than objective verdicts. The boundary follows the available evidence: properties encoded in structured fields can be calculated, whereas diagram adequacy, method quality, and tacit contextual judgement remain expert tasks. The L2 evidence adds a second condition: a formally automatic rule is reliable only when the capture path preserves the fields on which it operates. This does not change the catalogue’s automation classes, but it

Table 8.4: Automation scope of the criterion catalogue by quality dimension

Dimension	Auto	Semi	Expert	Evaluation implication
D1 Process & Governance	2	2	0	Computability depends strongly on participation, approval, and evidence metadata being present in the export.
D2 Formal Completeness	3	0	0	Fully deterministic on the structured mandatory fields.
D3 Coverage	8	1	3	Predominantly automatic; diagram and method adequacy remain expert judgements.
D4 Consistency & Traceability	4	4	1	Textual similarity and justification findings require confirmation.
D5 Comprehensibility	0	4	0	All results are heuristic candidate findings.
Total	17	11	4	

limits the practical interpretation of coverage failures when source evidence was lost during import.

EO1 conclusion. **EO1 is supported, with an explicit expert boundary.** Most catalogue criteria can be computed from the structured TRA: 17 are automatic and 11 are semi-automatic, whereas four require expert judgement. The resulting automation claim is bounded by the need for faithful input capture and expert confirmation of heuristic or context-dependent findings.

8.4 EO2: Detection Validity through Controlled Mutation (L1)

8.4.1 Case Selection: Why MiniCPS

The controlled mutation experiment requires a system whose architecture is *publicly documented*, so that a high-quality reference TRA and intentionally degraded variants can be authored and shared without disclosing confidential material. The MiniCPS toolkit and the public SWaT testbed architecture together satisfy these requirements: their controllers, process stages, communications, and network structure are described in the open literature, they represent a realistic ICS domain, and they carry no confidentiality restrictions (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016). They therefore provide a public case suitable for controlled reproduction for EO2, complementing the confidential industrial TRAs that motivate the work but cannot be published.

The MiniCPS/SWaT-derived reference uses the same structured TRA schema that the tooling already parses. The same criterion implementation can therefore be applied without

a case-specific code path. Lens L2 separately examines whether its findings remain interpretable and meaningful under real industrial conditions.

8.4.2 Modelling MiniCPS as a TRA

The documented MiniCPS/SWaT elements were mapped onto the structured TRA schema to produce a hand-authored reference analysis (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016). Table 8.5 summarises the mapping.

Table 8.5: Mapping of MiniCPS/SWaT elements onto the TRA schema

MiniCPS / SWaT element	TRA construct
Six process stages (raw water, chemical dosing, ultrafiltration, dechlorination, reverse osmosis, backwash)	System / software components
PLC1 to PLC6 control logic	In-scope components with interfaces
Sensors and actuators (level, flow, pumps, valves)	Component interfaces and assets
HMI, historian, engineering workstation	Components and trust zones
Modbus-TCP / EtherNet-IP links, ring network, Level-0/1/2 segmentation	Inter-component communications, security zones, zone exposures
Plant availability, water safety, process integrity	Assets and protection goals
Network and physical attacker positions	Threat scenarios and attack interfaces
Host- and hypervisor-hardening premises	Assumptions

The resulting reference TRA (source artefact *v0_good*, reported as *v0* in the result tables) serves as the clean baseline. It contains complete sections, fully structured threats, justified ratings, and full component and interface coverage. It was validated against the schema template and parses cleanly, with 13 threat scenarios, 11 protection goals, and 9 assets. Its overall indicator value is 89.6. To reduce construct bias, the reference was written from the public MiniCPS/SWaT documentation *before* the metric formulae were consulted (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016). A structured summary of the reference TRA is provided in Appendix C, and its dimension-level baseline scorecard is reproduced in Appendix I.

8.4.3 Method and Hypotheses

A single TRA cannot demonstrate that a criterion *discriminates* quality. The experiment therefore adopts a *mutation-based sensitivity analysis* (also known as fault injection or defect seeding), a recognised technique from empirical software engineering. Starting from the reference *v0_good*, a family of degraded variants is derived, each injecting *one* defect class that corresponds to a specific criterion or small group of criteria. Running the analyser on every variant and comparing the results against *v0* shows whether the affected criteria respond as intended.

The experiment is framed as two falsifiable hypotheses:

- **H1 (sensitivity).** Injecting defect class d lowers at least one criterion in its declared target set T_d relative to v_0 .
- **H2 (specificity).** Criteria outside T_d remain within a small tolerance band ε of their v_0 values; any departure is retained as an off-target detection.

Framed this way, each measurement is a classification outcome: an on-target score drop is a TP, while an off-target drop is an FP. Aggregated over all variants, this yields a crude precision/recall characterisation of the catalogue as a *detector* of quality defects.

8.4.4 Injected Defect Classes

Table 8.6 lists the degraded variants. Each isolates one defect class mapped to the dimension and criteria it is expected to affect. Exact criterion identifiers follow the catalogue of Chapter 6.

Table 8.6: Degraded variants and their targeted quality dimension

Variant	Injected defect	Targeted dimension
V1	Placeholder text (“TBD”, open questions) left in fields	Formal Completeness
V2	System overview and scope description removed	Formal Completeness / Coverage / Comprehensibility
V3	Components added with no linked threat	Coverage
V4	Network-facing interfaces left unattacked	Coverage
V5	Protection goals never referenced by any threat	Coverage
V6	Threat descriptions reduced to single keywords	Consistency & Traceability / Comprehensibility
V7	Rating-rationale or handling-decision fields blanked	Consistency & Traceability
V8	Risk rating contradicts impact $\times$ likelihood	Consistency & Traceability
V9	Near-identical threats cloned with contradictory ratings	Consistency & Traceability
V10	Inconsistent version and date metadata	Process & Governance
V11	Assumptions marked unvalidated	Formal Completeness
V12	Required treatment or threat-structure fields dropped	Consistency & Traceability / Comprehensibility
V13	Keyword-stuffed evasion (verbose but non-distinctive wording)	Consistency & Traceability

To further reduce construct bias, the defect injection was performed independently of the reference authoring, and all off-target movements are reported rather than suppressed. The exact mutation operators and their independently declared criterion target map are documented in Appendix E.

8.4.5 Analysis and Central Result

The analyser was run on V_0 and every variant, and all criterion values were recorded. The central artefact is a *variant* $\times$ *criterion delta matrix*: rows are the variants $V_1 \dots V_{13}$, columns are the criteria $CM-01 \dots CM-28$, and each cell holds the change $\Delta = m(V_i) - m(V_0)$. A successful outcome has an *on-target* structure in which strong drops are concentrated in the criteria targeted by each defect (supporting H1), with only limited, explainable movement elsewhere (supporting H2). Because several defect classes legitimately touch a small group of related criteria (Table 8.6), the resulting pattern is block-structured rather than a strict one-to-one diagonal. Figure 8.1 presents this matrix as a heat map.

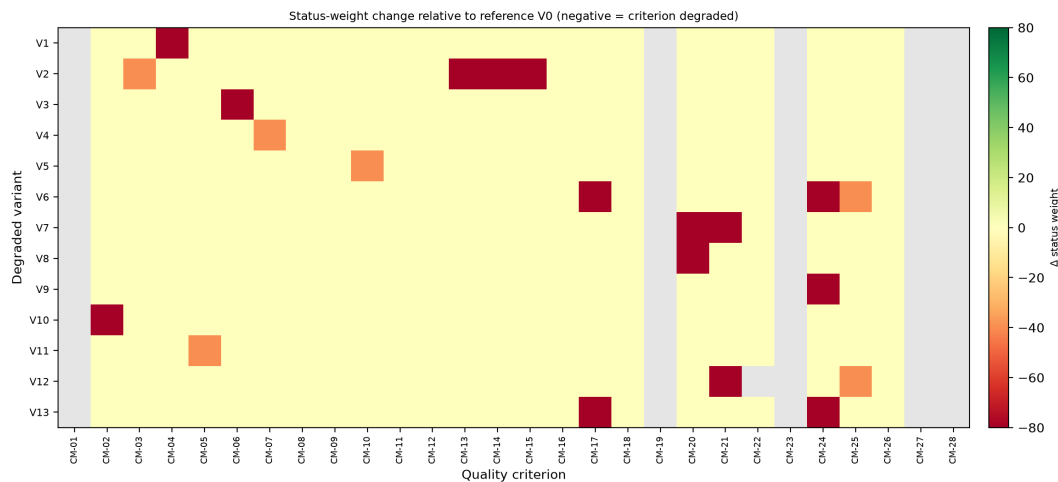


Figure 8.1: Sensitivity of the criteria to seeded defects. Each cell shows the score change of a criterion (column) under a degraded variant (row) relative to the reference TRA.

Results. The reference V_0 received an overall indicator value of 89.6. Table 8.7 reports, for each variant, the resulting overall indicator, the change relative to V_0 , and the criterion(s) whose status weight or continuous value the injected defect reduced, distinguishing status-band movement from continuous-only movement where applicable. Every variant lowered the score of at least one *targeted* criterion, so **H1 (sensitivity) is supported**: the catalogue reacts to each seeded defect class. All thirteen variants flipped at least one targeted traffic-light rating, including V_3 under the strengthened orphan-component mutation.

Table 8.7: Overall indicator and criteria affected by each degraded variant (reference V0 scores 89.6)

Variant	Overall	Δ	Criteria degraded (targeted dimension)
V1	86.1	−3.5	CM-04 placeholder density (Formal Completeness)
V2	77.4	−12.2	CM-03, CM-13, CM-14, CM-15 overview/scope (Formal Completeness/Coverage/Comprehensibility)
V3	86.1	−3.5	CM-06 component coverage degraded by added in-scope orphan components with no threat path (Coverage)
V4	87.8	−1.8	CM-07 attack-surface utilisation (Coverage)
V5	87.8	−1.8	CM-10 linkage between protection goals and threats (Coverage)
V6	81.7	−7.9	CM-17, CM-24, CM-25 threat specificity/wording (Consistency & Traceability/Comprehensibility)
V7	82.6	−7.0	CM-20 rating rationale and CM-21 handling decision (Consistency & Traceability)
V8	86.1	−3.5	CM-20 risk-rating coherence (Consistency & Traceability)
V9	83.3	−6.3	CM-24 status-band degradation; CM-19 continuous consistency value decreased, but the baseline n/a state prevented a status-band transition (Consistency & Traceability)
V10	86.1	−3.5	CM-02 version/date metadata (Process & Governance)
V11	87.8	−1.8	CM-05 assumption validation (Formal Completeness)
V12	87.3	−2.3	CM-21 treatment and CM-25 threat-structure completeness (Consistency & Traceability/Comprehensibility)
V13	83.3	−6.3	CM-17 rule-based threat specificity; CM-24 near-duplicate boilerplate (Consistency & Traceability)

Off-target movement in Figure 8.1 is limited: defects overwhelmingly move the criteria they target and leave unrelated criteria within a narrow tolerance band. **H2 (specificity) is therefore largely supported, but not strictly satisfied at the status-band level**, because two non-targeted CM-24 changes remain. These additional cells are semantically coherent rather than random. For example, reducing every threat to a single keyword (V6) degrades the targeted criteria CM-17 and CM-25 and, as an expected side effect of near-identical wording, also triggers CM-24. The same pattern appears in V13, where boilerplate-heavy descriptions are correctly penalised by CM-17 and also counted as near-duplicates by CM-24. These grouped movements reflect coherent criterion interactions rather than random crosstalk. Variant V9 remains informative: its mutation clearly lowers the continuous CM-19 consistency value, but status-band accounting is constrained by the baseline n/a state (no similar threat pairs in V0), so the strongest evidence is visible in the value matrix (`delta_value_matrix.csv`) rather than a full status-band drop.

The catalogue as a detector. Treating each criterion whose status band moves under a variant as a positive detection makes the two hypotheses quantitative. The operational target set is the group of criteria each defect is *designed* to affect (Table E.1). An on-target band change is a TP, an off-target change is an FP, and a targeted criterion that fails to move is an FN. The experiment driver computes precision and recall against a fixed target map declared independently of the observed results and writes them to `results/precision_recall.csv`. Across the thirteen variants, the results are 19 TPs, 2 FPs, and 1 FN. This corresponds to a **precision of 0.905**, a **recall of 0.950**, and an F_1 of 0.927 at the status-band level. All 13 variants change at least one targeted band.

Both FPs involve CM-24 near-duplicate detection under V6 and V13. In each case, the edit makes the threat descriptions genuinely near-identical or dominated by boilerplate. The resulting CM-24 change is therefore a related effect of the edit, and no unrelated criterion crosses a band. The false negative is V9/CM-19. The mutation lowers the continuous CM-19 value, but no status-band transition can be calculated because the V0 baseline has no similar pair population. Variants V3 and V13 meet their targets: CM-06 drops under the stronger orphan-component mutation, and the rule-based specificity check lowers CM-17 below the passing threshold. The latter result shows that keyword stuffing with non-distinctive vocabulary is detected without penalising the specific threats in the reference. At the continuous value level, the remaining movements, such as V2 affecting CM-03 and CM-14, stay within semantically adjacent criteria and follow from the same field deletion. The result therefore supports the intended specificity of the detector while retaining the two related off-target status changes in the reported precision value. The complete per-variant TP, FP, and FN classification is reproduced in Appendix F.

Criteria not fully exercised by this experiment. Two criteria remain not assessable across all thirteen variants, and one is only partly verified. CM-27 (authority approval presence) and CM-28 (known deficiency evidence references) depend on approval and external evidence metadata that the public MiniCPS export does not contain, so they report an honest *not assessable* value throughout (Section 6.4) rather than a false pass. V9 verifies CM-19 (rating consistency across *similar* threats) at the continuous value level by introducing contradictory ratings. However, the baseline has no similar pair population (n/a), which prevents a conventional status-band drop from being computed. This is a coverage constraint of the baseline corpus rather than evidence that the contradiction check failed. Adding a consistent similar pair control to the baseline is therefore the remaining step for status-band verification (Section 9.7).

The experiment was designed for independent reproduction. The public MiniCPS base, the reference and variant TRAs, and a single batch script that imports the analyser's `analyze()` function and exports the results table together constitute the reproducibility package. Appendix D records the artefacts, file locations, environment, and execution procedure required to regenerate the results.

8.4.6 Threshold Sensitivity

Because several criteria depend on numeric thresholds (Section 6.6), the ranking of TRAs might appear to reflect an arbitrary choice of cut-off. The test varied five thresholds: the three minimum word counts, the near-duplicate Jaccard cut-off, and the threat specificity pass threshold. Three joint configurations were evaluated, with all five thresholds set to their *low*, *default*, or *high* values. Three representative cases were re-scored: the clean reference (V0), a mildly damaged variant (V4, one unattacked interface), and a heavily damaged variant (V2, the system overview and scope descriptions removed). Table 8.8 reports the overall indicator under each joint configuration.

Table 8.8: Overall indicator for a clean, a mildly damaged, and a heavily damaged TRA under three joint low, default, and high threshold configurations

Threshold setting	V0 (clean)	V4 (mild)	V2 (heavy)	Ordering preserved
Low	89.6	87.8	77.4	yes
Default	89.6	87.8	77.4	yes
High	89.6	87.8	77.4	yes

The precise low, default, and high values used for each threshold, together with the sweep procedure, are documented in Appendix H.

The comparative ordering clean > mild > heavy is preserved under all three joint configurations. The cases are sufficiently separated that the thresholds do not alter their overall indicator values across this range. This is a narrow robustness result for these cases, not evidence that the defaults are correctly calibrated or that thresholds cannot change the ordering of more similar TRAs.

Analytical boundary audit. The unchanged aggregate values above could obscure the behaviour that matters closest to a cut-off. Table 8.9 therefore applies the documented decision rules to deliberately boundary-adjacent probe values. These are analytical micro-cases, not additional TRAs or empirical calibration observations. Their purpose is to show explicitly where the low, default, and high settings change a signal.

Table 8.9: Boundary-adjacent audit of threshold-dependent signals

Probe value	Low	Default	High
Five-word threat description against the 4/6/8-word floor	meets	below	below
25-word system overview against the 15/20/30-word floor	meets	meets	below
Six-word scope description against the 3/5/8-word floor	meets	meets	below
Jaccard overlap 0.65 against cut-offs 0.50/0.60/0.70	flagged	flagged	not flagged
CM-17 specificity score 0.60 against pass cut-offs 0.55/0.65/0.75	passes	fails	fails
CM-17 specificity score 0.70 against pass cut-offs 0.55/0.65/0.75	passes	passes	fails

The audit confirms that threshold choices are consequential at the boundary, exactly as expected for discrete decision rules. A single resulting transition from *ok* to *warning* changes the overall indicator by $40/n$, where n is the number of assessed criteria. Several transitions could therefore change the ordering of close cases. The case-level sweep establishes only that this did not occur for V0, V4, and V2 within the tested range. Selecting the defaults themselves still requires an independently reviewed calibration corpus, and evaluating ranking stability near real decision boundaries remains future work.

E02 conclusion. E02 is supported within the exercised scope. Every variant lowered the status weight of at least one criterion in its declared target set, supporting H1. H2 is

largely, but not perfectly, supported: the two off-target CM-24 changes are coherent consequences of descriptions becoming genuinely near-identical rather than unrelated detector crosstalk. At the status-band level, the experiment yields precision 0.905, recall 0.950, and $F_1 = 0.927$, and the ordering of clean, mildly degraded, and heavily degraded cases remains stable throughout the threshold sweep. This conclusion applies to the exercised defect classes on the public case and remains subject to the stated baseline and external-validity limits.

8.5 EO3: Usefulness and Interpretability in Practice (L2)

Lens L2 is an exploratory industrial case study of the framework under working conditions. Five experienced TRA practitioners from the interview study of Chapter 5 (E1–E5) applied the checker to genuine internal TRAs and provided anonymised written feedback. One additional practitioner reviewer from a separate organisational unit reviewed the framework and report and supplied written feedback under the code R1. Together, six practitioners contributed to L2. The reviewed analyses originated from workflows involving spreadsheets, TRA-X, and a low-code platform. TRA-X is the anonymised label used in this thesis for an industrial tool that supports TRA authoring and management. The reviewers commented on whether the examined metrics were relevant, how they interpreted them, whether the findings agreed with their own judgement, and what they expected the checker to do differently. Anonymised participant codes are retained only to trace individual observations to the evidence base.

The feedback was not collected through a fixed criterion-by-criterion rating form. Although Table 8.10 contains observations concerning 26 of the 28 implemented criteria, the number of reviewers contributing to each row varies, two criteria received no criterion-specific feedback, and no independent reference rating was recorded for every TRA–criterion pair. Coverage in the table must therefore not be read as 26 independent validations. L2 supports practical plausibility, interpretability, and refinement discovery. It cannot estimate criterion accuracy, inter-rater agreement, or general industrial validity.

This section addresses EO3: whether the report helps an experienced reviewer and supports action. The same reviewer material also supplies the expectation evidence for EO4, which is analysed separately in the following section. Only aggregate outcomes, defect classes, and anonymised expectation statements are reported. No confidential TRA content is reproduced.

All six reviewers considered the tool useful within the same boundary: it is a first-pass review aid that surfaces easy-to-miss problems and directs expert attention, not a measure of deep content quality. The dependency-light, deterministic, offline design was viewed positively (E3), as was the HTML dashboard’s combination of an overview with drill-down findings (E2, E3). Reviewers also proposed integrating the checker into TRA-X so that quality feedback reaches authors during preparation rather than only during review (E2, E5), and extending the empirical base by applying it to more real analyses (E2).

The limits were equally consistent. E3 judged some TRAs weaker than their favourable structural scores suggested because a substantive review uses product knowledge that a self-contained JSON artefact does not contain. The same reviewer cautioned that a mechanical response to a finding can satisfy a formal check without producing the best technical improvement. E5 stressed that users must be able to reject an FP and that the report should explicitly invite expert confirmation.

Two repeated requests concerned the report layer rather than the detectors. Reviewers wanted the relevant TRA text and field path shown with each finding so that the source can be located immediately (E2), and they preferred prioritised, constructive improvement prompts to a penetration-test-style red/amber/green verdict that can encourage box-ticking (E5). These requests are recorded as workflow refinements rather than changes to the underlying measurement.

R1 characterised formal, quantifiable, and deterministic checking as a strength because it supports consistent assessment against an explicit criterion catalogue and can assist TRA creation and maintenance. R1 nevertheless distinguished this contribution from questions that require detailed domain knowledge: whether the system model, assets, and assumptions are appropriate; whether the relevant threat scenarios were identified in the first place; and whether a formally sufficient description is substantively precise and meaningful. Weak foundations can propagate into later analysis layers without being exposed by checks over the completed structured artefact. The checker was therefore regarded as a complement to expert authors, architects, and reviewers rather than a substitute for their technical judgement.

E4 reported that the tool generally worked well and identified potential weak points as its most important output. E4 nevertheless advised against foregrounding precise percentage values, because values such as 80 and 72 may invite unsupported comparisons between TRAs. This concern is strongest where a dimension contains only a small number of assessed criteria. The calculation of the overall indicator and the distinction between automatic and semi-automatic checks were also insufficiently apparent from the report. The feedback on visual encoding was not uniform: E5 cautioned that traffic-light verdicts can encourage box-ticking, whereas E4 preferred categorical bands to apparently precise percentages. The common expectation was that the report should foreground the weak point, supporting evidence, and required expert action. Any aggregate number or colour should remain secondary.

R1 also suggested a possible extension in which the tool prompts reviewers about potentially omitted threat families based on documented system capabilities and assets. For example, an authentication capability without any authentication-related threat scenario could trigger a review prompt. This is a future rule- or AI-assisted design direction, not a capability evaluated in the present prototype.

EO3 conclusion. The L2 evidence provides provisional support for EO3 within the stated role. The six reviewers found the tool understandable and useful as a first-pass, expert-in-the-loop review aid. They also consistently rejected interpreting it as a measure of deep content quality or an automatic source of recommendations. This conclusion is limited to that bounded role. The uneven, small, and qualitative evidence base does not constitute a general usability or industrial validity study.

8.6 EO4: Reviewer-Expectation Alignment and Evidential Classification

EO4 uses the second set of L2 evidence to compare the meaning reviewers assigned to each discussed criterion with the behaviour of the implementation. It then synthesises the observed differences into general evidential categories and uses L3 only as an illustrative comparison of a separate assessment route.

8.6.1 L2 Expectation Analysis

For every metric on which feedback was received, the analysis recorded the reviewer's expectation, the observed tool behaviour, and the reason for any mismatch. Each individual mismatch is assigned to one of four gap classes. A row in Table 8.10 may contain more than one class when it combines several distinct comments.

G1—Evidence gap. The detector required information that was not present in the structured input, often because an import or modelling step omitted information that existed in the source analysis. The result reflects the captured artefact, which may differ from the complete source.

G2—Interpretation gap. The input and rule were available, but the criterion's definition, purpose, wording, or contributing signals were not clear enough for the reviewer to interpret the result correctly.

G3—Detection gap. The rule itself disagreed with expert judgement on real data, for example because it compared elements without sufficient context, treated a small denominator too harshly, or overlapped another criterion.

G4—Workflow gap. The finding could be understood but was difficult to act upon because the report lacked a field path, inline evidence, or a sufficiently concrete improvement prompt.

A practically important proportion of negative coverage and completeness findings were G1 evidence gaps rather than detector failures. In one reviewed analysis, participant records, the system-overview figure, interfaces, and inter-component communications were present in the source material but were not retained by the spreadsheet-to-platform capture path (E5). The criteria therefore described the structured input correctly, but the structured input did not fully represent the source analysis. This is direct empirical support for expert confirmation of input-sensitive findings.

A second recurring expectation was that a pass should demonstrate good quality. Reviewers instead identified many criteria as *knock-out* or minimum-floor checks: a failure is meaningful, while a pass establishes only that a basic precondition is present (E3). This pass/fail asymmetry motivates the classification in Section 8.6.3.

The comparison-based criteria were regarded as the strongest candidates for a positive quality signal, but also as the checks most in need of context. CM-19 and CM-24 sometimes compared threats across different components or flagged deliberately repeated default patterns (E1, E2, E3). Reviewers therefore requested same-component or same-interface comparison, visibility of the contributing signals, and domain-aware vocabulary and thresholds.

E4's feedback added two cross-cutting interpretation requirements. First, an uncovered component, interface, or protection goal should normally be presented as a review candidate rather than as conclusive evidence of poor quality, because a justified absence of a corresponding threat is possible. Second, the report must expose enough of the calculation to make its result intelligible: the assessed-criterion count, the aggregation rule, the automatic or semi-automatic class, and the evidence behind similarity or distribution checks. These observations are incorporated into the criterion rows and the report-level rows of Table 8.10.

Table 8.10 consolidates the expectation study. It does not claim that every criterion was independently validated: it records each criterion on which reviewer feedback was available, attributes the expectation by interview identifier, classifies the mismatch, and states a refinement direction. Because the reviewers did not complete the same instrument for every criterion, the table is a structured qualitative synthesis rather than a criterion-validation matrix.

Table 8.10: Reviewer expectation and observed tool behaviour, with gap class and refinement direction (EO4)

Criteria	Reviewer expectation	Observed behaviour	Gap	Refinement direction
CM-01	Check the adequacy of roles, including business-owner and quality roles, and account for multi-year or delta analyses rather than one workshop record (E3, E5).	Participant evidence was absent after import. The current rule sees only the captured participation metadata.	G1, G3	Add expected-role presence and iteration-aware checks; retain expert confirmation where evidence is incomplete.
CM-02	Determine whether the analysis is current within a configurable period, using review or release workflow dates rather than only raw modification dates (E1, E3, E5).	Checks whether creation, change, and version metadata indicate that the TRA was maintained.	G3	Add a configurable recency window and prefer review/release timestamps where available.

continued on next page

Table 8.10, continued

Criteria	Reviewer expectation	Observed behaviour	Gap	Refinement direction
CM-27	State clearly what approval means, which role approves, and where the marker is expected; <i>authority</i> can be confused with an external regulator (E1, E3, E5).	Reports an approval marker when present and otherwise often returns <i>not assessable</i> .	G2	Rename and define the process meaning, accountable role, and expected meta-data location.
CM-28	Explain why an external-evidence reference indicates quality and where such a reference is expected to occur. References in the system description or scope should not be disregarded merely because a dedicated deficiency-evidence field is absent (E1, E4, E5).	Searches captured evidence text for references to penetration tests, vulnerability management, end-of-life information, and related artefacts, but can return <i>not assessable</i> when the expected schema field is absent.	G1, G2	Distinguish absence of a dedicated field from absence of evidence, search documented alternative locations, and explain the expected source fields.
CM-03, CM-13	Judge the system description as represented by both text and figures; comprehensibility of the combined evidence cannot be inferred from text length alone (E5).	The word-count floor fails when a figure-borne overview is not imported into the structured artefact.	G1, G2	Ingest figure-borne evidence where possible and present the text check explicitly as a minimum floor.
CM-04	Retain placeholder detection but show the exact source field and avoid incidental matches in legitimate prose (E5).	Scans flattened text for unfinished markers and can produce incidental token matches.	G3, G4	Emit field paths and surrounding text; refine marker rules using context.
CM-05	Identify the individual unvalidated assumptions rather than presenting only a ratio, and rely on a clear source of truth (E5).	Reports the proportion of validated assumptions.	G4	Make the list of unvalidated assumptions the primary finding and retain the ratio as a summary.
CM-06	Recognise that components receive threats through interfaces and communications, that a holistic model may contain deliberately out-of-scope neighbours, and that an in-scope component can legitimately have no identified threat. An unlinked component should prompt review rather than prove poor quality (E3, E4, E5).	Penalises declared in-scope components that have no linked threat path.	G1, G2, G3	Honour explicit scope flags, explain dependence on CM-07 and CM-09, and phrase the result as a confirmation prompt unless the method requires threat coverage for every component.

continued on next page

Table 8.10, continued

Criteria	Reviewer expectation	Observed behaviour	Gap	Refinement direction
CM-07, CM-08	Define whether <i>interface</i> includes network, host, physical, and proximity interfaces; account for interfaces omitted or differently classified during import. An unlinked interface can require review without necessarily being a defect, and declared network interfaces should not produce an unexplained <i>not assessable</i> result (E3, E4, E5).	Computes coverage only over interfaces declared and classified in the structured input; network-facing elements can be missed when the source taxonomy is not preserved.	G1, G2, G3	Clarify the schema taxonomy and external/network-facing definition, ingest interfaces from the modelling source, show the denominator, and present uncovered interfaces as review candidates.
CM-09	Do not let a single uncovered communication dominate a very small set; communications present in the source must survive import (E1, E5).	A ratio with a small denominator can move sharply, and omitted links appear uncovered.	G1, G3	Add denominator-aware interpretation and improve communication ingestion.
CM-10	State the direction of comparison and also consider the reverse question: whether every threat names a violated protection goal. A protection goal may be documented before a corresponding threat is known, so an unlinked goal should trigger review rather than automatically imply poor quality (E3, E4, E5).	Flags protection goals that are never referenced by a threat.	G2, G3	Clarify directionality, add a complementary threat-to-goal coverage view, and permit a documented explanation for goals with no currently identified threat.
CM-12	Explain how component/communication mapping differs from asset-to-goal mapping and goal coverage; parse mappings recorded in free text (E3, E5).	Flags assets without an explicit structured link to a component or communication.	G1, G3	Parse the free-text mapping and analyse correlation with CM-10 and CM-11.
CM-14	Make the intent of the out-of-scope check explicit and support scope flags in the authoring workflow (E5).	Returns <i>not assessable</i> when no structured boundary statement is available.	G1, G2	Explain the expected evidence and add explicit scope fields to the model.
CM-16	Treat the zero-threat case as an entry gate and explain that other coverage checks partly overlap it (E3, E5).	Fails immediately when the analysis contains no threats.	G2, G3	Place it at the beginning of the report and retain it for the empty-analysis corner case.

continued on next page

Table 8.10, continued

Criteria	Reviewer expectation	Observed behaviour	Gap	Refinement direction
CM-17	Justify the curated reference vocabulary, expose the score components, and allow for technically valid wording absent from the reference list (E1, E3, E5).	Combines linkage, reference-vocabulary matching, length, and vagueness signals. The result is difficult to interpret without those components.	G2, G3	Show contributing signals per threat and calibrate the vocabulary against domain-specific examples.
CM-18	Permit justified exemptions and consider checking protection-goal balance per component rather than only across the complete analysis (E1, E5).	Reports an analysis-level C//A balance signal.	G2, G3	Add component-level views, documented exemptions, and knock-out wording.
CM-19	Separate internal rating coherence from rating differences between similar threats, avoid severe cross-component findings caused by one missing rating, and explain how similarity is detected. One reviewed example produced the expected no-issue result, but the comparison basis was not visible (E1, E4, E5).	Compares ratings within Jaccard-similarity pairs, including some cross-component pairs, without fully exposing the paired texts and similarity value.	G2, G3, G4	Stratify same-interface and cross-interface comparisons, split the two meanings, reduce missing-rating severity, and display the paired texts and similarity value.
CM-20	Explain the purpose of the justification comment and restrict matrix mismatch checking to contexts where the final risk is editable (E5).	Verifies the exact risk-matrix cell and the presence of explanatory comments.	G2	State the comment-field purpose and applicability conditions.
CM-21	Retain treatment coverage, but permit an explicit acceptance disposition and point directly to the missing decision (E5).	Flags threats without a handling or treatment value.	G4	Add precise evidence pointers and an explicit must-be-accepted disposition.
CM-22	Surface suspiciously uniform rating patterns without penalising a legitimate distribution or presenting the signal as proof of poor analysis; explain which pattern triggers the detector and why it matters (E1, E4, E5).	Flags low-discrimination or uniformly repeated rating distributions, but the trigger and intended interpretation were not sufficiently visible.	G2, G3	Make interpretation size- and method-aware, expose the trigger and observed distribution, and report it as an informational review signal.
CM-23	Check zone-, interface-, and threat-specific assumptions as well as general assumptions (E3, E5).	Evaluates linkage for the assumption types exposed by the current structured input.	G3	Extend linkage checking to every supported assumption type.

continued on next page

Table 8.10, continued

Criteria	Reviewer expectation	Observed behaviour	Gap	Refinement direction
CM-24	Exclude deliberate default patterns across different components and show both threat texts so the pair can be judged (E1, E2, E3).	Jaccard similarity at or above 0.6 can flag legitimate cross-context near-duplicates.	G3, G4	Compare within relevant component/interface context and display both descriptions inline.
CM-25	Explain which source fields and semantic slots are read and show what is missing from each threat (E5).	Applies a slot-completeness heuristic whose internal slot result is not fully visible in the report.	G2	Show detected and missing slots, example formulations, and source-field mappings.
CM-26	Retain vague-language detection but support generic product-line analyses in which some abstraction is intentional (E3, E5).	Flags vague or hedging markers in threat descriptions.	G3	Add configurable domain exceptions and optionally extend the check to other descriptive fields.
Scope	Use formal and quantifiable checks to support consistent review, but do not infer that the underlying system model, asset selection, assumptions, threat set, or substantive clarity are correct (R1).	The prototype assesses properties observable in the structured artefact and cannot establish whether the right threats were identified or whether the foundations are technically adequate.	G2	State this boundary prominently and treat capability-to-threat-family prompting as a future reviewer aid rather than as automated validation.
Scoring	Make the aggregation method, assessed-criterion counts, denominator, and distinction between automatic and semi-automatic checks visible. Avoid implying that an 80-point TRA is inherently better than a 72-point TRA when dimensions contain different or very small numbers of criteria (E4).	Dimension and overall indicators are numerical means of status weights. Not all comparability limits or confirmation responsibilities are equally prominent in the report.	G2, G4	Show the formula and assessed counts, label semi-automatic results as requiring confirmation, and discourage cross-TRA numerical ranking until weighting and calibration have been independently evaluated.
Report/UX	Show offending text inline, foreground potential weak points, use constructive priorities, and invite reviewers to overrule FPs. Reviewers differed on whether traffic-light bands were preferable, but agreed that verdict-like precision should not dominate the evidence (E2, E4, E5).	The dashboard uses traffic-light statuses and percentage-like indicators, while findings do not always include an explicit action or source pointer.	G2, G4	Make the criterion-level finding primary; add inline evidence, field paths, constructive priority wording, recommended actions, and an explicit confirmation/override workflow; keep aggregate numbers and colours secondary.

How the gaps cluster. G1 evidence gaps are concentrated in coverage and formal-content checks and are often traceable to the capture path rather than the rule. G2 interpretation gaps occur most often where process terms or natural-language signals are not sufficiently explained. G3 detection gaps are concentrated in similarity comparisons, distribution checks, and small-denominator behaviour. G4 workflow gaps concern locating and acting on the finding. Only G3 necessarily changes what a criterion computes. G1, G2, and G4 are primarily addressed through input fidelity, explanation, and presentation.

8.6.2 Refinement Commitments

Three changes arising from the industrial review were already incorporated before the reported experiment was finalised: placeholder tokens were removed from the Jaccard comparison, richer threat descriptions were added to the report, and the risk-coherence check was aligned with exact impact $\times$ likelihood matrix lookup. The remaining requests are grouped into four commitments for the next development cycle rather than presented as capabilities of the evaluated prototype:

1. **Close evidence gaps at the input boundary (G1).** Preserve figure-borne overviews, interfaces, communications, scope flags, and participant evidence when converting the source analysis into the structured artefact.
2. **Close interpretation gaps in the report (G2).** Give every criterion a concise definition, purpose, applicability condition, and, for language metrics, the signals contributing to the result. Explain aggregation, denominators, assessed counts, and the different confirmation responsibility attached to automatic and semi-automatic checks.
3. **Close detection gaps through context and calibration (G3).** Restrict comparisons to relevant components or interfaces, interpret small denominators explicitly, extend linkage rules, expose domain-specific thresholds, and test aggregate comparability when dimensions contain different numbers of assessed criteria.
4. **Close workflow gaps with locatable, actionable findings (G4).** Add field paths, in-line evidence, constructive priority wording, and explicit expert confirmation or override. Present the weak point and required review action before any numerical or categorical summary.

8.6.3 Metric Classification

The evaluation also showed that the implemented criteria do not all provide the same kind of evidence. Some discrepancies between tool output and expert judgement resulted from an interpretation mismatch: a reviewer expected evidence of substantive content quality where the tool measured structural presence, or treated a minimum-content heuristic as a content endorsement. EO4 therefore classifies each core criterion by its evidential character. The classification draws on its behaviour in L1, the reviewer expectations in Table 8.10, and the intent stated in the criterion definition.

This evidential classification is orthogonal to the five quality dimensions: the dimensions describe *what aspect of TRA quality* a criterion assesses, whereas Categories A–E describe *what kind of evidence* its result provides. Each core criterion therefore retains its original dimension while also receiving one evidential category. The categories neither replace nor redefine the dimensions.

Table 8.11 records the classification at category level. Individual criterion definitions remain in Chapter 6.

Table 8.11: Classification of core criteria by evidential character

Category	Core criteria	Correct interpretation
A: Direct analytical quality	CM-17, CM-19, CM-20, CM-24	Both pass and fail provide content-oriented evidence, subject to contextual confirmation.
B: Structural coverage	CM-06–CM-12, CM-18, CM-21, CM-23	A failure identifies a structural coverage, balance, or linkage gap. A pass does not establish the semantic adequacy of the represented content.
C: Descriptive and scope heuristic	CM-13–CM-15, CM-25, CM-26	A candidate scope, description, or readability problem for reviewer confirmation. A pass is only a minimum floor.
D: Formal sanity gate	CM-03–CM-05, CM-16	A failure indicates an unfinished or degenerate artefact. A pass confirms reviewability only.
E: Process tracer	CM-01, CM-02, CM-22, CM-27, CM-28	Evidence of process or rating-pattern traces, not proof of analytical content quality. Some results may be <i>not assessable</i> .

Non-implications. Four interpretations are explicitly unsupported. A Category E pass does not show that the analysis is substantively strong. A high Category B result does not show that the linked threats are adequate. A Category C pass is a heuristic floor rather than a content endorsement. A high overall indicator therefore means that the artefact is comparatively strong under the implemented checks, not that it is correct in every domain-specific respect.

Correlated criteria. Component, interface, and communication coverage (CM-06, CM-07, and CM-09) observe related connectivity from different entry points. They are retained separately to localise gaps, but their correlation can give the underlying coverage property more influence in an unweighted dimension mean. A future cross-criterion correlation analysis should determine whether weighting or partial consolidation is warranted.

Refinement implications. Across the five categories, the recurring needs are clearer evidence pointers, context-aware similarity comparison, transparent language heuristics, and better process metadata. These evaluation-derived directions are consolidated with the wider research agenda in Section 9.7, avoiding a second detailed future-work catalogue here.

Reading the classification against reviewer expectation. Categories D and E contain the clearest knock-out and process-floor checks: failure is meaningful, but passing is not proof of substantive quality. Category B contains the coverage checks most exposed to G1 capture gaps, so a failure means a gap in the captured artefact until source completeness is confirmed. Category A contains the comparison-oriented criteria for which both passing and failing can be informative, subject to the G3 context and calibration refinements. Category C provides heuristic minimum floors and therefore requires the G2 transparency improvements before a reviewer acts on a finding.

8.6.4 L3: Descriptive AI-Assisted Comparison

L3 adds a descriptive comparison using three separately generated reports on the same TRA artefact: two AI-assisted interpretation reports and one report generated directly by the implemented rule set. No human expert report or independently validated gold standard is part of this lens. Agreement with the LLM reports therefore cannot establish concurrent or construct validity. At most, it shows whether the issue families identified by the deterministic rules are also visible to two general-purpose semantic assessment routes under a shared rubric.

The AI-assisted workflow is treated here as a separate perspective rather than as a competitor. The two approaches evaluate different aspects of quality: the AI-assisted interpretations consider semantic adequacy in the supplied artefact, while the implemented checks assess predefined structured quality signals. The comparison examines whether both routes identify *compatible* quality gaps. To keep the comparison fair, the analysis was limited to the eight criteria shared across all three reports (CM-13, CM-15, CM-17, CM-19, CM-20, CM-24, CM-25, CM-26). The evidence base for this comparison consists of three separately generated reports on the same TRA artefact (labelled *Report A*, *Report B*, and *Report C* in this thesis). To preserve confidentiality and prevent partner identifiability, concrete file names are retained only in the internal project archive and are not reproduced in the manuscript. For criterion-level comparison, the original status labels are normalised to *GOOD*, *REVIEW*, *CRITICAL*, and *N/A*; these comparison labels do not replace the checker's native *ok*, *warning*, and *bad* statuses. The report provenance, label mapping, agreement calculation, and L3-specific validity threats are documented in Appendix G.

The three reports show both convergence and divergence. Reports A and C assign the same overall percentage (50%), whereas the direct computed report (Report B) yields 76%. These report-level percentages are retained as supplied and are not recalculated from the eight normalised labels in Table 8.12. The difference reflects the distinct evidential logic of semantic judgement and schema-based checks. For the shared criteria, exact label agreement is moderate between Report A and Report B (4/8), lower between Report C and Report B (2/8), and moderate between the two AI-assisted reports themselves (4/8). At the level of gap presence, however, the qualitative overlap is stronger: the two AI-assisted reports both signal a quality concern on all eight shared criteria, while all three reports signal a quality

Table 8.12: L3 shared-criteria status comparison on the same TRA artefact

Criterion	Report A	Report B	Report C	All signal gap?
CM-13	REVIEW	GOOD	REVIEW	No
CM-15	REVIEW	REVIEW	REVIEW	Yes
CM-17	REVIEW	REVIEW	CRITICAL	Yes
CM-19	REVIEW	GOOD	CRITICAL	No
CM-20	REVIEW	GOOD	REVIEW	No
CM-24	REVIEW	REVIEW	CRITICAL	Yes
CM-25	REVIEW	REVIEW	REVIEW	Yes
CM-26	REVIEW	GOOD	CRITICAL	No

concern on four of them (CM-15, CM-17, CM-24, and CM-25). Across the reports, recurring issue families remain stable: weak interface/component naming, overlap between T-7 and T-10, and insufficiently specific threat formulations (especially T-1, T-2, T-7, and T-10). The strongest disagreements appear where structured checks cannot fully represent semantic interpretation, particularly in CM-19 and CM-20, where ratings may be matrix-consistent yet still appear weakly justified in the AI-assisted reports. The agreement figures reported here are computed as exact label agreement (GOOD/REVIEW/CRITICAL/N/A) across the eight shared criteria listed in Table 8.12. Given the single-case design, this agreement value is reported descriptively and is not treated as a basis for statistical inference.

The L3 result shows that, on this case and under the shared criterion prompt, the AI-assisted interpretations and the deterministic checker sometimes converge on recurring issue families while assigning different severities. The second LLM report shows that some issue families remain visible across two model outputs, but this may reflect the common rubric, prompt framing, or surface features of the artefact rather than independent domain judgement. The comparison is therefore retained as an illustration of complementary assessment behaviour, not as validation of the framework. Extension to multiple TRAs and comparison with independent expert ratings remain future work.

L3 contribution to EO4. L3 does not establish EO3 usefulness, because no human user evaluated the reports in this lens. That evidence comes from L2. Nor does L3 validate the criteria. Its narrower contribution is illustrative: the strongest disagreements occur on CM-19 and CM-20, where the classification predicts that structured consistency and semantic adequacy can diverge. A matrix-consistent rating can still be interpreted as weakly justified. The single-case comparison is compatible with that explanation but cannot test it independently.

EO4 conclusion. **EO4 receives provisional support for the reviewed criteria within the qualitative evidence base.** Every recorded reviewer objection was traced to an evidence, interpretation, detection, or workflow cause and connected to a concrete refinement. The five-category classification states the general evidential rule behind those individual

gaps, while L3 illustrates how structured and semantic assessments can diverge where the classification predicts. The result is a traceable account of where and why reviewer expectation and tool behaviour agree or differ. Criteria without reviewer feedback are not claimed as independently validated.

8.7 Threats to Validity

- **Construct validity and researcher dependence.** The same researcher designed the criteria and hand-authored the MiniCPS reference TRA, creating a circularity risk: modelling choices in the baseline may unconsciously make the criteria appear better targeted. *Mitigation:* the reference was written from the public MiniCPS/SWaT documentation before the metric formulae were consulted, validated against the fixed schema, and altered through deterministic defect injection. These steps improve traceability but do not make the baseline independent. L1 therefore demonstrates detector response conditional on this author-constructed baseline, not independent construct validation.
- **Internal validity.** A single mutation could perturb more than one criterion. *Mitigation:* one defect class per variant, with off-target movement reported explicitly through the delta matrices and detector accounting.
- **External validity.** The controlled case represents one industrial control domain, while the reviewer study concerns real analyses from one organisational setting and includes a prominent lossy import path. *Mitigation:* the G1 classification separates capture effects from detector behaviour, and broader cross-domain and cross-workflow replication remains future work.
- **Expectation-elicitation validity.** Reviewer expectations were supplied as criterion-level written feedback rather than through a fixed, identical questionnaire, so coverage across criteria is uneven. *Mitigation:* Table 8.10 reports only the criteria that received feedback and does not treat unreviewed criteria as validated. Even reviewed criteria are interpreted as qualitative observations rather than validated measurements because reviewer coverage per criterion was not standardised.
- **Conclusion validity.** The reviewer group is small and unevenly sampled by criterion, while L3 is a single-case comparison with general-purpose LLM outputs rather than an independent expert standard. *Mitigation:* EO3 and EO4 are interpreted qualitatively; L3 agreement is reported descriptively at case level and is not treated as validity evidence.
- **Metric transportability.** Minimum word counts, similarity cut-offs, specificity thresholds, and some vocabulary choices were selected for the studied setting rather than empirically calibrated. *Mitigation:* the parameters are transparent and configurable, their boundary behaviour is reported explicitly, and independent domain-specific calibration is identified as future work.

Robustness to a contested criterion. The overall indicator is an unweighted mean over the assessed criteria, so the direct influence of one criterion is bounded by approximately $1/n$ of that assessed set. More importantly, the L1 conclusions depend on the ordering across variants and their targeted movements, while the L2 conclusions depend on the gap classes rather than on one absolute score. Removing a disputed criterion such as CM-22 would alter displayed means slightly but would not reverse the observed clean–mild–heavy ordering or remove the expectation-gap classification. This is a robustness argument for the reported comparisons, not a substitute for later correlation and weighting analysis.

8.8 Chapter Summary

Chapter 8 evaluated the framework through four explicitly mapped questions and three complementary lenses, with a scoped conclusion for each question.

EO1—Supported with an explicit expert boundary. The formal automation boundary is 17 automatic, 11 semi-automatic, and 4 expert criteria. Reliable automation additionally depends on faithful input capture, and heuristic findings still require expert confirmation.

EO2—Supported within the exercised defect classes. In the controlled mutation experiment (L1), every variant changed a targeted status band, the detector achieved precision 0.905, recall 0.950, and $F_1 = 0.927$, and the clean–mild–heavy ordering remained stable throughout the threshold sweep. Specificity was largely rather than perfectly supported because two coherent off-target CM-24 changes remained.

EO3—Provisionally supported within the first-pass review role. In the exploratory industrial reviewer case study (L2), six practitioners found the tool useful and interpretable as an expert-in-the-loop aid, while rejecting its use as a measure of deep content quality or an automatic source of recommendations. The uneven qualitative protocol supports plausibility and refinement, not general usability validity.

EO4—Provisionally supported for the reviewed criteria within the qualitative evidence base. Reviewer expectations were compared with tool behaviour and each recorded mismatch was classified as an evidence, interpretation, detection, or workflow gap. Many coverage and completeness disagreements were traced to information lost during capture, while the comparison metrics generated the main algorithmic refinement needs. The five-category classification makes the resulting pass/fail asymmetry explicit. L3 adds a descriptive illustration: all three reports identified gaps in CM-15, CM-17, CM-24, and CM-25, while disagreements occurred where AI-assisted semantic interpretation and structured checks were expected to differ. Agreement with these general-purpose LLM reports is not treated as framework validation.

Together, the evidence establishes what the prototype measures, how its findings should be interpreted, and where expert judgement remains essential. It does not justify treating a high score as certification of domain-specific quality. Chapter 9 interprets these findings against the RQs, limitations, industrial implications, and future-work priorities.

9 Discussion and Future Work

Building on the evaluation in Chapter 8, this chapter interprets the results in relation to the three RQs. The discussion considers both industrial and academic perspectives before addressing limitations, recommendations, and future work. Chapter 10 then presents the conclusion.

9.1 Revisiting the RQs

The RQs form a progression from identification, through formalisation, to automation. The detailed evidence mapping is summarised in Table 9.1.

Table 9.1: Synthesis of RQs, evidence, and answer strength

RQ	Primary evidence	Answer supported by the thesis	Remaining limitation
RQ1	Literature review and expert interviews (E1–E5)	TRA quality can be articulated through a structured set of indicators grouped into process and governance, formal completeness, coverage, consistency and traceability, and comprehensibility.	Based on a small expert sample and therefore analytically strong but not statistically exhaustive.
RQ2	Criterion construction in Chapter 6 and implementation in Chapter 7	A substantial subset of expert review logic can be translated into explicit, repeatable criteria tied to observable properties of a structured TRA artefact.	Some criteria remain semi-automatic or require expert judgement because their signal depends on semantics, diagrams, or tacit domain knowledge.
RQ3	Controlled mutation experiment (L1, EO2), exploratory industrial reviewer case study (L2, EO3 and EO4), descriptive AI-assisted comparison (L3), and the automation-scope analysis (EO1)	Automated checking is feasible for a substantial share of the catalogue and can detect meaningful quality gaps, but it does not remove the need for expert confirmation and interpretation.	L2 involved six practitioners from related units within one organisation under an uneven qualitative protocol; L3 covers one shared case with no expert gold standard and is illustrative only.

- **RQ1 (quality indicators).** The expert interviews and the literature review yielded a structured set of indicators organised into five dimensions, showing that practitioner TRA quality judgements can be articulated explicitly.

- **RQ2 (repeatable metrics).** These indicators were formalised into the criterion catalogue of Chapter 6, demonstrating that a substantial subset of expert review logic can be translated into repeatable, observable checks.
- **RQ3 (automated detection).** The PoC tool of Chapter 7 and the four evaluation questions of Chapter 8 show that 17 criteria are automatic, 11 are semi-automatic, and 4 require expert judgement. L1 establishes detection behaviour on seeded defects, L2 supplies exploratory evidence of practical usefulness and reviewer expectations, and L3 illustrates differences between rule-based and AI-assisted assessment routes without validating either one.

9.2 Industrial Perspective

Within the exploratory L2 case study, the six contributing practitioners (E1–E5 and R1) regarded the checker as useful and interpretable as a first-pass, expert-in-the-loop review aid (Section 8.5). E2 and E3 specifically valued the dashboard’s overview and drill-down structure. However, the feedback consistently rejected interpreting the output as a measure of deep content quality. E4 further prioritised criterion-level weak-point identification over precise percentage comparisons and requested clearer explanation of aggregation and automation classes. The main practical benefit therefore appears to lie not in a single quality number but in a structured, transparent breakdown that makes review findings explainable and comparable across projects and teams. In recurring use, this breakdown can support a continuous quality-improvement cycle: experts confirm and prioritise findings, the TRA is corrected, and the checks are re-run. Comparison between successive versions remains manual in the current implementation.

The confidentiality-preserving design of Chapter 7 is central to industrial adoption. The tool can process detailed confidential data within the authorised environment, while reporting outside the analysis team is restricted to aggregate scores and defect classes. This arrangement enabled both the real-TRA application (lens L2) and the descriptive AI-assisted comparison (lens L3) without disclosing the underlying artefacts.

The AI-assisted comparison is a plausible industrial direction. As experts increasingly use AI agents and skills to author TRAs and to predict required or missing threats, the quality framework can serve as an independent, auditable check on that output by quantifying the agreement between AI-predicted gaps and the coverage criteria’s findings. Positioned this way, the framework complements AI-assisted authoring rather than competing with it: the AI proposes content, and the metrics assess the quality of the resulting analysis.

In parallel to the formal evaluation reported in Chapter 8, the thesis author and a project collaborator integrated the metric checker into an AI skill used during TRA authoring. The integration was applied in a real partner-organisation project, where the involved experts reviewed the generated quality feedback and found it useful and broadly consistent with the issue classes identified in lens L2. Because this was an operational pilot rather than

a predefined study protocol, it is reported as practice evidence of feasibility and industrial relevance, not as independent validation of the framework or the AI skill.

9.3 Academic Perspective

From an academic standpoint, the contribution is to treat the completed TRA as an *evaluable artefact* and to make expert review logic explicit, repeatable, and partly automatable. This changes the object of assessment relative to two important foundations in the literature. IEC 62443-3-2 specifies activities and expected content for systematic industrial risk assessment, but does not provide an artefact-quality verdict for a completed TRA (IEC, 2020). Similarly, Cherdantseva et al. (2016) compare SCADA risk assessment methods using explicit dimensions, whereas the present framework applies explicit criteria to individual analysis outputs. The thesis therefore complements standards- and method-level guidance with a post-hoc review layer rather than replacing either foundation.

The mutation-based sensitivity analysis (lens L1) provides a documented, falsifiable evaluation design intended for reproduction: the sensitivity and specificity hypotheses (H1, H2) and the variant $\times$ criterion delta matrix characterise the catalogue as a *detector* of quality defects on a public, shareable system. The reproducibility package, comprising a public base model, reference and variant TRAs, and a single batch script, is designed for independent repetition and will become part of the methodological contribution when deposited with the final thesis.

A second methodological contribution is the reviewer-expectation study (EO4) in Chapter 8. By comparing, criterion by criterion, what experienced reviewers expected with what the tool produced, and by assigning each difference to an evidence, interpretation, detection, or workflow gap (Table 8.10), it converts dispersed practitioner feedback into a structured and auditable account of where automated checks do and do not align with human judgement.

The academic value of the MiniCPS choice lies in its public availability. It allows the industrial method to be mirrored on public data, so the evaluation can be published and independently repeated where the confidential industrial cases cannot. The shared schema allows the same criterion implementation to be applied to both the public and industrial cases, while lens L2 separately tests whether the resulting findings remain meaningful under realistic conditions.

The model- and pattern-based work of Maidl et al. (2019) and Maidl, Münz, et al. (2021) demonstrates how components, interfaces, threats, and expert knowledge can be made explicit in a CPS representation. The present framework carries that principle into a different stage of the lifecycle: it uses explicit relationships as observable evidence when reviewing an already completed TRA for coverage and traceability gaps. In the same way, the tool comparison by Granata and Rak (2024) documents substantial variation in automated threat-modelling capabilities. The PoC addresses a complementary automation role by checking the resulting artefact rather than generating the threat model itself.

The evaluation-based classification in Section 8.6.3 complements this methodological contribution. It separates direct analytical indicators from coverage signals, language heuristics, sanity gates, and process tracers. This reduces a common construct-validity risk in quality measurement: treating every measurable property as equivalent evidence of substantive quality. It also supplies a clearer basis for later weighting, replication, and comparison studies. This distinction follows the measurement principle that a metric must represent the property claimed for it (Fenton & Bieman, 2014), and the validity principle that evidence must support the intended interpretation of a result rather than merely the reliability of its calculation (Messick, 1995). Consequently, a reproducible structural count is treated as evidence of structural coverage, not automatically as evidence of semantic adequacy or technical correctness.

9.4 Limitations

Several limitations qualify these contributions and mirror the threats to validity discussed in Chapter 8:

- **Expert sample.** The criteria were elicited from a small number of experts (E1–E5). While appropriate for an exploratory qualitative study, this limits statistical generalisation of the indicator set.
- **Self-authored reference.** The MiniCPS reference TRA was hand-authored by the same researcher who designed the criteria, which creates a genuine circularity risk and may unconsciously favour the checks. This was mitigated by authoring from public documentation before consulting the metric formulae, validating the reference against the fixed schema before scoring, and separating reference construction from deterministic defect injection. These measures make the experiment auditable but do not remove researcher dependence. Once deposited with the final thesis, the artefacts will permit independent replication, but only an independently authored and reviewed baseline can address this dependence.
- **Single domain.** The controlled evaluation uses one industrial control domain; broader generalisation across sectors remains to be demonstrated.
- **Limited and uneven industrial evidence.** The exploratory L2 case study covered confidential internal TRAs within one organisation and six practitioners from related units. Criterion feedback was not collected with the same rating form for every reviewer and TRA. It supports plausibility and refinement discovery rather than criterion validity. L3 covers one shared case and compares against two general-purpose LLM reports rather than an independent expert standard. Broader, structured evidence across organisations, domains, and export routes is still required.
- **Scope of automation.** The extended criteria and several context-dependent process aspects continue to depend on expert judgement by design. The framework supports rather than replaces the reviewer.

- **Threshold and weighting dependence.** Several checks rely on configurable linguistic or similarity thresholds, and the current aggregation uses equal weights. The thresholds are prototype defaults rather than empirically calibrated estimates, and equal weighting is not neutral: it assigns the same direct importance to unlike weaknesses and can amplify correlated criteria. The case-level sweep supports only the ordering of three widely separated cases, while the boundary audit shows that near-cut-off classifications do change. Independent domain calibration, structured weight elicitation, and cross-criterion correlation analysis remain necessary.

9.5 Reflection on Key Challenges

Several methodological challenges shaped the framework and its design responses.

- **Confidentiality versus reproducibility.** Credible evaluation requires real analyses, but confidential analyses cannot be published. The public MiniCPS reference model provides a reproducible basis for the L1 experiment without disclosing confidential material. The tool processes confidential partner-organisation TRAs inside the authorised environment, while only aggregate results are disclosed externally. Together, these mechanisms are intended to make the method publicly auditable and industrially applicable.
- **Schema variability.** Real TRA exports differ in structure, and hard-coding a single layout would have made the tool brittle. The implementation uses structural detection rather than fixed field positions (Chapter 7), allowing it to support the documented target-area layouts without product-specific criterion logic.
- **The limits of automation.** Some quality aspects cannot be reduced to a metric, including whether an architecture figure is fit for purpose, whether a justification is technically sound, and whether the right roles were involved. These aspects require expert judgement because assigning numeric values would imply unsupported precision. The framework follows the principle articulated by the experts (Chapter 5): automation should support review, not replace it. The pipeline reduces the mechanical burden, while judgement remains with the reviewer.
- **Avoiding overclaiming.** The controlled mutation experiment (L1) is a single case. External validity claims therefore rest on the schema-agnostic transfer argument and the reviewer study (L2), which so far covers one organisational setting and a limited set of confidential internal TRAs. This limitation is stated explicitly to avoid over-interpreting the L1 result.
- **Dependence on the structured input.** The criteria operate on the structured representation of a TRA, so their reliability depends on how completely the source analysis is captured in that representation. When information is only implicit in the original artefact, such as system structure held in a diagram or fields not carried across during

conversion into the structured schema, the affected checks can raise findings that reflect the input path rather than a genuine quality defect. This is mitigated by keeping such criteria semi-automatic and subject to expert confirmation, but it remains an inherent limitation of artefact-based measurement. The reviewer study in Chapter 8 made this limitation observable: many of the coverage and completeness disagreements on the real analyses were traced to G1 evidence gaps in the captured input rather than to faulty detectors (Table 8.10). This supports prioritising improvements at the input boundary while retaining expert confirmation for the affected criteria.

- **Single iteration scope.** The framework currently evaluates a TRA as a single, self-contained artefact and does not yet model iterative or delta analyses, where a TRA is revised across several workshops or extended for a follow-up scope. Such cases are common in practice and are not fully captured by the present design. Re-running the checker on successive versions can support a manual improvement cycle, but changes between versions are not yet identified or evaluated automatically.

9.6 Recommendations

The findings support several immediate recommendations for organisations that intend to use the framework in practice.

- **Use the framework as decision support, not as an automatic approval mechanism.** Automated results should direct reviewers to possible omissions and inconsistencies, while final acceptance remains a documented expert decision.
- **Review criterion- and dimension-level results before the overall indicator.** A single aggregate value can conceal a serious weakness in one area. The scorecard and the underlying findings should therefore be the primary basis for corrective action.
- **Use a continuous quality-improvement loop.** For each TRA version, run the checks, have an expert confirm and prioritise the findings, correct the artefact, re-run the checks, and document the remaining accepted findings. Where successive versions are available, their criterion- and dimension-level results should be compared manually. Repeated review experience may inform controlled refinements to schema mappings, vocabulary, and thresholds, while automated delta analysis remains future work.
- **Retain explicit human checks for judgement-dependent criteria.** Technical plausibility, adequacy of architecture evidence, stakeholder participation, and the quality of risk justification should remain part of a structured expert review.
- **Pilot and calibrate the checks on representative organisational TRAs.** Thresholds, vocabulary, and schema mappings should be validated against local analysis practices before the framework is introduced as a recurring quality gate.

- **Preserve traceability and confidentiality.** Each finding should identify the affected criterion and artefact element, while reports used outside the analysis team should continue to expose only the minimum necessary aggregate information.

9.7 Future Work

The limitations also point to the following directions for future research and development.

- **Scale up the industrial evaluation.** Extend lens L2 beyond the current organisational setting and limited internal sample to a larger, cross-domain set of real TRAs. Use a fixed criterion-by-criterion review form, independent expert ratings, and a declared sampling plan so that coverage, agreement, false-positive patterns, and inter-rater reliability can be reported without disclosing confidential content.
- **Operational AI-skill deployments.** Document additional cases where the metric checker is integrated into AI-assisted TRA authoring workflows, and compare the resulting expert feedback systematically with lens L2-style review outcomes.
- **Stronger text analysis.** Extend the rule-based specificity and similarity checks with embedding-based measures and domain-adapted synonym handling, building on the implemented rule-based baseline, to improve discrimination of vague or duplicated threats.
- **Cross-domain generalisation.** Repeat the mutation experiment on public models from other CPS domains (for example energy or manufacturing) to test transfer beyond water treatment.
- **Broader expert validation.** Enlarge the expert study to refine criterion weights and to establish inter-rater agreement on the presence of quality gaps. Weighting should use a reproducible elicitation method and be compared with the unweighted baseline; criterion correlations should be examined before assigning multipliers so that related coverage checks are not unintentionally counted several times.
- **Role-participation checks.** Extend the process and governance criteria to test for the presence of the roles a complete TRA is expected to involve, for example a business owner or a quality assurance role. A missing but expected role would then become a visible quality signal. Whether a named participant is actually qualified for a role would remain an expert judgement and is deliberately left outside automation.
- **Iterative and delta TRAs.** Extend the model to handle revised and follow-up analyses, so that version history and incremental changes between successive TRA iterations can be evaluated rather than only a single static artefact.
- **Complete the defect set.** Extend the variant family to exercise the criteria left untested by the current experiment, in particular a conflicting rating duplicate to trigger CM-19, and exports carrying approval and external evidence metadata to exercise CM-27 and

CM-28. This should be paired with clearer guidance on where approval sign-off and external evidence references (for example penetration test or vulnerability management artefacts) are expected to appear, and why their presence is treated as a quality signal, so that these criteria are interpretable to analysts.

- **Maturity model integration.** Deepen the mapping to established TRA maturity models so that the automatable share and its boundaries are characterised more formally.
- **Data-driven threshold calibration.** The numeric thresholds used by the automatic and semi-automatic criteria, including minimum word counts, the near-duplicate Jaccard cut-off, and the specificity pass score, are currently set by expert judgement and linguistic convention (see Table 6.3). A defensible calibration study requires a corpus of real TRA elements labelled independently by multiple experts at criterion level, including examples close to the candidate boundaries. Candidate cut-offs should be selected on a training subset against a predeclared error trade-off (for example, prioritising recall for knock-out checks and precision for expensive review findings), then evaluated on a held-out subset from different projects or domains. Inter-rater agreement and uncertainty intervals should be reported alongside the selected values. This design reduces the risk of merely fitting the prevailing quality level of a contaminated corpus. The resulting domain-specific values should remain external configuration parameters, with the present defaults retained only as documented prototype baselines until such evidence exists.
- **Boundary-focused robustness study.** Construct independently reviewed TRA cases whose raw criterion values lie immediately above and below the candidate cut-offs. Vary one threshold at a time as well as jointly, and report both criterion-level transitions and any change in the ordering of closely matched TRAs. This would extend the analytical boundary audit of Table 8.9 into an empirical robustness test.

9.8 Chapter Summary

This chapter connected the evaluation evidence to RQ1–RQ3 and distinguished the framework’s industrial and academic contributions from its limitations. Industrially, the framework is best understood as transparent decision support within an expert-in-the-loop quality process. Academically, it demonstrates how review knowledge can be represented as explicit criteria and tested against controlled defects, practitioner expectations, and a separate assessment route.

The central conclusion is deliberately bounded: the framework can improve the consistency and explainability of completed-TRA reviews, but it does not certify domain-specific correctness or replace expert judgement. The recommendations therefore position repeated checking, correction, and expert confirmation as a continuous quality-improvement loop. The future-work priorities extend the evidence base, version-aware analysis, text processing, and

calibration. Chapter 10 now consolidates the answers to RQ1–RQ3 and states the scope of the thesis contribution.

10 Conclusion

Chapter 9 interpreted the evaluation evidence and its limitations. This concluding chapter returns to the practical problem introduced in Chapter 1: within the industrial setting studied, completed TRAs in CPS and ICS were commonly reviewed through personal experience, making the grounds for acceptance or criticism difficult to compare. The research therefore treated the TRA as an evaluable artefact rather than proposing another method for performing risk analysis.

The thesis makes three contributions. Literature and expert practice provide a structured set of TRA quality indicators (RQ1). These indicators are formalised as a criterion catalogue with observable checks and explicit automation classes (RQ2). A confidentiality-preserving prototype implements the 28 core criteria, while the four-question evaluation combines a controlled mutation experiment, an exploratory industrial reviewer case study, and a descriptive AI-assisted comparison to assess detection behaviour and provide bounded evidence about practical usefulness and the limits of automation (RQ3).

The evaluation further distinguishes five evidential classes within the implemented criteria: direct analytical indicators, structural coverage signals, comprehensibility heuristics, formal sanity gates, and process tracers. This classification clarifies that different checks support different conclusions and prevents a structural pass from being read as proof of substantive content quality. It therefore does not claim that a high automated score certifies substantive content quality: the EO4 classification in Chapter 8 shows that most criteria provide a minimum floor, structural signal, or process trace, while only a smaller group supplies direct content-oriented evidence. Nor are the results assumed to generalise unchanged across all domains and organisations.

The evidence supports feasibility and practical relevance, not full generalisation: the industrial case study covers confidential internal TRAs in one organisation with six practitioners from related units under an uneven qualitative protocol, while the AI-assisted comparison covers one case without an independent expert gold standard. It is illustrative rather than validity evidence.

Within these limits, TRA review can be made more transparent, explainable, and repeatable without exposing confidential artefacts. Methodologically, the thesis contributes a documented evaluation pattern for quality criterion catalogues that is designed for reproduction, including sensitivity/specificity framing and cross-lens triangulation.

Beyond the formal evaluation protocol, the thesis author and a project collaborator integrated the metric checker into an AI skill used during TRA authoring in a real partner-organisation project. The involved experts reviewed the generated feedback and considered it useful and

Conclusion

broadly consistent with the L2 issue classes. Since this was an operational pilot rather than a predefined evaluation, it demonstrates workflow feasibility and industrial relevance but is not treated as independent validation.

The next step is to scale the evidence base: extend industrial case coverage, repeat the AI-assisted comparison against independent expert ratings across additional TRAs, and continue the text analysis and cross-domain enhancements outlined in Chapter 9.

References

- Amro, A., Gkioulos, V., & Katsikas, S. (2023). Assessing cyber risk in cyber-physical systems using the ATT&CK framework. *ACM Transactions on Privacy and Security*, 26(2), 1–33. <https://doi.org/10.1145/3571733>
- Anton, S. D., Fraunholz, D., Lipps, C., Pohl, F., Zimmermann, M., & Schotten, H. D. (2017). Two decades of SCADA exploitation: A brief history. *2017 IEEE Conference on Application, Information and Network Security (AINS)*, 98–104. <https://doi.org/10.1109/AINS.2017.8270432>
- Antonioli, D., & Tippenhauer, N. O. (2015). MiniCPS: A toolkit for security research on CPS networks. *Proceedings of the First ACM Workshop on Cyber-Physical Systems-Security and/or Privacy*, 91–100. <https://doi.org/10.1145/2808705.2808715>
- Cherdantseva, Y., Burnap, P., Blyth, A., Eden, P., Jones, K., Soulsby, H., & Stoddart, K. (2016). A review of cyber security risk assessment methods for SCADA systems. *Computers & Security*, 56, 1–27. <https://doi.org/10.1016/j.cose.2015.09.009>
- Eckhart, M., Ekelhart, A., Biffl, S., Lüder, A., & Weippl, E. (2023). QualSec: An automated quality-driven approach for security risk identification in cyber-physical production systems. *IEEE Transactions on Industrial Informatics*, 19(4), 5870–5881. <https://doi.org/10.1109/TII.2022.3193119>
- European Parliament and Council of the European Union. (2022a, December 14). Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the union (NIS 2 directive). Retrieved July 29, 2026, from <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng>
- European Parliament and Council of the European Union. (2022b, December 14). Directive (EU) 2022/2557 on the resilience of critical entities. Retrieved July 29, 2026, from <https://eur-lex.europa.eu/eli/dir/2022/2557/oj/eng>
- European Union Agency for Cybersecurity. (2025, October 1). *ENISA threat landscape 2025* (tech. rep.). European Union Agency for Cybersecurity. <https://doi.org/10.2824/1946374>
- Fenton, N., & Bieman, J. (2014). *Software metrics: A rigorous and practical approach* (3rd ed.). CRC Press. <https://doi.org/10.1201/b17461>
- Granata, D., & Rak, M. (2024). Systematic analysis of automated threat modelling techniques: Comparison of open-source tools. *Software Quality Journal*, 32(1), 125–161. <https://doi.org/10.1007/s11219-023-09634-4>
- Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75–105. <https://doi.org/10.2307/25148625>

- IEC. (2018, January 15). *IEC 62443-4-1: Security for industrial automation and control systems – part 4-1: Secure product development lifecycle requirements* (1st ed.). IEC Standard. IEC. Geneva, Switzerland. <https://webstore.iec.ch/en/publication/33615>
- IEC. (2020, June 24). *IEC 62443-3-2: Security for industrial automation and control systems – part 3-2: Security risk assessment for system design* (1st ed.). IEC Standard. IEC. Geneva, Switzerland. <https://webstore.iec.ch/en/publication/30727>
- ISO/IEC. (2016, June 13). *ISO/IEC 25023: Systems and software engineering – systems and software quality requirements and evaluation (SQuaRE) – measurement of system and software product quality* (1st ed.). International Standard. ISO/IEC. Geneva, Switzerland. <https://www.iso.org/standard/35747.html>
- ISO/IEC. (2023, November 15). *ISO/IEC 25010: Systems and software engineering – systems and software quality requirements and evaluation (SQuaRE) – product quality model* (2nd ed.). International Standard. ISO/IEC. Geneva, Switzerland. <https://www.iso.org/standard/78176.html>
- Kallio, H., Pietilä, A.-M., Johnson, M., & Kangasniemi, M. (2016). Systematic methodological review: Developing a framework for a qualitative semi-structured interview guide. *Journal of Advanced Nursing*, 72(12), 2954–2965. <https://doi.org/10.1111/jan.13031>
- Khan, R., McLaughlin, K., Lavery, D., & Sezer, S. (2017). STRIDE-based threat modeling for cyber-physical systems. *2017 IEEE PES Innovative Smart Grid Technologies Conference Europe (ISGT-Europe)*, 1–6. <https://doi.org/10.1109/ISGTEurope.2017.8260283>
- Krippendorff, K. (2018). *Content analysis: An introduction to its methodology* (4th ed.). SAGE Publications.
- Langner, R. (2011). Stuxnet: Dissecting a cyberwarfare weapon. *IEEE Security & Privacy*, 9(3), 49–51. <https://doi.org/10.1109/MSP.2011.67>
- Lincoln, Y. S., & Guba, E. G. (1985). *Naturalistic inquiry*. Sage.
- Maidl, M., Kröselberg, D., Zhao, T., & Limmer, T. (2021). System-specific risk rating of software vulnerabilities in industrial automation and control systems. *2021 IEEE International Symposium on Software Reliability Engineering Workshops (ISSREW)*, 327–332. <https://doi.org/10.1109/ISSREW53611.2021.00097>
- Maidl, M., Münz, G., Seltzsam, S., Wagner, M., Wirtz, R., & Heisel, M. (2021). Model-based threat modeling for cyber-physical systems: A computer-aided approach. In M. van Sinderen, L. A. Maciaszek, & H.-G. Fill (Eds.), *Software technologies* (pp. 158–183, Vol. 1447). Springer. https://doi.org/10.1007/978-3-030-83007-6_8
- Maidl, M., Wirtz, R., Zhao, T., Heisel, M., & Wagner, M. (2019). Pattern-based modeling of cyber-physical systems for analyzing security. *Proceedings of the 24th European Conference on Pattern Languages of Programs (EuroPLOP)*, 23:1–23:10. <https://doi.org/10.1145/3361149.3361172>
- Mathur, A. P., & Tippenhauer, N. O. (2016). SWaT: A water treatment testbed for research and training on ICS security. *2016 International Workshop on Cyber-Physical Systems for Smart Water Networks (CySWater)*, 31–36. <https://doi.org/10.1109/CySWater.2016.7469060>

- Mayring, P. (2000). Qualitative content analysis. *Forum Qualitative Sozialforschung / Forum: Qualitative Social Research*, 1(2), Article 20. <https://doi.org/10.17169/fqs-1.2.1089>
- McLaughlin, S., Konstantinou, C., Wang, X., Davi, L., Sadeghi, A.-R., Maniatakos, M., & Karri, R. (2016). The cybersecurity landscape in industrial control systems. *Proceedings of the IEEE*, 104(5), 1039–1057. <https://doi.org/10.1109/JPROC.2015.2512235>
- Messick, S. (1995). Validity of psychological assessment: Validation of inferences from persons' responses and performances as scientific inquiry into score meaning. *American Psychologist*, 50(9), 741–749. <https://doi.org/10.1037/0003-066X.50.9.741>
- Palinkas, L. A., Horwitz, S. M., Green, C. A., Wisdom, J. P., Duan, N., & Hoagwood, K. (2015). Purposeful sampling for qualitative data collection and analysis in mixed method implementation research. *Administration and Policy in Mental Health and Mental Health Services Research*, 42(5), 533–544. <https://doi.org/10.1007/s10488-013-0528-y>
- Phillips, S. C., Taylor, S., Boniface, M., Modafferi, S., & Surridge, M. (2024). Automated knowledge-based cybersecurity risk assessment of cyber-physical systems. *IEEE Access*, 12, 82482–82505. <https://doi.org/10.1109/ACCESS.2024.3404264>
- Shi, Z., Graffi, K., Starobinski, D., & Matyunin, N. (2022). Threat modeling tools: A taxonomy. *IEEE Security & Privacy*, 20(4), 29–39. <https://doi.org/10.1109/MSEC.2021.3125229>
- Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., Lightman, S., Hahn, A., Saravia, S., Sherule, A., & Thompson, M. (2023). *Guide to operational technology (OT) security* (tech. rep. No. Special Publication 800-82 Revision 3). National Institute of Standards and Technology. Gaithersburg, MD. <https://doi.org/10.6028/NIST.SP.800-82r3>
- Tuma, K., Çalikli, G., & Scandariato, R. (2018). Threat analysis of software systems: A systematic literature review. *Journal of Systems and Software*, 144, 275–294. <https://doi.org/10.1016/j.jss.2018.06.073>
- Zhou, Y., Zhang, Z., Fan, K., Wang, M., Cheng, K., Zhang, Z., & Zhang, H. (2025). A novel quantitative risk assessment model for industrial control systems integrating the cyber–physical domain. *IEEE Transactions on Industrial Informatics*, 21(8), 6433–6442. <https://doi.org/10.1109/TII.2025.3564074>
- Zibak, A., Sauerwein, C., & Simpson, A. C. (2022). Threat intelligence quality dimensions for research and practice. *Digital Threats: Research and Practice*, 3(4), Article 44, 1–22. <https://doi.org/10.1145/3484202>

A Semi-Structured Interview Guide

This appendix reproduces the semi-structured interview guide used to elicit expert knowledge on TRA quality (Chapters 4 and 5). The guide was tool-agnostic by design: it probes how experienced practitioners judge quality independently of any particular TRA software. Interviews were conducted with informed consent, and the responses were anonymised before analysis. Participants are referred to only by the identifiers E1–E5.

Study Framing Presented to Participants

Purpose. This interview aims to understand how experienced security professionals evaluate the quality of TRAs. The goal is to identify key quality indicators and to explore whether these can be translated into measurable metrics, independent of any specific tool or software used to perform the TRA.

TRA quality was considered along three main dimensions:

- **Coverage:** whether all relevant elements of the system and the analysis (assets, threats, interfaces, and scenarios) are addressed.
- **Consistency:** whether the different parts of the TRA are logically aligned and do not contradict one another.
- **Comprehensibility:** whether the TRA is clearly described in a way that allows reviewers to understand and follow the analysis.

Part 1: Background and Experience

1. Could you briefly describe your experience with TRA, including your role in creating, reviewing, or using TRA methods?
2. Roughly how many TRAs have you been involved with, whether creating, reviewing, or using them?

General

3. Could you please explain, in your own words, what makes a TRA “good” in quality?
4. Similarly, what makes a TRA “poor” in quality?

Part 2: The Review Process

5. Imagine you have just received a TRA to review. Please walk me through what you do first. What do you look at, and what questions do you ask yourself?

6. Are there any early signs that make you suspect a TRA may be low quality before you review it in detail? What are they?
7. What are the most common problems or gaps you have seen in TRAs, even ones that look complete on the surface?

Part 3: Coverage

8. What does good coverage in a TRA look like to you?
9. What do you look at to decide whether important threats, risks, assets, or scenarios are missing from a TRA?
10. Are there specific elements whose absence would immediately signal a serious quality problem in a TRA?

Part 4: Consistency

11. When you are reviewing a TRA, where do you typically look for inconsistency? Which sections do you cross-check against each other?
12. Can you give an example of an inconsistency you have encountered that significantly affected the quality of a TRA?

Part 5: Comprehensibility

13. What makes a threat description or risk justification easy to understand in a TRA?
14. What makes it difficult? What kinds of language issues, such as vagueness or unnecessary technicality, reduce TRA quality?
15. Have you ever reviewed a TRA where the content was technically present but difficult to follow or interpret? What made it hard to understand?
16. Are there specific sections or other parts of a TRA where clarity and comprehensibility matter most to you?

Part 6: Towards Measurable Quality

17. If you had to explain to a junior analyst exactly what to check to judge the quality of a TRA, what would your top three concrete checks be?
18. If you had to score or rate a TRA's quality, even informally, what would you base that score on?
19. Are there any parts of your review process that feel repetitive, that you check the same way every time?
20. Which parts of TRA quality do you think can be measured through automated checks?

21. In which areas does expert judgement remain essential?

Part 7: Closing

22. Do you have any advice for someone trying to develop a structured and automatable approach by identifying metrics to measure TRA quality?

B TRA Quality Criterion Catalogue: Definitions and Automation Classes

This appendix expands the consolidated catalogue of Table 6.2 into concise per-criterion definitions and measurement summaries. For each criterion it records the measurement performed on the structured TRA artefact and the degree of automation (*Auto* = fully automated from structured fields; *Semi* = automated signal requiring expert confirmation; *Expert* = criterion retained for manual expert assessment). Each computed core criterion is graded into one of three status bands (*ok*, *warning*, or *bad*), which are aggregated into the per-dimension scorecard using the status weights defined in Section 6.5 (*ok* = 100, *warning* = 60, *bad* = 20). Numeric thresholds referenced below are the prototype defaults of Section 6.6. The dimension-level automation totals derived from these assignments are summarised in Table 8.4.

Complete catalogue artefact. The complete working catalogue containing the detailed criterion attributes described in Section 6.2 is provided in the accompanying Git repository as docs/TRA_Quality_Metrics_Catalog.xlsx. The workbook supplements the condensed, printable definitions below with the detailed source traceability, required inputs, checking information, reviewer-judgement notes, and recorded priority information. The repository and its reproducibility artefacts are documented in Appendix D.

Table B.1: Definitions, measurement summaries, and automation classes of the TRA quality criteria

ID	Definition and measurement	Auto.
D1: Process and Governance		
CM-01	Whether metadata records participation of the relevant roles (e.g. product owner, architect, product security expert and officer) in the analysis.	Semi
CM-02	Living-document maintenance: whether the change date / version metadata shows the TRA was updated after its creation rather than left static.	Auto
CM-27	Authority-approval presence: explicit sign-off on key sections by an accountable role.	Auto*
CM-28	Known deficiency evidence references: linkage to security requirements, static analysis, penetration test results, vulnerability management, or end-of-life information.	Semi*
D2: Formal Completeness		
CM-03	Mandatory field and section completion: core sections (system overview, assumptions, assets, protection goals, threats) present and non-empty.	Auto
CM-04	Placeholder / unfinished entry detection: text fields scanned for template or open markers (e.g. "TBD", "to be discussed", "TODO").	Auto
CM-05	Assumption validation ratio: proportion of assumptions marked validated relative to all recorded assumptions.	Auto
D3: Coverage		

continued on next page

Table B.1, continued

ID	Definition and measurement	Auto.
CM-06	Component coverage: share of in-scope components referenced by at least one threat.	Auto
CM-07	Interface coverage: share of component interfaces referenced by at least one threat.	Auto
CM-08	External / network-facing interface coverage: share of externally exposed interfaces covered by at least one threat.	Auto
CM-09	Communication coverage: share of communication links addressed by at least one threat.	Auto
CM-10	Protection goal coverage: share of protection goals exercised by at least one threat.	Auto
CM-11	Asset coverage: share of assets mapped to at least one protection goal.	Auto
CM-12	Asset mapping to components / communications: share of assets linked to a component or communication.	Auto
CM-14	Out-of-scope boundaries: presence of explicit statements delimiting what is excluded from the analysis.	Semi
CM-16	No-threat / empty analysis red flag: decisive warning when the analysis contains no threats.	Auto
CM-29	Architecture-figure adequacy: whether the architecture figure is genuinely fit for analysis (not too abstract, detailed, or advertisement-like).	Expert
CM-30	Systematic threat identification method visibility: whether a recognisable method (question list, STRIDE, model-driven) is evident.	Expert
CM-31	Structured threat source utilisation: whether structured sources (CWE, CAPEC, ATT&CK) were used.	Expert
D4: Consistency and Traceability		
CM-17	Threat specificity: each threat is scored using interface linkage, matches against a curated reference vocabulary, and substantive, non-vague wording. It passes at a combined score ≥ 0.65 , which under the configured weights requires the concrete-language signal plus at least one other signal.	Semi
CM-18	Protection goal C/I/A balance: distribution of C/I/A goals across the analysis.	Auto
CM-19	Rating consistency across similar threats: variance of ratings within clusters of similar threats.	Semi
CM-20	Rating coherence and justification: final risk rating checked against the likelihood/impact matrix, and presence of explanatory rating comments.	Semi
CM-21	Risk-treatment / handling decision coverage: share of threats carrying a handling or treatment decision.	Auto
CM-22	Rating-distribution / rubber-stamping detector: flags degenerate distributions where ratings are uniformly identical.	Auto
CM-23	Assumption usage / linkage by type: whether assumptions are linked to the elements they qualify, by assumption type.	Auto
CM-24	Duplicate / similar-threat detection: near-duplicate threats identified by Jaccard token overlap (≥ 0.6).	Semi
CM-32	Architecture-to-component alignment: consistency between the architecture description and the enumerated components.	Expert
D5: Comprehensibility		

continued on next page

Table B.1, continued

ID	Definition and measurement	Auto.
CM-13	System overview presence: a system overview / description is present and of adequate length (≥ 20 words).	Semi
CM-15	Scope clarity: scope descriptions present and of adequate length (≥ 5 words).	Semi
CM-25	Threat-structure completeness: whether each threat states an actor, an action or substantive description, a target or interface, a weakness where represented, an impact, and a protection goal.	Semi
CM-26	Vagueness / imprecision reduction: flags threat descriptions dominated by vague or hedging wording (two or more vague / generic markers).	Semi

*CM-27 and CM-28 are computable in principle but depend on metadata that current TRA exports may not contain. Where the fields are absent, the criterion reports *not assessable* rather than a false pass.

C MiniCPS Reference TRA: Structured Summary

This appendix documents the hand-authored reference analysis (variant V0) used as the uncorrupted baseline of the mutation experiment (Section 8.4). It was written from the public MiniCPS/SWaT documentation before the metric formulae were consulted (Antonioli & Tippenhauer, 2015; Mathur & Tippenhauer, 2016), and it is reproduced here in structured summary form using identifiers and titles only. The public model therefore supports reproduction without disclosing confidential material. It targets the *Software* area and comprises 13 components across 6 security zones, 9 assets, 11 protection goals, 4 assumptions, and 13 threat scenarios. Tables C.1, C.2, and C.3 enumerate the zones, inventory, and threat scenarios used in the reference model.

Table C.1: Security zones (Purdue levels) of the reference model

ID	Zone
SZ-1	Plant Enterprise Network (Level 3)
SZ-2	Supervisory Network (Level 2)
SZ-3	Control Network (Level 1)
SZ-4	Field Network (Level 0)
SZ-5	Engineering Zone
SZ-6	External / Internet

The four recorded assumptions state that field wiring is physically protected (validated), the engineering workstation is hardened (validated), the plant boundary firewall provides segmentation (*not* validated), and the control protocols lack authentication (validated). The single unvalidated assumption is deliberate: it exercises the assumption-validation criterion (CM-05) on the clean baseline.

Table C.2: Components, assets, and protection goals of the reference model

Components (13)	Assets (9)	Protection goals (11)
PLC1: Raw Water Supply	Data-1 Sensor measurements	I-1 Integrity of sensor measurements
PLC2: Chemical Dosing	Data-2 PLC control logic and set-points	I-2 Integrity of actuator commands
PLC3: Ultrafiltration	Data-3 Actuator command signals	I-3 Integrity of PLC control logic
PLC4: Dechlorination	Data-4 Historian process database	A-1 Availability of water treatment process
PLC5: Reverse Osmosis	Data-5 HMI configuration and views	A-2 Availability of SCADA monitoring
PLC6: Permeate and Backwash	Data-6 Engineering project files	I-4 Integrity of historian data
SCADA / HMI Workstation	Func-1 Water treatment process operation	I-5 Integrity of HMI configuration
Process Historian	Func-2 Physical plant safety	I-6 Integrity of engineering project files
Engineering Workstation	Func-3 SCADA monitoring functionality	C-1 Confidentiality of process design and setpoints
Level-0 Field Devices		A-3 Physical plant and process safety
Plant Firewall		C-2 Confidentiality of historian reporting data
Vendor Remote Support		
Enterprise Reporting Client		

Table C.3: Threat scenarios of the reference model

ID	Threat scenario
T-1	False sensor data injection to PLC1
T-2	Actuator command manipulation on control ring
T-3	Unauthorised modification of PLC control logic
T-4	Denial of service on the control ring
T-5	Compromise of the SCADA/HMI workstation
T-6	Spoofed stop command halts raw water pump
T-7	Tampering with historian records
T-8	HMI alarm masking
T-9	Malware on engineering workstation alters controller project
T-10	Eavesdropping on unencrypted control traffic
T-11	Coordinated overflow of the raw water tank
T-12	Chemical overdose via dosing controller manipulation
T-13	Replay attack on dechlorination controller

D Reproducibility and Artefact Statement

The evaluation in Chapter 8 is designed to be independently reproducible from the public MiniCPS reference model of Appendix C and the accompanying project artefacts. This appendix records the artefacts and procedure required to regenerate the results.

Artefacts. The implementation consists of three Python programs:

- `src/tra_quality_report.py`: the analyser reads a TRA in JSON form, computes the criterion catalogue, and produces the per-dimension scorecard, a standalone interactive HTML report, and a machine-readable JSON metrics output (optionally with explicit output paths via `--html-out` and `--metrics-out`).
- `MiniCPS_Evaluation/run_mutation_experiment.py`: applies the thirteen mutation operators to the reference TRA, re-scores each variant, and writes the delta-status matrix, the delta-value matrix, the overall-score table, and the heat-map figure.
- `MiniCPS_Evaluation/run_sensitivity_analysis.py`: re-scores a clean, a mildly degraded, and a heavily degraded variant under three joint low/default/high threshold configurations and writes the sensitivity table.

Inputs and outputs. The reference model is `MiniCPS_Evaluation/tra/minicps_swat_tra.json`. The mutation script writes its variants to `MiniCPS_Evaluation/results/variants/V1.json` through `MiniCPS_Evaluation/results/variants/V13.json` and the tabular results to `MiniCPS_Evaluation/results/*.csv`. The heat-map figure is written to `MiniCPS_Evaluation/results/figures/delta_matrix.png` and appears as Figure 8.1. The good-threat vocabulary used by criterion CM-17 is read from the `data/Good_TRA_Threat_List` directory.

Traceability artefact. The full interview-to-metric traceability mapping is maintained separately in the workbook `docs/TRA_Quality_Metrics_Catalog.xlsx`. Within that artefact, the *Code-Aligned Core Set* sheet mirrors the current implementation in `src/tra_quality_report.py`, while the interview index and traceability matrix preserve the evidence links used to derive each criterion. In the thesis body, only the condensed catalogue summary is reproduced. The workbook is the project's detailed traceability source for the full evidence mapping.

Environment and procedure. The analyser core depends only on the Python 3 standard library. The mutation figure additionally uses `matplotlib` and `numpy`. The full experiment is intended to be reproduced by running, from the project directory, the analyser on the reference model, then the mutation experiment, and finally the sensitivity analysis. Each program

is self-contained and writes its outputs to the `MiniCPS_Evaluation/results` directory. Because the operators and thresholds are deterministic, the archived release should reproduce the scores reported in Tables 8.7 and 8.8. The three commands in Listing D.1 reproduce the full pipeline from the project directory.

```
# 1) Generate the HTML report and JSON metrics for the reference TRA
python src/tra_quality_report.py MiniCPS_Evaluation/tra/minicps_swat_tra.json

# 2) Run the controlled mutation experiment (writes MiniCPS_Evaluation/results/)
python MiniCPS_Evaluation/run_mutation_experiment.py

# 3) Run the threshold sensitivity analysis
python MiniCPS_Evaluation/run_sensitivity_analysis.py
```

Listing D.1: Copy-paste reproduction commands, run from the project directory

Repository availability. The accompanying project repository is available on GitHub: [masterThesis-tra-quality-metrics-framework](https://github.com/masterThesis-tra-quality-metrics-framework).

E Mutation Operators and Predeclared Target Map

This appendix specifies the thirteen mutation operators of the L1 experiment (Section 8.4) and the design-intent target map against which detector precision and recall are computed. Each operator takes a fresh copy of the reference model (variant V0, Appendix C) and injects exactly one defect class. The *target criteria* column is the set of criteria that the defect is *designed* to degrade. It is declared in the experiment driver independently of the observed results, so that the precision/recall figures of Appendix F are evaluated against a fixed, inspectable target map rather than fitted after the fact. A defect is counted as detected when a targeted criterion’s traffic-light status drops (status-weight delta < 0).

Table E.1: The thirteen mutation operators and their design-intent target criteria

Variant	Injected defect (one class per variant)	Target criteria
V1	Placeholder text (“TBD” / open questions) left in fields	CM-04
V2	System overview and scope description removed	CM-03, CM-13, CM-14, CM-15
V3	In-scope components added with no linked threat	CM-06
V4	Network-facing interfaces left unattacked	CM-07
V5	Protection goals never referenced by any threat	CM-10
V6	Threat descriptions reduced to single keywords	CM-17, CM-25
V7	Rating-rationale or handling-decision fields blanked	CM-20, CM-21
V8	Risk rating contradicts impact × likelihood	CM-20
V9	Near-identical threats cloned and assigned contradictory ratings	CM-19, CM-24
V10	Inconsistent version and date metadata	CM-02
V11	Assumptions marked unvalidated	CM-05
V12	Required treatment or threat-structure fields dropped	CM-21, CM-25
V13	Keyword-stuffed evasion (verbose but non-distinctive wording, component link kept)	CM-17

The operators mutate the structured artefact deterministically, so the variants MiniCPS_Evaluation/results/variants/V1.json through MiniCPS_Evaluation/results/variants/V13.json and the downstream scores are intended to be reproduced on re-execution of the archived release (Appendix D). Variant V13 is an *evasion* case: unlike V6, which degrades the wording so crudely that several gates fire, V13 keeps a plausible length and a valid component link but uses only generic wording outside the curated reference vocabulary. The concrete-language signal therefore remains absent. Linkage and length contribute only 0.60, below the CM-17 pass threshold of 0.65.

F Per-Variant Detector Classification

Table F.1 reproduces the TP, FP, and FN counts for each variant behind the aggregate precision, recall, and F_1 reported in Section 8.4. For each variant, a targeted criterion whose status band drops is a TP. A targeted criterion that does not drop is an FN, and a non-targeted criterion that drops is an FP. The values are read directly from `results/precision_recall.csv`, which the experiment driver writes against the fixed target map of Table E.1.

Table F.1: Detector classification per variant (status-band level)

Variant	Target criteria	TP	FP	FN	Off-target
V1	CM-04	1	0	0	None
V2	CM-03, CM-13, CM-14, CM-15	4	0	0	None
V3	CM-06	1	0	0	None
V4	CM-07	1	0	0	None
V5	CM-10	1	0	0	None
V6	CM-17, CM-25	2	1	0	CM-24
V7	CM-20, CM-21	2	0	0	None
V8	CM-20	1	0	0	None
V9	CM-19, CM-24	1	0	1	None
V10	CM-02	1	0	0	None
V11	CM-05	1	0	0	None
V12	CM-21, CM-25	2	0	0	None
V13	CM-17	1	1	0	CM-24
Total		19	2	1	

The aggregate detector performance is summarised in Equation F.1:

$$\text{precision} = \frac{19}{19 + 2} = 0.905, \quad \text{recall} = \frac{19}{19 + 1} = 0.950, \quad F_1 = 0.927. \quad (\text{F.1})$$

These values match the figures quoted in the main text. The remaining FN is *v9/CM-19*, where the contradictory rating mutation lowers continuous consistency and therefore verifies the CM-19 contradiction logic at the value level, but status-band accounting is constrained by the baseline *n/a* state for similar pair consistency. Variants *v3* and *v13* are TPs under the strengthened mutations. The two FPs are both CM-24 near-duplicate flags that are semantically coherent side effects of the edit: *v6/CM-24* (single-keyword descriptions become genuinely near-identical) and *v13/CM-24* (boilerplate descriptions are likewise near-identical). Neither is spurious crosstalk, and no *unrelated* criterion crosses a band.

G L3 Comparison Protocol and Agreement Computation

This appendix documents the protocol behind the descriptive L3 comparison of Section 8.6.4. It records, in order, (i) how the three reports were produced and what evidential basis each one uses, (ii) how their differing verdict vocabularies are normalised onto one common scale, (iii) how the two agreement figures quoted in the main text are computed from Table 8.12, and (iv) the validity threats specific to a single-case, LLM-based comparison and how they are contained. The intent is that every agreement number in Section 8.6.4 can be re-derived by hand from the published status table, so the comparison is auditable rather than asserted.

G.1 Report Sources

All three reports judge the *same* TRA artefact, so any difference between them is a difference in *how* the analysis is judged, not in *what* is judged. Reports A and C are LLM-generated interpretation reports, produced by *ChatGPT* (GPT-5.4) and *Claude Sonnet 4.6* respectively, each prompted to judge the analysis as a reviewer would, focusing on semantic adequacy and domain plausibility. Report B is produced directly by the deterministic rule-based checker of Chapter 7, which reads only the structured schema. All three were made to follow the same criterion catalogue (Chapter 6) as a shared rubric, which is the precondition that makes a criterion-by-criterion comparison legitimate. Table G.1 records the producer, evidential basis, and verdict process for each report.

Table G.1: The three L3 reports, the tool that produced each, and its evidential basis.

Report	Produced by	Basis	How the verdict is reached
A	ChatGPT (GPT-5.4)	LLM, semantic	LLM prompted to interpret the analysis as a reviewer against the shared catalogue.
B	Rule-based checker	Structured schema	Deterministic checker of Chapter 7; verdict computed from schema fields only.
C	Claude Sonnet 4.6	LLM, semantic	LLM prompted to interpret the analysis as a reviewer against the shared catalogue.

The identity of the two LLMs is recorded here for provenance and auditability. The underlying TRA artefact itself remains confidential: concrete file names and any partner-identifying content are kept only in the internal project archive and are not reproduced, so the comparison relies only on the per-criterion verdicts and the kind of evidence each report rests on.

G.2 Label Normalisation

The three reports use different verdict vocabularies, so each per-criterion verdict is first mapped onto one common three-level ordinal scale before any comparison is made. The mapping is fixed in advance and applied identically to all three reports.

Table G.2: Normalisation of raw report verdicts onto the common scale used for the agreement computation.

Raw verdict	Normalised level	Counts as a flagged gap?
GOOD	good	No
REVIEW	review	Yes
CRITICAL	critical	Yes
N/A	not assessable	Excluded from both agreement views

A *not assessable* verdict is excluded rather than treated as a pass or a fail, exactly as in the main scoring scheme (Section 6.5), so that a criterion no report could judge cannot inflate or deflate the agreement.

G.3 Agreement Computation

Two complementary agreement views are reported. *Exact-label agreement* between two reports is the fraction of the eight shared criteria on which both carry the identical normalised level. *Gap-presence agreement* asks only whether each report flags a concern at all, meaning whether its normalised level is *review* or *critical*. It therefore tolerates severity-calibration differences between a structured checker and an LLM interpretation. Both are read directly off the status table (Table 8.12). The per-criterion comparison is reproduced in Table G.3, where = marks an identical normalised level and ≠ a difference.

Table G.3: Per-criterion derivation of the exact-label agreement figures from Table 8.12. Columns A/B/C give the normalised level; the last three columns mark whether each pair matches.

Criterion	A	B	C	A,B	C,B	A,C
CM-13	review	good	review	≠	≠	=
CM-15	review	review	review	=	=	=
CM-17	review	review	critical	=	≠	≠
CM-19	review	good	critical	≠	≠	≠
CM-20	review	good	review	≠	≠	=
CM-24	review	review	critical	=	≠	≠
CM-25	review	review	review	=	=	=
CM-26	review	good	critical	≠	≠	≠
Agreement				4/8	2/8	4/8

The exact-label figures are therefore 4/8 between Reports A and B (they agree on CM-15, CM-17, CM-24, CM-25), 2/8 between Reports C and B (CM-15, CM-25), and 4/8 between the two LLM reports A (ChatGPT) and C (Claude Sonnet 4.6), which agree on CM-13, CM-15, CM-20, and CM-25. These are the values quoted in Section 8.6.4.

For gap-presence, applying the “flagged gap” column of Table G.2 to the same rows shows that the two LLM reports (A and C) flag a concern on *all eight* shared criteria, whereas the structured checker (B) flags a concern on four (CM-15, CM-17, CM-24, CM-25). The criteria on which *all three* reports flag a concern are exactly four: CM-15, CM-17, CM-24, and CM-25.

This is the qualitative overlap reported in the main text. The stronger gap-presence overlap than exact-label overlap is expected: separately generated reports point at the same problem areas even when they calibrate severity differently.

G.4 Validity Threats Specific to L3

Because L3 is a single-case, LLM-based comparison, four threats deserve to be named explicitly alongside the general threats of Section 8.7.

- **Single shared case.** All figures come from one TRA artefact, so they characterise agreement on that case and cannot support statistical inference. *Containment:* every agreement value is reported descriptively and at case level, and extension to more TRAs is stated as future work.
- **Subjectivity and non-determinism of the LLM reports.** Reports A and C are LLM outputs, so both are subject to interpretation variability, prompt sensitivity, and run-to-run variation, and each reflects the tendencies of its particular model. *Containment:* using two different models (ChatGPT and Claude Sonnet 4.6) exposes model-specific bias. All three reports were evaluated against the same criterion catalogue as a fixed rubric. The comparison was restricted to the eight criteria all three actually addressed, and agreement was read at the ordinal-label and gap-presence level rather than from raw scores, so a small wording change in one report cannot move the reported figures.
- **No independent validity standard.** General-purpose LLM agreement is not a substitute for domain-expert judgement, and all reports used the same criterion catalogue, which can induce agreement through shared framing. *Containment:* L3 is described only as an illustration of assessment-route convergence and divergence. It is not used to validate a criterion or the overall framework.
- **Compression by normalisation.** Mapping a finer verdict onto three levels can hide nuance. *Containment:* the coarser gap-presence view is reported alongside the exact-label view precisely so that a conclusion never rests on a single, possibly brittle severity label.

H Threshold Sensitivity Sweep Design

The threshold sensitivity analysis of Section 8.4 tests whether the comparative ranking clean > mild > heavy survives reasonable changes to the prototype threshold defaults of Section 6.6. This appendix documents the *sweep design* that produced the results table in the main text (Table 8.8). It is complementary to the prototype defaults, which are not repeated here. The five thresholds are evaluated in three joint configurations: all low, all default, and all high. The three representative cases are re-scored, and the original values are then restored, so the sweep does not change the operational defaults. Table H.1 records the low, default, and high values used for each swept threshold.

Table H.1: Threshold sweep ranges (default column = prototype value of Section 6.6)

Threshold	Low	Default	High
Keyword-only minimum words (CM-17/CM-25)	4	6	8
System overview minimum words (CM-13)	15	20	30
Scope description minimum words (CM-15)	3	5	8
Near-duplicate Jaccard threshold (CM-19/CM-24)	0.5	0.6	0.7
Threat-specificity pass threshold (CM-17)	0.55	0.65	0.75

The three representative cases are the clean reference (V0), a mild, localised defect (V4: a single unattacked interface), and a severe structural defect (V2: the system overview and scope descriptions removed). As reported in Table 8.8, the ranking $V0 > \text{mild} > \text{heavy}$ is preserved in all three joint configurations. This result is limited to the tested ranges and these three clearly separated cases.

I Worked Example: Reference Scorecard

To illustrate the checker's output, Table I.1 reproduces the per-dimension scorecard produced for the clean reference TRA (variant V0, Appendix C). These are the values written to `results/overall_scores.csv` and correspond to the baseline overall indicator of 89.6 used throughout Section 8.4. Each dimension score is the status-weighted aggregate of its criteria (ok = 100, warning = 60, bad = 20), as defined in Section 6.5.

Table I.1: Reference-TRA (V0) scorecard as produced by the analyser

Dimension	Score
Process & Governance	100.0
Formal Completeness	86.7
Coverage	86.7
Consistency & Traceability	86.7
Comprehensibility	100.0
Overall	89.6

The clean reference does not score a perfect 100: the single deliberately unvalidated assumption (Appendix C) keeps Formal Completeness below the ceiling. The coverage and consistency dimensions also reflect that a realistic hand-authored analysis is not exhaustive. This baseline is the reference point against which every degraded variant in Table 8.7 is compared.